CRECISOL
DOCUMENTO MAESTRO ÚNICO

Producto SaaS multitenant · Seguridad integral · Arquitectura limpia · Desarrollo local secuencial

IDENTIDAD	ALCANCE AUTORIZADO
Marca de trabajo	CRECISOL - Tu negocio, a tu manera.
Estado real	Especificacion consolidada. Software no certificado. Ninguna implantacion productiva.
Ejecución	37 capítulos en orden, tres auditorías por capítulo, desarrollo de código exclusivamente local.
Estructura	frontend/ · backend/ · database/ - tres areas independientes dentro de un mismo proyecto.
Persistencia	Base MySQL compartida por defecto + base dedicada opcional por tenant, con el mismo código.
Titularidad	Cada negocio: usuarios, perfiles, fotos, módulos, datos, configuración, sesiones y auditoría propios.
Protección institucional	SOLQARYN: consulta autorizada y solo lectura. Ninguna escritura o cambio remoto.

Consolidación original: 7 de noviembre de 2026. Ampliación universal de seguimiento: 8 de noviembre de 2026. Documento de especificación; no acredita software desarrollado ni certificado.

Un solo contenido maestro emitido en dos formatos equivalentes: Word editable y PDF imprimible.

CONTROL DOCUMENTAL

Objeto, jerarquía y procedencia

Se integran las tres evidencias adjuntas en una especificacion única, sin multiplicar planes ni perder las 37 secciones del origen.

Entrada	Naturaleza comprobada	Tratamiento en el maestro
DOCX original 05/11/2026	Diseño SaaS de 37 capítulos y 84 tablas.	Se conserva cada bloque sustantivo y cada tabla, en secuencia y con el texto de origen.
DOCX desarrollo 07/11/2026	Reglamento, arquitectura de tres areas, fichas y auditoría triple.	Se integran normas y fichas de ejecución debajo del capítulo correspondiente.
PDF consolidado 139 pp.	Compilacion del plan DOCX y del diseño maestro original.	Se contrasta como tercera evidencia, sin copiar el mismo contenido dos veces.
Instrucciones posteriores	Prioridad absoluta a seguridad, SuperAdmin, datos y auditorías aislados; DB compartida/dedicada.	Son ampliaciones vinculantes incorporadas con puertas de aceptacion y pruebas.

Precedencia operativa: controles de seguridad, privacidad y ley aplicable > instrucciones explicitas más recientes del propietario compatibles con dichos controles > diseño maestro original > plan de desarrollo anterior > decisiones tecnicas propuestas. El texto original se preserva para trazabilidad; ante contradiccion rige la regla nueva explicita y se registra el impacto.

Autorización de herramientas: las credenciales o conectores disponibles no constituyen instruccion para efectuar despliegues o escribir en SOLQARYN. El trabajo actual solo autoriza la consolidación documental local de CRECISOL.

POLÍTICA DE PRODUCTO

Reglas institucionales irreversibles

- Un solo producto CRECISOL, con código compartido y módulos reutilizables; sin instalaciones separadas por rubro ni duplicaciones de lógica.
- Cada tenant opera su espacio aislado: usuarios, roles, membresias, sesiones, sucursales, módulos habilitados, configuraciones, clientes, archivos, reportes, ventas y auditoría propios.
- Nadie del tenant A puede leer, modificar, enumerar, restaurar, exportar ni inferir información o configuraciones privadas del tenant B; tampoco puede leer datos internos del plano de control CRECISOL.
- Toda persona autenticada -plataforma, propietario, empleado, consumidor o subcuenta autorizada- dispone de registro o invitacion, perfil con foto segura, datos de contacto, cambio y recuperación de credenciales; jamas hereda privilegios entre tenants.
- SuperAdmin gobierna y visualiza todas las interfaces y funciones administrativas del SaaS, con controles reforzados para datos privados y operaciones peligrosas; no existe superpoder irrestricto invisible.
- Persistencia hibrida: SHARED por defecto con limites logicos verificados; DEDICATED por tenant a peticion, incluso bases gestionadas por el cliente si pasan controles de admision, soporte y compatibilidad.
- No se utiliza ningun identificador o dominio del navegador como prueba suficiente de pertenencia o permiso; el servidor verifica identidad, pertenencia, alcance, acción y recurso.
- El inicio de sesion de usuarios de negocios y consumidores resuelve automaticamente el tenant autorizado SIN selector de empresas. El SuperAdmin accede a CRECISOL mediante un realm separado y abre empresas solo desde el gestor con autorización especial.
- Todo parametro comercial y visual permitido se edita mediante administración, con una fuente por clave/ambito/revisión y vista previa; nunca se ofrece ejecutar SQL o JS arbitrarios desde CMS.
- La plataforma usa Angular, ASP.NET Core, MySQL y Node.js 24 como entorno de herramientas; el código se divide en frontend/, backend/ y database/ y se mantiene liviano.
- Cada capítulo se implementa individualmente, con pruebas funcionales, aislamiento, UI, rendimiento y tres auditorías independientes con evidencia reproducible.
- No se crean repositorios, despliegues ni servicios de infraestructura en la fase de código local; no se modifica nada perteneciente a SOLQARYN.

ARQUITECTURA NORMATIVA

A. Fronteras de confianza: producto y tenants

CRECISOL comparte ejecutables y componentes; no mezcla activos, identidades ni resultados de negocios. La frontera de seguridad existe en el servidor y se comprueba en todas las superficies.

Plano / recurso	Propietario y almacen	Exposición autorizada
Plano de control SaaS	CRECISOL: operadores, tenant registry, placement, planes, contratos, controles globales y auditoría de plataforma.	Unicamente identidades de plataforma autorizadas; ningun endpoint de tenant puede consultarlo.
Identidad de plataforma	Operadores CRECISOL, sesiones MFA y privilegios globales separados.	Ni propietarios ni empleados de tenant reciben claims de plataforma.
Espacio de tenant	Usuarios del negocio, perfiles, roles, configuraciones, sucursales, clientes, ventas, medios y reportes.	Solo su tenant y usuarios con permisos vigentes, incluso cuando otro negocio use los mismos módulos.
Bitácora de tenant	Eventos aislados bajo el propietario tenant, con integridad y retención propia.	Lectura solo desde ese tenant; acceso excepcional de CRECISOL mediante servicio de soporte auditado.
Auditoría de plataforma	Eventos de superadmin, cambios de placement, acceso de soporte y seguridad global.	Jamás visible por cuentas tenant; no volcar PII de otros negocios.
Componentes y código	Frontend, API, casos de uso, modelos, componentes del design system.	Se comparten binarios y definiciones, nunca registros privados por defecto.
Telemetria global	Solo metricas tecnicas/consumos agregados, minimizados por política.	No exponer listas de clientes u operaciones de una empresa a otra.

Interpretacion de "sin duplicar": los componentes, contratos, plantillas de código y migraciones son compartidos. Los datos, configuraciones y auditorías de cada tenant son privados. Una persona puede tener membresias separadas en negocios distintos, pero no hereda permisos o datos entre ellos.

B. Dos modelos de datos, un solo código

La modalidad no cambia la API ni el contrato de los módulos. El control plane guarda la ubicación autorizada; cada solicitud escoge un almacén seguro a traves de infraestructura interna, nunca de una cadena de conexión enviada por el cliente.

Perfil	Descripcion	Límite de seguridad / validación
SHARED (defecto)	Un MySQL logico con tablas tenant-owned compartidas; tenant_id obligatorio y relaciones compuestas donde aplique.	Aplicación tenant-aware + repositorios estrictos + FK compuestas + accesos DB mínimos + pruebas negativas contra cada consulta.
DEDICATED MANAGED	Base MySQL independiente para un solo negocio, con misma versión lógica del esquema y migraciones.	Credenciales dedicadas de privilegio mínimo; backup/restore, monitoreo, limites de conexión, red y cifrado evaluados por separado.
DEDICATED CUSTOMER HOSTED (condicionado)	Base MySQL del propio cliente fuera de la plataforma, si el contrato y las pruebas tecnicas lo permiten.	Sin URLs ni credenciales arbitrarias por API: admision revisada, TLS, egress allowlist, conectividad y versiones compatibles, respaldo y plan de incidentes.

Nota: MySQL 8.4 no debe tratarse como si ofreciera las mismas políticas nativas RLS de PostgreSQL. En SHARED, depender de un WHERE manual aislado o de un global filter EF es insuficiente: se exige cobertura de todas las rutas, autenticación del scope, llaves/FK compuestas, SQL restringido, revisiones de comandos crudos y pruebas integrales. Vistas/procedimientos y privilegios MySQL se podrán usar como defensa adicional sin confundirlos con RLS nativo.

No se promete portabilidad sin condiciones a cualquier motor de datos ni administración segura de cualquier servidor externo. El contrato de almacen exige dialecto soportado, versión, backups, red, capacidad y control de integridad verificados antes de habilitar BYODB.

C. Catálogo de ubicaciones y datos

Plano de control (CRECISOL)	Espacio tenant SHARED o DEDICATED	Prohibicion
platform_admin, platform_permissions, platform_audit	tenant_users, tenant_user_profiles, tenant_roles, tenant_role_grants	Nunca listar usuarios de otro tenant ni miembros de plataforma.
tenant_registry, tenant_placements, verified_domains	tenant_sessions, tenant_memberships, tenant_modules, tenant_settings	Una sesion no cambia de negocio por editar tenant_id.
plans, contract_versions, entitlements, global health	branches, customers, orders, appointments, memberships	El plano tenant no consulta contratos SaaS globales.
support_grants, protected_secret_references	media_metadata, file_access, tenant_audit_events	El secreto DB no viaja a frontend ni logs.

D. Resolución de contexto y autorización efectiva

01. 01. Validar origen, host y dominio registrado como VERIFIED; el host indica el contexto del sitio, pero no es por si solo una autorización.
02. 02. Autenticar al principal y validar el tipo de cuenta: PLATFORM_ADMIN o TENANT_PRINCIPAL, sin mezclar roles.
03. 03. Para solicitudes tenant, resolver automaticamente la única pertenencia autorizada en el contexto verificado (dominio de negocio o cuenta con membresia única). Nunca pedir ni mostrar selector empresarial en login; si hay ambiguedad, no elegir arbitrariamente: exigir enlace contextual del negocio y fallar cerrado.
04. 04. Crear TenantContext inmutable, firmado o mantenido internamente, que incluya tenantId, actorId, branchScope, permissionsVersion, requestCorrelationId, placementId.
05. 05. Evaluar ActionPolicy y ABAC por recurso real: propiedad, branch, estado, contrato, permiso y finalidad; aplicar deny-by-default.
06. 06. Resolver TenantPlacement desde registro protegido del plano de control y obtener conexión mediante TenantConnectionFactory solo después de autenticar, comprobar membresia y autorizar; rechazar placement inexistente/inactivo.
07. 07. Consultar solo repositorios tenant-scoped; toda PK/FK de tablas privadas obliga coherencia del tenant. Deshabilitar rutas no-scoped por defecto.
08. 08. Proyectar DTOs autorizados por campos; no enviar entidades EF, PII o atributos administrativos por comodidad.
09. 09. Aislar cache, media, outbox, notificaciones, reportes y eventos mediante contexto verificado; revalidar al consumir tareas asincronas.
10. 10. Emitir auditoría del tenant o del plano de plataforma segun el actor; nunca mezclar los indices de consulta ni revelar registros externos.

E. Registro de componentes/contratos

Componente	Contrato requerido	Prueba de rechazo
TenantContextResolver	Resolve(verifiedHost, authenticatedActor, memberships) -> immutable TenantContext	Cambia Host/slug/claim/tenantId: no aumenta acceso; no listado de tenants en login.
TenantPlacementRegistry	ResolvePlacement(tenantId) -> SHARED | DEDICATED + secretRef + schemaVersion	No acepta JDBC/URL/connectionString del navegador.
TenantConnectionFactory	Open(placement, readonly/writeRole), pools por placement, sin fuga de contexto	A tras B en mismo pool: no mezcla session ni DB.
TenantScopedRepository	Query(context, aggregate), no unscoped salvo operación de plataforma separada	Raw SQL sin restriccion o nueva tabla sin clasificación: CI rechaza.
TenantAuthorization	authorize(actor, tenant, branch, action, resource, entitlements)	Rol de A/B y revocaciones: denegados con resultado estable.
TenantAuditWriter	Append(event, scoped actor, correlationId, privacyClass)	Intercambio de audit tenantId: lectura y escritura negadas.

F. SuperAdmin: control total con puertas seguras

SuperAdmin administra todo el SaaS y puede inspeccionar sus interfaces y configuraciones; no debe existir una cuenta tenant disfrazada de operador global ni una suplantacion silenciosa.

Capacidad	Permitida con	Protección obligatoria
Inventario de todas las interfaces	Visualizador catalogado por sector, plan, rol y estado.	Vista de demo con datos sintéticos por defecto; ningun dato real de tercero.
Administración global	Identidad exclusiva de plataforma, MFA/passkey, roles de plataforma.	Aprobación y auditoría de planes, dominios, tenants, claves, placement y soporte.
Inspeccion del negocio real	Sesion de soporte scoped con motivo, ticket, tenant, tiempo y permisos de solo lectura.	Banner visible modo soporte; campos sensibles minimizados; registro en audit plataforma y evento tenant.
Cambio administrativo sensible	Step-up y permiso especifico; cuatro ojos en acciones de alto riesgo cuando aplique.	Sin acceso directo DB como usuario de aplicación; expiracion, revocación y replay.
Break-glass de incidente	Política excepcional auditada, tiempo limitado y revisión independiente.	Justificacion, alerta, actividad inmutable, cierre y evidencia posterior.
Metrica global	Aggregates anonimizados y operativos.	Sin exportar compras, nombres de clientes ni mensajes de otros negocios.

Acceso a "todas las interfaces" no equivale a acceso permanente e indiscriminado a cada dato de consumidor. La empresa CRECISOL gobierna la plataforma, mientras que la lectura de información privada se limita por finalidad, necesidad, contrato y ley aplicable.

G. Aislamiento de identidad y módulos por tenant

- Cada tenant posee su registro logico de miembros, perfil, roles, permisos, sesiones tenant-contextuales y bitácoras; se puede usar un verificador de credenciales central para autenticar sin que se mezclen las membresias.
- Una misma persona vinculada a dos negocios recibe dos espacios de pertenencia y autorización separados; accede desde el enlace/dominio verificado de cada negocio, sin selector empresarial en login ni panel multitenant consolidado.
- Los módulos implementados comparten el mismo código fuente; su habilitacion, sus opciones, datos, branding, plantillas y limites comerciales se almacenan por tenant y versión.
- Revocar una membresia invalida las sesiones/caches/colas autorizadas para ese tenant sin afectar indebidamente una membresia distinta.
- El panel de CRECISOL puede inspeccionar funciones en modo sintético universal y supervisar el estado de cada tenant sin confundir la auditoría de soporte con la del usuario del negocio.

SEGURIDAD DE CUENTAS | REQUISITO UNIVERSAL

G.1. Registro integral, perfiles y recuperación de acceso

Toda persona que necesite cuenta, sea operador de CRECISOL, propietario, administrador, empleado, consumidor o cliente de un negocio, debe disponer de un ciclo de identidad completo y seguro dentro del alcance de su relación. Registrar una persona no le otorga ninguna pertenencia ajena ni privilegios de plataforma.

Tipo de persona	Registro y experiencia	Regla de aislamiento
Personal CRECISOL / SuperAdmin	Alta exclusiva por invitación y aprobación de plataforma; foto, perfil, contacto verificado, passkey/MFA, sesiones y recuperación reforzada.	Realm PLATFORM_ADMIN independiente; nunca autenticación global como usuario de negocio.
Propietario / administrador del negocio	Onboarding por invitación o contratación verificada; perfil y foto, seguridad de cuenta, contexto de empresa, sucursales y roles.	Las acciones pertenecen solo a su tenant y alcance permitido; nunca ve planos privados CRECISOL.
Empleados y colaboradores	Invitación con expiración, aceptación de condiciones, perfil, foto opcional, acceso revocable y recuperación.	Permisos por acción/sucursal/turno; retirar del negocio no concede acceso a otro.
Cliente final / consumidor del negocio	Alta contextual voluntaria, perfil personal, contacto verificado, foto opcional, historial y cuenta recuperable.	Historial, reservas, QR, consentimientos y medios segregados por tenant; no revela relación con otros negocios.
Usuario de cliente de un cliente, cuando exista relación autorizada	La misma experiencia segura se aplica a roles B2B2C o subcuentas expresamente modeladas; creación con consentimiento y roles limitados.	No existe herencia ilimitada de permisos ni datos por cadena comercial. Cada relación se autoriza explícitamente.

El requisito «todos pueden registrarse» no significa registro público de administradores o empleados: esos roles nacen de invitaciones y aprobaciones autorizadas. Tampoco exige recolectar PII innecesaria; formulario y campos obligatorios dependen de finalidad, legislación, edad y rol.

G.2. Contrato único de perfil y autenticación

Dominio de datos	Contenido mínimo administrable / protegido	Propiedad y control
Perfil personal visible	Nombre preferido, foto, idioma, zona horaria, preferencias de accesibilidad, canales de contacto con visibilidad por campo.	Edita titular autenticado; permisos sobre otros perfiles solo por caso de uso autorizado.
Datos de contacto	Correo con estado verificado, teléfono opcional verificado, preferencias de avisos y consentimientos versionados.	Cambio de correo con verificación del nuevo canal y reautenticación según riesgo; no enumerar cuentas.
Credenciales	Password hash Argon2id (parámetros revisados), passkeys/WebAuthn, MFA de administradores y códigos de respaldo de un solo uso.	Credenciales nunca visibles al tenant ni en API pública; secretos de verificación en almacén protegido.
Sesiones y dispositivos	Sesión, familia de refresh, hora, agente/huella minimizada, factor, revocación, propósito y contexto de autorización.	Revocación servidor; sesiones de plataforma y tenant no intercambiables; no tokens duraderos en localStorage.

Dominio de datos	Contenido mínimo administrable / protegido	Propiedad y control
Foto / medios de perfil	ID de activo con owner, tenant/realm, estado de revisión, MIME real, dimensiones, tamaño, variante y visibilidad.	Carga temporal en cuarentena, revalidación de MIME/decodificación, EXIF controlado, ACL, enlaces cortos y aislamiento R2/local.
Relaciones tenant	Membership tenant, rol y grant, branch, consumer-link, estado, consentimientos y access versión.	No autoenlazar cuentas de distintos tenants por email, nombre o ID de foto.
Recuperación	Tokens aleatorios de un solo uso almacenados como hash, vencimiento, propósito, consumo, aviso y revocación.	Respuestas neutras, rate limiting por cuenta/IP/riesgo; tokens nunca en logs/Referer.
Historial de seguridad	Eventos de login, enrolamiento, cambio de email, contraseña, MFA, foto, sesión, invitación y recuperación.	PLATFORM_AUDIT o TENANT_AUDIT según realm; evidencia mínima sin contraseñas ni tokens.

Modelo recomendado: IdentityPrincipal y CredentialVault pertenecen al servicio protegido de identidad; PlatformOperator y TenantMembership/ScopedProfile son relaciones separadas. Un principal puede estar autorizado en dos empresas, pero una empresa no obtiene el perfil ni la existencia de la otra relación. El aislamiento de identidad incluye el buscador, las invitaciones, los mensajes y las fotografías.

G.3. Flujos de cuenta exigidos antes de certificar

01. Registro público de consumidor o propietario habilitado: abrir un dominio o invitación verificados del negocio -> validar email y antiautomatización -> aceptación de políticas vigentes -> credencial segura o passkey -> correo de confirmación neutro -> activar solo la relación concreta. Un invitado no recibe permisos antes de aceptar invitación válida.
02. Invitación de empleado: actor autorizado crea invitación de tenant y rol dentro de su techo -> vínculo único con expiración -> receptor verifica email -> se vincula al tenant correcto -> se audita alta. Enlaces de otro tenant o reusados no sirven.
03. Perfil y foto: seleccionar archivo -> vista previa local no confiable -> subir a cuarentena con límites -> revalidar formato real, decodificar/re-encode y retirar EXIF sensible -> comprobar ownership -> guardar revisión -> vista previa autorizada -> publicar variante limpia y revocar URLs antiguas.
04. Contraseña: verificar identidad y sesión con step-up si aplica -> comprobar clave actual cuando corresponda -> política de longitud/compromiso -> hash resistente con sal individual -> rotar credencial y revocar sesiones de riesgo -> notificar sin revelar secreto. Nunca mostrar ni reenviar contraseña existente.
05. Recuperación de contraseña: mensaje no enumerativo -> token de alta entropía de único uso y propósito -> enlace en dominio verificado -> expiración breve y validación de token en servidor -> contraseña nueva -> invalidar sesiones/tokens de recuperación -> notificar; cuentas privilegiadas exigen paso reforzado.
06. Pérdida de MFA o correo: códigos de respaldo o passkey alterna; si soporte interviene, doble control para privilegios globales, verificación proporcional, retraso por riesgo, alertas a canales previos y auditoría. Prohibidas preguntas de seguridad.
07. Cambio de email o teléfono: verificación del canal nuevo y confirmación/reautenticación reforzada según riesgo; evitar toma de cuenta usando exclusivamente un canal recién cambiado. Versionar preferencias de notificación.
08. Eliminar/suspender usuario: revocar relaciones y sesiones efectivas, invalidar cachés, accesos de archivos y canales en tiempo real; aplicar retención/anonimización conforme obligaciones, sin destruir auditoría legal conservable.
09. Cuentas en dos negocios: no se mostrará selector de tenants; se entrará por enlace o dominio contextual verificado. Ingresar en A no concede ninguna lectura de B; el cliente puede reservar en ambos con historiales y sesiones contextualizadas.

G.4. Defensa del navegador a la base de datos

Capa / ataque	Medida obligatoria	Evidencia de prueba negativa
URL, ID, parámetros y Host	El backend deriva TenantContext y autorización desde sesión y membresía; IDs ajenos no son permisos. Validar Host y cabeceras de proxy confiables.	Manipular id/tenant_id, slug, route, Host, query o token no revela ni modifica recurso ajeno.
XSS, HTML de CMS, SVG y medios	Codificación contextual, sanitizador/allowlist, CSP restrictiva, Trusted Types cuando soporte, no scripts ni CSS arbitrarios de tenant.	Inyectar HTML/eventos/SVG activo no ejecuta código ni roba sesión.
CSRF, CORS y cookies	Cookies Secure + HttpOnly + SameSite adecuadas, anti-CSRF para estado, orígenes explícitos, método/scope validados.	Cross-origin POST y navegación maliciosa no cambian datos ni cookies útiles.
Secuestro, replay, fijación de sesión	Rotación de sesión tras auth, vencimiento por riesgo, revocación servidor, protección de refresh, paso adicional en cambios críticos.	Cookie/token revocado, reutilizado o robado no mantiene privilegio.
Credenciales / enumeración / fuerza bruta	Argon2id, verificación passkeys, límites por origen y cuenta con respuesta no enumerativa, bloqueo progresivo seguro.	Email existente/inexistente sin diferencias explotables; brute force y credential stuffing detectados.
Subida de perfil	MIME real, límites por tamaño y píxeles, sanitización, reencode, EXIF, antivirus donde aplique, URL temporal autorizada.	Archivo polyglot, SVG activo, ZIP bomb y foto B desde A rechazados.
API / filtros / exportación / realtime	RBAC+ABAC en cada caso de uso, campos y recursos; consultas tenant-scoped y control de versiones de permisos.	IDOR/BOLA, BFLA y búsquedas de otros tenants rechazados y auditados.

Capa / ataque	Medida obligatoria	Evidencia de prueba negativa
Respuestas y secretos	Errores homogéneos, no debug stack trace, no PII/tokens en logs o métricas, headers de seguridad.	Fallos no filtran connection strings, emails privados, claves ni IDs internos correlacionables.

Objetivo verificable: ninguna ruta privada se pública sin pruebas de autorización negativas y regressiones de sesión, identificadores y tenant en navegador, API y persistencia. Ningún sistema puede prometer inmunidad absoluta al hackeo: se exigirá defensa en profundidad, actualizaciones, monitorización, respuesta a incidentes y riesgo residual documentado.

G.5. Pruebas P0 de registro, perfil y recuperación

Prueba	Escenario ejecutable	Resultado mínimo esperado
IDN-001	Alta de consumidor en tenant A	Activar solo A; no afiliación automática a B ni acceso de plataforma.
IDN-002	Invitación de empleado B usada en A	Denegada; invitación vinculada a tenant, correo y expiración.
IDN-003	Registrar operador de CRECISOL desde formulario tenant	Imposible; realm de plataforma cerrado a inscripciones públicas.
IDN-004	Correo existente vs inexistente en recuperación	Respuesta neutra y límites uniformes; no enumeración.
IDN-005	Token de recuperación caducado/reutilizado	Denegado sin modificar contraseña ni sesión.
IDN-006	Cambio de contraseña de usuario A desde sesión B	Exige dueño y autorización del realm; B no edita A.
IDN-007	Reinicio de contraseña y sesiones anteriores	Sesiones anteriores revocadas según política; prueba de reutilización fallida.
IDN-008	MFA SuperAdmin ausente / recuperación débil	Operación global bloqueada; sin bypass por correo recién cambiado.
IDN-009	Alterar userId en ruta /me/photo o perfil	403/404 sin obtener foto, email o datos de B.
IDN-010	Foto polyglot, SVG con script o MIME falso	No publicada; cuarentena y reencode seguro.
IDN-011	Acceso a miniatura original EXIF/foto de B	No descarga ni metadatos privados; solo variantes autorizadas.
IDN-012	Dos membresías para mismo principal	No hay selector ni enumeración; sin host específico se bloquea la resolución ambigua, con host A/B se usa solo su membresía.
IDN-013	Usuario A reasigna role/branch en request	Backend ignora claims no verificados; denegado y auditado.
IDN-014	CSRF con cookie activa y origen ajeno	No muta perfil, cuenta, foto, correo ni contraseña.
IDN-015	XSS desde nombre/biografía/carga de avatar	No ejecuta script ni roba tokens; CSP y encoding probados.
IDN-016	Refresh token revocado o replay detectado	Rechazado, familia invalidada si procede y evento auditado.
IDN-017	Invitación usada dos veces o con rol mayor	No escala permisos, token consumido exactamente una vez.
IDN-018	Operador global ve perfil privado sin grant	Denegado o redacción de campos; registro de intento.
IDN-019	Descarga y exportación de perfil desde otro tenant	Rechazadas; tampoco filtra existencia ni metadata.
IDN-020	Suspensión o baja de cuenta / tenant	Sesiones, chats, QR privados y realtime dejan de autorizar.

Estado IDN-001 a IDN-020: DEFINIDOS, NO EJECUTADOS. Estos casos deben integrarse con las suites TEN y con la triple auditoría de capítulos 01, 02, 04, 05, 06, 07, 17, 21, 27, 32, 33, 34 y 36.

REGLA DE ACCESO | SIN SELECTOR DE EMPRESAS

G.6. Inicio de sesión sin selector: resolución automática y denegación segura

Ningún propietario, administrador, empleado ni cliente final verá una lista para elegir empresa al iniciar sesión. CRECISOL identifica automáticamente la empresa autorizada usando contexto de acceso verificable, identidad y pertenencia, sin revelar otras relaciones del mismo principal.

Entrada / identidad	Resolución automática obligatoria	Comportamiento de seguridad
Dominio o subdominio propio de negocio	Se valida el Host registrado, su titularidad y estado VERIFIED; tras login, se valida que el usuario pertenece a ese tenant y conserva permisos.	Abre únicamente ese negocio y sus módulos autorizados. Si falta membresía, no se presenta una lista de otros tenants.
Ruta contextual en plataforma	Una ruta de negocio validada o invitación vinculada al tenant aporta contexto de sitio; el backend valida la membresía y la finalidad.	El navegador no escoge tenant_id ni connectionString; no funciona editar slug, ruta, host o query para cambiar de empresa.
Login general con una sola membresía	El servicio privado de identidad confirma exactamente una membresía activa y determina su destino canónico autorizado.	Entra automáticamente al entorno permitido; no hay selector, listado público de relaciones ni pista sobre otras empresas.
Login general con dos o más membresías	Contexto insuficiente para saber cuál negocio abrir sin decisión arbitraria; se rechaza la activación y se solicita entrar mediante enlace contextual verificado.	Nunca elige el primer/último tenant, no enumera empresas ni envía información sobre sus nombres o IDs.
Personal CRECISOL / SuperAdmin	Inicio en realm de plataforma separado con MFA/passkey. Consola central de empresas y permisos globales independientes.	No selector en login; inspección de tenant solo desde gestor de empresas tras grant/ticket/step-up, expiración y doble auditoría.
Cliente final con perfiles en A y B	El login desde sitio A permite ver su historial A; desde sitio B permite únicamente B; la identidad no mezcla carritos, reservas ni consentimiento.	Las sesiones y los tokens se limitan por audiencia/contexto; jamás se reúnen historiales por correo repetido.

Precisión técnica: la base MySQL no autentica por sí misma ni «adivina» qué empresa debe mostrarse. El backend de identidad consulta el registro seguro de membresías y resuelve TenantContext; después la factoría de conexión elige SHARED o DEDICATED por configuración administrativa verificada. La base impone coherencia referencial y restricciones por tenant. Un WHERE tenant_id escrito manualmente en una pantalla nunca será el único control.

G.6.1. Flujo normativo de autenticación tenant-first

01. El navegador solicita login desde un host/slug contextual; el reverse proxy entrega solamente la cabecera Host canónica desde un proxy confiable y el backend valida la resolución del sitio en el registro verificado. Un Host de ataque no concede contexto.
02. El usuario presenta su credencial o passkey; el servidor valida la identidad con respuesta no enumerativa, antifraude, revocación, MFA/step-up y vínculo al contexto de login sin confiar en los parámetros del formulario.
03. El backend consulta pertenencias activas y firmadas por el propio sistema. Con un contexto de tenant verificable exige membresía específica; con un solo tenant y sin contexto puede redirigir al destino aprobado; ante múltiples pertenencias y sin contexto, deniega y solicita URL oficial del negocio, SIN listar empresas.
04. Una vez resuelto el tenant se comprueban estado, contrato, sucursal, roles, permissionsVersion, audience y propósito de la sesión. Se genera un TenantContext inmutable y se revalida en cada solicitud sensible.

05. TenantPlacementRegistry del plano de control mapea ese tenant a SHARED o DEDICATED. TenantConnectionFactory abre una conexión permitida; falla cerrada si no hay placement sano, sin fallback silencioso a otra base.
06. Frontend recibe únicamente su propio perfil, menú, módulos habilitados y permisos efectivos por proyecciones del backend. El cambio de ID, dominio o URL no altera la sesión, la base elegida ni la autorización.
07. Se audita el inicio en el ámbito correspondiente; intentos de host falso, membresía ajena, contexto ambiguo y bypass no revelan enumeraciones ni datos de otra empresa. Empleados y consumidores nunca ven el control plane.

G.6.2. Casos negativos adicionales de acceso automático

ID	Prueba dirigida	Resultado aceptable
AUTO-001	Empleado de A inicia en dominio verificado A	Entra automáticamente en A; solo roles, perfil, módulos y datos A.
AUTO-002	Empleado A usa URL, slug o host de B	Sin membresía B: rechazo uniforme; no se enumeran personas ni datos B.
AUTO-003	Mismo correo/persona con pertenencias A+B desde dominio A	Entra solo a A y jamás recibe menú, claims o token B.
AUTO-004	Mismo principal A+B inicia desde login general	No hay selector; contexto ambiguo falla cerrado y remite a URL oficial del negocio.
AUTO-005	Usuario con una membresía desde login general	Resolución única y redirección canónica sin revelar IDs o listas.
AUTO-006	Cliente final registrado en B entra desde sitio A sin afiliación A	No vinculación automática, ni historial B, ni aviso enumerativo de la cuenta B.
AUTO-007	Inyección de tenant_id, x-tenant, claims y sessionStorage	No cambia TenantContext ni connection placement; backend ignora datos no autenticados.
AUTO-008	Dominio verificado reciclado o Host no reconocido	Rechazo y control de dominio; no crea sesión ni ejecuta consultas tenant.
AUTO-009	Fallback de base dedicada indisponible	Operación rechazada sin redirigir al MySQL compartido ni a base de otro tenant.
AUTO-010	SuperAdmin inicia por login tenant o visita dominio de B	No obtiene impersonación; requiere consola global, permiso específico y grant de soporte.
AUTO-011	Admin CRECISOL abre empresa B desde gestor central	Reautenticación reforzada, límites temporales, visualización segura y eventos auditados en ambos planos.
AUTO-012	Sesión A reutilizada en rutas, API, preview y WebSocket de B	Rechazada en cada canal aun cuando el navegador manipula cookies, rutas o identificadores.

Estado AUTO-001..AUTO-012: requisitos y escenarios ESPECIFICADOS, NO EJECUTADOS. Estas pruebas son P0 y deben formar parte de los cierres de capítulos 02, 04, 05, 06, 07, 26, 27, 33 y 36. Si alguna falla, no se certifica el capítulo ni se habilita la superficie de autenticación.

REQUISITO TRANSVERSAL DE PRODUCTO · SIN EXCEPCIÓN POR RUBRO

G.7. Seguimiento universal, expedientes, observaciones y autorizaciones

Toda operación de un negocio que implique pedido, reserva, cita, prestación, reparación, venta con entrega, acceso programado, trabajo personalizado o compromiso de atención tendrá un expediente de seguimiento contextual, privado y trazable. El mismo motor contractual servirá a todos los rubros, con flujos y vocabulario administrables por tenant y sin clonar aplicaciones ni omitir las autorizaciones.

AMPLIACIÓN DEL PROPIETARIO · 08-11-2026. Norma universal obligatoria de CRECISOL. Se integra sin añadir un capítulo 38 y sin cambiar el orden de los 37 capítulos originales. Todo caso de aceptación UC-001..UC-042 está DEFINIDO, NO EJECUTADO.

G.7.1. Alcance, sujetos y separación de responsabilidades

- El usuario final consulta desde el sitio/portal contextual del tenant sus propios expedientes, estados públicos, observaciones, documentos, presupuestos y decisiones. No ve notas internas, otros clientes, trabajadores ajenos ni información comercial o de plataforma no autorizada.
- Empleados autorizados crean check-in, diagnóstico, tareas, observaciones y cambios de etapa dentro de su propio tenant, sede y asignación. El propietario define perfiles y visibilidad sin conceder permisos superiores a los disponibles.
- El módulo universal conserva una línea de tiempo visible al cliente y una bitácora de auditoría técnica separada. La línea de tiempo no reemplaza la bitácora: la primera es producto; la segunda registra quién, cuándo, desde qué sesión y qué cambió.
- Seguimiento y comentarios constituyen comunicación asincrónica con evidencia. No implican chat en tiempo real, firma electrónica legal ni consentimiento médico por defecto; esas capacidades tienen requisitos adicionales independientes.
- La capacidad básica de seguimiento, observaciones y registro de resolución se ofrece a todo rubro y tenant, no depende de elegir un sector. La habilitación de acciones especiales depende de permisos y compatibilidad del negocio; nunca se desactiva la trazabilidad por conveniencia visual.

G.7.2. Modelo operativo de expediente, sujeto y línea temporal

Entidad / contrato	Propósito y campos mínimos	Garantía
CustomerCase	tenant_id, id opaco, branch_id, customer_scope, subject_kind/id, case_type, workflow_version, current_stage, revision, opened_at, closed_at, owner.	FK tenant-scoped; caso no es una tabla universal de todo el negocio.
CaseStageTransition	from_stage, to_stage, actor, reason, occurred_at UTC, sequence, authorization_snapshot, correlation_id.	Transición validada en servidor; secuencia íntegra e idempotente.
CaseActivity / Comment	kind, author, audience, body saneado, created_at, reply_to, visibility, edited_policy.	Interno versus cliente; correcciones mediante nueva versión, no borrado furtivo.
CaseEvidence /	file_ref, MIME validado, tamaño, hash, autor, relación, política	Cuarentena y medios

Entidad / contrato	Propósito y campos mínimos	Garantía
Attachment	de acceso, revisión.	privados; preview antes/después; URL temporal.
CheckIn / CheckOut	programación, objeto recibido, quien entrega/recibe, fecha-hora, condición, fotos, sucursal, firma de acuse si aplica.	Custodia y secuencia; no deducir recepción de una reserva.
Diagnosis / Finding	observaciones, hallazgos, responsable, evidencia, versión y fecha; categorías permitidas por rubro.	Diagnóstico no equivale a autorización ni a historia clínica.
QuoteVersion / QuoteLine	moneda, descripción, cantidades, mano de obra, repuesto, impuestos, total, expiración, hash y revisión.	Inmutable al aprobar; no cambiar importes después de consentimiento.
ApprovalRequest / Decision	renglones solicitados, versión exacta, actor, aprobación/denegación/parcial, comentarios, alcance y sello temporal.	Solo titular/representante autenticado; no confundir apertura del aviso con aprobación.
CaseDelivery / Closure	resultado, entregado_a/por, hora, evidencia de entrega, pendientes, checklist, causa y sello de cierre.	Separar completado, entregado, cancelado, disputado y cerrado.
CaseNotification / Outbox	evento, destinatario, plantilla, canal, estado, dedupe key, intento, fecha y error saneado.	Persistencia primero; cola recuperable; avisos no cambian el estado.

G.7.3. Estados y transiciones: configurables sin comprometer invariantes

La interfaz usará etiquetas editables por empresa y plantillas sectoriales; el motor almacena códigos y transiciones tipadas y versionadas. Cada empresa define etapas intermedias permitidas, responsables, tiempos esperados y reglas de visualización. La validación contra saltos ilegales, autorización y cierre permanece en código protegido.

Familia	Estados orientativos	Regla de aceptación
Entrada	SOLICITADO, CONFIRMADO, AGENDADO, EN_CHECK_IN	Agendar no significa recibir; QR no equivale a identidad.
Ejecución	RECIBIDO, EN_REVISION, DIAGNOSTICADO, COTIZADO, EN_ESPERA_CLIENTE, AUTORIZADO, EN_PROCESO, LISTO_ENTREGA	No iniciar trabajo no aprobado ni comprar piezas sin autorización de alcance.
Entrega y cierre	EN_ENTREGA, ENTREGADO, PENDIENTE_RESOLUCION, CERRADO	CERRADO requiere condiciones de entrega/resolución comprobadas; fecha/hora y actor.
Ramas alternativas	RECHAZADO, CAMBIO_SOLICITADO, CANCELADO, INCIDENCIA, DISPUTA, REABIERTO	CANCELADO no se muestra como ENTREGADO; nunca se destruye la

Familia	Estados orientativos	Regla de aceptación
		historia.

- Las etapas no son una secuencia rígida idéntica para todos: una venta POS puede pasar por entrega inmediata; una visita de spa puede registrar asistencia y prestación; un taller exige diagnóstico y autorización cuando cambia el trabajo.
- Estado visible y estado interno son distintos. La empresa puede cambiar los nombres visibles y colores, pero no eliminar eventos, permitir salto arbitrario a CERRADO ni convertir denegación en aprobación.
- Una operación cancelada antes de la entrega queda CANCELADA con motivo, iniciador, fecha, condición de pago, devoluciones si aplica y evidencia; es terminal, pero jamás “servicio completado”. Reabrir genera evento vinculado y requiere permiso.
- Un expediente concluido no borra garantías, reclamaciones o soporte posteriores. Se vincula caso de posventa o reapertura con nueva versión, sin cambiar el evento histórico de entrega original.

G.7.4. Flujo ilustrativo obligatorio: taller de vehículos

01. Reserva — El cliente agenda para el lunes. Se registra fecha/hora, sucursal, servicio estimado, identidad y cita. Recibe comprobante sin que la reserva se marque atendida.

02. Check-in físico — El receptor confirma llegada del vehículo, quién lo entregó y quién lo recibió, hora local y UTC, matrícula/atributos mínimos, condición inicial y fotos con consentimiento. No se inventa acuse.

03. Evaluación — El mecánico asignado registra revisión, diagnóstico, piezas propuestas, observaciones, evidencia y tiempos previstos. El estado pasa a DIAGNOSTICADO, no a AUTORIZADO.

04. Propuesta versionada — El taller emite presupuesto por renglones: repuestos, mano de obra, cantidad, impuestos, total, alcance, vigencia y condiciones; el cliente ve la versión exacta en su perfil.

05. Aviso y conversación — La plataforma persiste solicitud de decisión y notifica al cliente: “Hay una actualización pendiente”. Cliente abre detalle, pregunta, comenta o adjunta evidencia; el taller recibe evento en su bandeja.

06. Aprobación granular — El cliente acepta unas piezas, rechaza otras o pide aclaraciones. Cada decisión registra actor, hora, versión, monto y alcance; el rechazo no se interpreta como autorización implícita.

07. Trabajo condicionado — El mecánico ejecuta solo conceptos autorizados. Un costo adicional, pieza distinta o aumento de monto crea revisión nueva y queda EN_ESPERA_CLIENTE hasta nueva aprobación.

08. Preparación y entrega — Se documentan pruebas, fotos finales, entrega a persona autorizada, hora, garantía y pendientes. “Listo para retirar” no es “entregado”.

09. Cierre verificable — Solo se registra CERRADO cuando entrega/aceptación y pendientes obligatorios estén resueltos o conciliados según contrato, dejando comprobante e historial. Si hay reclamo, queda abierto el flujo de incidencia.

El presupuesto no transfiere fondos ni compra repuestos por sí solo. El botón “Autorizar” expresa una aceptación autenticada de la versión/importe mostrado; el efecto jurídico de firma electrónica o contratos específicos exige validación normativa y mecanismo adicional cuando proceda.

G.7.5. Flujo ilustrativo obligatorio: restaurante, cocina y QR

- QR de mesa o menú identifica solo el contexto público permitido y no autentica al cliente ni da acceso a otros pedidos. Crear pedido requiere validación antifraude y confirmación inequívoca; si se vincula a un perfil, aplicar membresía contextual.
- Pedido confirmado -> recibido por cocina -> preparando -> listo para servir/salir -> entregado/servido -> incidencias resueltas -> cerrado. El rol cocina actualiza producción; mesero confirma entrega; consumidor consulta solo su propio pedido.
- El restaurante registra notas como alergias únicamente en el contexto mínimo y autorizado; datos sensibles no se publican en pantallas comunes ni se utilizan para perfilamiento ajeno.

- Cambios, faltantes o sustituciones con precio distinto requieren aceptación explícita del cliente. Una cancelación o reembolso tiene una ruta terminal propia con evidencia y conciliación, nunca se marca como servido por comodidad.
- Desconexión del dispositivo de cocina no pierde pedidos; los cambios se guardan en API con control de concurrencia, Outbox y reintentos; no depender solo del websocket para la verdad transaccional.

G.7.6. Catálogo completo por rubro: seguimiento común, plantillas diferentes

Rubro del diseño original	Ruta de seguimiento propuesta	Control específico
Barberías, peluquerías, salones	Cita -> check-in -> servicio en curso -> finalizado -> satisfacción/observación -> cierre.	Profesional asignado, extras consentidos, fotos autorizadas.
Spa y estética	Reserva -> llegada -> confirmación de servicio -> atención -> indicaciones permitidas -> cierre.	Consentimientos específicos; no convertirlo en expediente clínico.
Odontología / consultorios	Cita informativa -> recepción -> atención administrativa -> salida -> seguimiento administrativo.	No incorporar diagnósticos clínicos sin análisis legal especial.
Restaurantes y cafeterías	QR/orden -> cocina recibe -> prepara -> sirve -> resuelve incidencias -> cierra.	Pedido por mesa privado, sustituciones y diferencias de precio autorizadas.
Estudios de tatuaje	Reserva -> anticipo -> propuesta/diseño -> aprobación -> sesión -> entrega/seguimiento.	Consentimiento de edad y bioseguridad según regulación, diseños versionados.
Talleres auto/moto	Cita -> custodia/check-in -> diagnóstico -> cotización -> decisión parcial -> reparación -> entrega.	Aceptación por partida; repuestos, fotos y garantía.
Car wash / detailing	Turno -> ingreso -> inspección visual -> lavado -> control de calidad -> entrega.	Extras/daños documentados y autorizados.
Joyerías y relojerías	Recibe pieza -> registra estado/serie -> diagnóstico -> aprobación -> reparación -> entrega.	Custodia de activos de alto valor, certificado y recibo.
Ropa, tenis y calzado	Pedido -> preparación -> reserva -> retiro/entrega -> cambio/devolución -> cierre.	Devoluciones y estado separado de la venta original.
Electrónica y gaming	Recepción -> diagnóstico -> presupuesto -> reparación/garantía -> devolución.	Serie, accesorios y evidencia de custodia.
Juguetes	Pedido -> surtido -> comprobación -> entrega -> reclamo o devolución.	Avisos por edad y protección de menores.
Pulperías y minimarkets	Venta -> surtido si diferido -> entrega; devolución o incidencia si existe.	Operación inmediata permite cierre simple pero auditable.
Supermercados / tiendas de departamento	Pedido/caja -> preparación -> despacho o retiro -> devolución/garantía.	Control por ítem, lotes y múltiples sucursales.

Rubro del diseño original	Ruta de seguimiento propuesta	Control específico
Gimnasios, yoga, pilates, clubes	Reserva clase -> acceso/check-in -> actividad -> salida -> atención de incidencia.	QR efímero y límites de membresía.
Academias y escuelas de baile	Inscripción -> clase reservada -> asistencia -> avance/entregable -> cierre.	Permiso de tutor cuando corresponda, privacidad de menores.
Veterinarias y mascotas	Reserva -> recepción mascota -> servicio administrativo -> entrega -> seguimiento.	Datos de tutor y registros clínicos sujetos a regulación.
Ferreterías y repuestos	Cotización -> autorización -> surtido -> despacho -> entrega/garantía.	Compatibilidad y cambios de precio aceptados.
Lavanderías / tintorerías	Ingreso prendas -> clasificación -> lavado -> listo -> devolución -> cierre.	Cadena de custodia, daños y hora de retirada.
Panaderías y reposterías	Pedido personalizado -> diseño/ingredientes -> aprobación -> producción -> entrega.	Alergénicos, sustituciones y fecha de entrega.
Imprentas y servicios personalizados	Archivo/diseño -> propuesta -> prueba de impresión -> visto bueno -> producción -> entrega.	Arte final aprobado, revisión exacta y propiedad del archivo.
Ópticas	Cita/compra -> propuesta -> preparación -> ajuste -> entrega/garantía.	Graduaciones y datos clínicos separados salvo habilitación legal.
Pequeños hospedajes / eventos	Reserva -> check-in -> servicio/estancia -> check-out -> incidencias -> cierre.	Identidad de huéspedes y documentos según ley.
Otros rubros	Plantilla de etapas, eventos y decisiones del mismo motor universal.	Alta mediante esquema validado y pruebas antes de publicar.

La tabla anterior especifica presets funcionales, no módulos implementados. Ningún sector queda excluido del historial, las observaciones, la atención de solicitudes o la capacidad de exigir autorización según la operación. Extensiones sanitarias y de menores requieren aprobación normativa separada.

G.7.7. Contrato de autorización del cliente y evidencia

- La solicitud incluye tenant, expediente, emisor autorizado, ítems y versiones exactas, moneda, coste final mostrado, alcance del trabajo, ventana de validez, reversibilidad, términos vigentes y quién puede decidir.
- La decisión puede ser APROBAR_TOTAL, APROBAR_PARTES, RECHAZAR, SOLICITAR_CAMBIOS o CONSULTAR; nunca se infiere aceptación por silencio, visita o lectura del aviso.
- En aprobación parcial, cada línea autorizada conserva importe y cantidad; las rechazadas quedan excluidas de ejecución. La orden de trabajo del empleado refleja únicamente las partidas aprobadas.
- Cambio de precio, cantidad, pieza, plazo esencial o alcance invalida la aprobación de los conceptos modificados y crea nueva QuoteVersion pendiente. El backend prohíbe trabajo/cobro no autorizado.
- Cada decisión guarda marca temporal UTC, actor autenticado, tenant, sesión y nivel de autenticación, revisión/hash de propuesta, texto de decisión, evidencia asociada, IP/datos técnicos mínimos protegidos y correlación. La exposición al cliente se limita a lo autorizado.

- Para operaciones de riesgo alto, configurar reautenticación/step-up; una aprobación ordinaria de interfaz no debe presentarse como firma electrónica cualificada ni reemplazar consentimiento regulado.
- La revocación/cambio de decisión exige operación explícita y política de trabajo ya ejecutado; jamás reescribir aprobación anterior. Registrar lo realizado antes de la revocación para resolver obligaciones.

G.7.8. Observaciones, comunicación y archivos

- La conversación del expediente admite notas de cliente/empleado, preguntas, respuesta, menciones limitadas, adjuntos y estados de leído si el canal lo permite; los mensajes son eventos versionados con trazabilidad.
- Dos tipos de entrada: PUBLICA_PARA_CLIENTE y INTERNA_NEGOCIO. Por defecto las notas internas no se exponen al portal del cliente, ni a otros clientes ni a tenants ajenos. El personal tampoco ve datos de otros casos fuera de su alcance.
- Imagen/documento: seleccionar -> preview segura -> validación MIME/tamaño/cuarentena -> autorización de subida -> guardar metadata y hash -> preview del objeto persistido -> descarga autorizada con vista previa; PDF/Office requieren conversión aislada cuando aplique.
- El historial incluye autor, fecha/hora local y UTC, etapa, adjuntos permitidos, referencias a decisiones y origen del cambio (cliente/empleado/automatización). Se prohíbe el “borrar definitivamente” de evidencia regulada desde la interfaz.
- Avisos por panel/correo/otros canales autorizados tienen plantilla parametrizada por tenant, deduplicación, preferencias, privacidad y corrección de destinatario. La notificación es un reflejo del hecho persistido, no el hecho en sí.
- Retención, rectificación, borrado y protección de información personal se ejecutan bajo política legal: minimizar PII y anonimizar cuando proceda, sin borrar evidencia que deba conservarse por obligación.

G.7.9. Cierre, cancelación, incumplimiento y reclamación

Evento	Condición obligatoria	Resultado
Finalizar ejecución	Prestación o preparación completa y checklist técnico firmado por empleado autorizado.	No equivale a entrega ni cierre.
Marcar entregado	Recepción o entrega comprobada con fecha, responsable, identidad/acuse si aplica, evidencias y alcance entregado.	Solo entonces estado ENTREGADO.
Cerrar expediente	Entrega o conclusión exigida comprobada + decisiones críticas resueltas + tareas obligatorias cerradas + incidencias tratadas o correctamente derivadas.	CERRADO con actor y timestamp; no borra anexos.
Cancelar	Estado permitente, solicitante autorizado, motivo, efecto económico/reembolsos y reservas liberadas.	CANCELADO auditable; no “entregado/completado”.
Rechazar presupuesto	Se registran líneas y comentarios rechazados, sin ejecución futura de esa parte.	EN_ESPERA_CLIENTE / RECHAZADO, según regla.
Reabrir / garantía	Nuevo reclamo o extensión con vínculo al expediente y resolución por política vigente.	Nueva secuencia y vínculos inmutables.
Cierre excepcional	Solo ante motivo regulado, permiso reforzado, doble control si aplica y registro explícito de incumplimiento/no entrega.	No falsificar “entregado”; revisión posterior.

G.7.10. Arquitectura de software e interfaces por capa

Ámbito	Componentes mínimos (diseño)	Dependencias y límites
frontend/	CaseTimeline, CaseStatusBadge, CaseCommentComposer, CaseAttachmentPreview, ApprovalDecisionDialog, QuoteComparison, CheckInForm, CaseClosureChecklist, CustomerCasePortal, StaffCaseInbox.	Angular lazy + Signals, tokens/ActionRegistry, modal XS–XL, móvil y a11y; nunca autorizar solo por botón.
backend/	Cases/Domain; CreateCase, CheckInCase, AddNote, PublishFinding, RequestApproval, DecideApproval, TransitionStage, MarkDelivered, CloseCase, CancelCase, ReopenCase, AddEvidence; query ACL; Outbox.	API delgada; un caso de uso por acción; sin servicio monstruo; integración con Orders/Scheduling/Media/Payments por contratos.
database/	case_records, case_events, case_comments, case_evidence, case_checkins, case_workflow_versions, case_transitions, quote_versions, quote_lines, approval_requests, approval_decisions, case_deliveries, case_closures, outbox.	MySQL 3FN, tenant_id compuesto/FK por ámbito, versionado y claves idempotentes; misma migración lógica en SHARED y DEDICATED.
Control plane	TenantContext -> TenantPlacementRegistry -> TenantConnectionFactory; policy engine y permisos por rol/sucursal/caso.	La URL no escoge DB; ninguna conexión a base de otro tenant.
Notificación	Transactional Outbox -> worker idempotente -> canal autorizado -> respuesta de entrega.	Reintentos/dedupe; fallos del canal no revierten una aprobación ya persistida.

Contrato API inicial (orientativo y sujeto a validación de seguridad): GET /api/v1/me/cases; GET /api/v1/me/cases/{id}/timeline; POST /api/v1/cases/{id}/check-ins; POST /api/v1/cases/{id}/notes; POST /api/v1/cases/{id}/approval-requests; POST /api/v1/me/cases/{id}/approvals/{approvalId}/decisions; POST /api/v1/cases/{id}/transitions; POST /api/v1/cases/{id}/deliveries; POST /api/v1/cases/{id}/close; GET /api/v1/me/cases/{id}/attachments/{fileId}/preview. Los IDs son opacos, no conceden acceso. Las mutaciones requieren revalidación de tenant, actor, estado y versiones; If-Match/optimistic concurrency e Idempotency-Key según caso.

G.7.11. Amenazas P0, protección y consistencia transaccional

- BOLA/IDOR: cambiar caseId, quoteId, approvalId, fileId o slug por el de otro tenant o usuario debe producir denegación sin revelar existencia. Verificar identidad contextual + relación con recurso en cada lectura y escritura.
- SHARED y DEDICATED: consultas, FK, aggregates, históricos, caché, búsqueda, reportes, sockets, tokens de archivo y workers conservan tenant_id y placement autorizados. Prohibidas consultas unscoped y fallback silencioso de datos dedicados a compartidos.
- Condiciones de carrera: cliente acepta mientras empleado cambia cotización, dos empleados intentan cierre, dos clicks aprueban, notificación llega duplicada; el estado final es determinista e idempotente o devuelve 409/reintento seguro.
- No se permite subir scripts, HTML ejecutable ni formatos inseguros que puedan abrir XSS/SSRF/XXE; procesar MIME real, límites de páginas y archivos y render aislado; enlaces firmados temporales con autorización previa.
- Auditoría diferenciada: historial visible del cliente, log del negocio y log de soporte/plataforma almacenan el mismo correlation_id, pero jamás comparten registros legibles entre tenants o roles. Append-only o mecanismos equivalentes de integridad.

- Caché y notificaciones con scoping estricto: tenant_id, usuario, permiso, placement, revisión; cambio de membresía revoca accesos efectivos de inmediato y limpia eventos en tránsito con revalidación.
- Cualquier acceso excepcional de SuperAdmin exige ticket/motivo, elevación temporal, audiencia y fecha de expiración, registro separado y minimización de datos. El panel central no vuelve públicos expedientes privados.
- Mensajes o notificaciones retrasadas, caídas de red y reintentos no alteran la verdad de la aprobación o la entrega; los eventos comprometidos tienen registro transaccional Outbox, replay seguro y deduplicación.

G.7.12. Matriz de pruebas nuevas y no certificadas (UC-001 a UC-042)

ID	Clase	Criterio reproducible pendiente de ejecución
UC-001	Funcional	Reserva creada no cuenta como check-in.
UC-002	Funcional	Check-in registra persona que entrega/recibe, hora, condición y evidencia.
UC-003	Funcional	Diagnóstico crea versión y no autoriza trabajo automáticamente.
UC-004	Funcional	El cliente ve detalle de cotización y todas sus líneas.
UC-005	Funcional	Aprobación parcial habilita solo partidas aceptadas.
UC-006	Funcional	Rechazo conserva explicación y bloquea partida.
UC-007	Funcional	Preguntas del cliente quedan visibles al trabajador asignado.
UC-008	Funcional	Observación interna no se filtra al consumidor.
UC-009	Funcional	Nueva versión de presupuesto exige aprobación nueva.
UC-010	Funcional	Empleados ven tareas correctas tras decisión del cliente.
UC-011	Funcional	Notificación se emite tras persistir y se deduplica.
UC-012	Funcional	Restaurante: QR no concede acceso a pedido de mesa ajena.
UC-013	Funcional	Restaurante: recibido/preparando/listo/servido se registran por rol.
UC-014	Funcional	Taller: check-in no implica cierre, listo no implica entrega.
UC-015	Funcional	Cancelación conserva historia pero nunca marca entregado.
UC-016	Funcional	Cierre impedido con tareas/decisiones/incidencias bloqueantes.
UC-017	Funcional	Entrega real crea acuse y permite cierre según checklist.
UC-018	Funcional	Posventa abre caso vinculado sin borrar expediente cerrado.
UC-019	Seguridad	Cliente A no lee caso/adjunto/estado de B en SHARED.
UC-020	Seguridad	Cliente A no lee caso/adjunto/estado de B en DEDICATED.
UC-021	Seguridad	Cliente X del mismo tenant no puede leer caso privado Y.

ID	Clase	Criterio reproducible pendiente de ejecución
UC-022	Seguridad	Empleado sin alcance sucursal/caso no añade notas ni cierra.
UC-023	Seguridad	Manipular URL, ID, host, cursor o búsqueda no eleva permisos.
UC-024	Seguridad	Reutilizar approvalId de otro expediente no autoriza nada.
UC-025	Seguridad	Enlace firmado de adjunto no cruza tenants ni audiencia.
UC-026	Seguridad	Eventos realtime y Outbox no entregan registros entre empresas.
UC-027	Seguridad	SuperAdmin sin grant excepcional no ve contenido privado.
UC-028	Seguridad	Cambio/revocación de roles invalida acceso a caso inmediatamente.
UC-029	Integridad	Aprobación simultánea con cambio de quote falla de forma segura.
UC-030	Integridad	Doble aprobación/aceptación produce una única decisión válida.
UC-031	Integridad	Cierre concurrente o transición repetida no duplica eventos.
UC-032	Integridad	Sin conexión de avisos, la aceptación queda persistida.
UC-033	Integridad	No existe compra de repuesto ni cobro no autorizado.
UC-034	Integridad	FK compuestas no permiten asociar adjunto/cliente de tenant ajeno.
UC-035	Integridad	Importación/restauración de tenant no mezcla secuencias ni bitácoras.
UC-036	UX	Timeline móvil/tablet/escritorio muestra estados/autor/hora con claridad.
UC-037	UX	Iconos, modales, contraste y teclado cumplen el design system.
UC-038	UX	Adjuntos y presupuesto ofrecen preview antes y después de guardar.
UC-039	UX	Antes de descarga hay preview fiel y control de autorización.
UC-040	UX	Estados y textos parametrizados no modifican transiciones legales.
UC-041	Sectorial	Todos los 23 rubros tienen preset de seguimiento o plantilla universal.
UC-042	Resiliencia	Retry/outbox, offline y errores 409 recuperan sin pérdida de hechos.

GATE DE CIERRE: UC-001 a UC-042 deben tener datos sintéticos, ejecución real, evidencia, expected/actual y responsable en el capítulo que implemente la superficie afectada. Son pruebas especificadas; no representan software construido ni validación operacional.

G.7.13. Matriz de integración en los 37 capítulos existentes

Cap.	Tramo contractual	Responsabilidad dentro del capítulo
01	Identidad y contratos	Definir clave universal de módulo/copyright/actores sin construir funciones futuras.
02	Experiencias	Presentar timeline y notificaciones para cliente/empleado/propietario por contexto.

Cap.	Tramo contractual	Responsabilidad dentro del capítulo
03	Arquitectura	Contratos Cases, puertos, outbox, límites de capas y dependencias.
04	Tenants	CaseContext, placement SHARED/DEDICATED y aislamiento de casos/archivos.
05	Identidad	Autoría del cliente/empleado y step-up en aprobaciones.
06	Permisos	RBAC/ABAC por etapa, recurso, cliente, sucursal y audiencia.
07	Seguridad	Amenazas P0, ataque a URLs, replay, archivos y concurrencia.
08	SuperAdmin	Métricas del módulo y acceso excepcional con trazabilidad.
09	Editor visual	Plantillas de timeline, estados, iconos, modales, preview y i18n.
10	Catálogo	Ítems y servicios referenciados en presupuestos y casos.
11	Inventario	Reserva/descuento solo para líneas aprobadas y trazabilidad.
12	Pedidos	Núcleo de seguimiento y estados de pedido/entrega/cancelación.
13	Agenda	Reserva -> check-in -> prestación -> cierre/ausencia/cancelación.
14	Restaurantes	QR mesa, producción cocina, entrega e incidencias.
15	Membresías	Asistencia/check-in y seguimiento de solicitud/servicio.
16	Sectores	Presets específicos de 23 rubros sin código duplicado.
17	CRM	Historial del cliente por tenant y proyección autorizada.
18	Fidelización	Reclamos, quejas, devolución y posventa vinculados.
19	Mensajería	Avisos sobre cada actualización, respuesta y decisión.
20	Web pública	Estado resumido y portal privado con contexto verificado.
21	Medios	Adjuntos, previews, descargas, hashes, escaneo y ACL.
22	Analítica	Duración por estado, SLA, atascos y métricas tenant-scoped.
23	Legal	Consentimiento, evidencias, retención y aceptación versionada.
24	VPS futuro	Solo definir requisitos de workers, colas y carga local; no desplegar.
25	CI/CD futuro	Checks de contrato, seguridad y pruebas locales reproducibles.
26	API/datos	Endpoints de casos, DTO, eventos e idempotencia.
27	Aceptación	Suite UC-001..042 y regresiones P0 ejecutadas cuando aplique.

Cap.	Tramo contractual	Responsabilidad dentro del capítulo
28	Mejoras	Cruzar 30 mejoras originales con servicio de seguimiento.
29	Gates	No avanzar con aprobación/entrega/aislamiento sin evidencia.
30	Módulos	Habilitar seguimiento universal sin bloqueo por rubro.
31	Cobros	Presupuesto/cobro separados; nunca cobrar por nota o aprobación sola.
32	Archivos	Evidencia segura y previews por tipo y ubicación tenant.
33	Diccionario DB	Tablas normalizadas, FK compuestas y migraciones reversibles.
34	Formularios	UI responsive check-in, diagnóstico, aprobación, observaciones y cierre.
35	Topología	Especificar aislamiento de sockets/caché/outbox para futuro.
36	Pruebas	Cross-tenant, UI, concurrencia, entrega, offboarding y regresión.
37	Referencias	Registrar sustento legal/técnico del nuevo módulo.

G.7.14. Puerta de salida documental y de software

- Cierre DOCUMENTAL del diseño de seguimiento: casos, arquitectura, estados, autorización, 23 presets, 37 impactos y 42 pruebas especificadas; no exige conexión real ni usuarios finales todavía.
- Cierre DE CÓDIGO de cada capítulo: compilación real Angular/Node24, .NET, MySQL donde corresponda; pruebas positivas y negativas; tres auditorías; métricas, rollback, capturas y acta con responsable y evidencia.
- Sin un backend funcional, identidad, permisos, motor de eventos y base de datos probados no puede declararse que “las empresas ya tienen seguimiento”, “la aprobación es irrefutable” o que la plataforma es inmune a ataques.
- Toda regla del motor es transversal; se implementa únicamente en el capítulo que corresponda, no se salta la secuencia 01-37 ni se introducen microservicios distribuidos por defecto.
- Las reglas de notificaciones, conciliación de pagos, firma electrónica, consentimientos sanitarios y SLAs legales quedan condicionadas a pruebas o validación externa según la naturaleza de cada contrato; no se cierra una decisión técnica no demostrada.

H. Auditorías: separadas, privadas e intégras

Bitácora	Actor / persistencia	Acceso y retención
TENANT_AUDIT	Event stream tenant-owned, tenant_id verificado, actor, acción, recurso, outcome, timestamp UTC, request_id, hash encadenado/ sello segun diseño.	Consultable solo por permisos del mismo tenant; no contiene auditorías de otros negocios.
PLATFORM_AUDIT	Eventos de operadores globales, altas/bajas de empresas, placement, configuración y soporte, separados de los tenant streams.	Solo auditor de plataforma; no visible desde endpoint tenant.
SECURITY_EVENTS	Intentos fallidos, BOLA/IDOR, MFA, anomalías, rate limits y alertas con minimizacion.	Roles de respuesta a incidentes, no empleados tenant por defecto.
SUPPORT_CORRELATION	Relación causal de acceso autorizado de SuperAdmin a un tenant; dos eventos distintos con mismo correlation ID.	No se copian registros enteros: cada propietario conserva su evento y su política.

- Cada consulta de audit valida tenantId y rol en servidor; exportaciones, filtros y busquedas no pueden saltar tenant scope.
- Permisos DB append-only o controles de escritura restringida para bitácoras; hash/sello por lote permite detectar alteraciones, no las impide por si solo.
- Estrategia tenant-aware de retención, legal hold, backup, restauración y borrado; IDs correlativos no revelan clientes de otros negocios.
- Un usuario A no puede crear un audit record falso de B ni consultar volumen, fechas o eventos privados de B.
- La infraestructura compartida puede centralizar almacenamiento de logs si el acceso efectivo conserva particion estricta por tenant; para dedicated, priorizar almacenamiento tenant propio.

I. Seguridad de superficies adyacentes

Superficie	Regla de aislamiento	Prueba minima
API / GraphQL / WebSocket	Contexto inmutable + permiso por operación, recurso, acción y campo.	Lectura/escritura por id de B, change tenant headers y sockets contra B: rechazados.
MySQL / EF / SQL crudo	PK/FK compuestas, queries por tenant, permisos mínimos, ownership verificado.	SQL auditor y fuzz de consultas: no muestra filas de B.
Cache / CDN / SSR	Claves de cache tenant+user+permVersion+revConfig; Vary apropiado; public seguro.	Warm cache A, request B: nunca devuelve A.
Mensajes / workers / outbox	Productor autenticado, contexto tenant validado, cola y retries scoped.	Cambiar tenant en payload/replay/collision key: rechazo.
Media / documentos / preview	Object metadata tenant-owned; firmas por objeto+acción+usuario+expiracion.	URL/preview/thumbnail de B desde A: no se filtra.
Exportaciones / reportes	Query y snapshot autorizados; temporales tenant-specific.	Report de A no incluye ni cuenta filas de B.
Backup / restore	Backup shared aislado; restore selectivo en staging. Dedicated restaura independiente.	Restaurar A nunca pisa B ni su audit; no dar snapshot shared a tenant.
Buscador / analitica	Indices y agregaciones etiquetados por tenant; permisos por campo y visibilidad.	Autocomplete y métricas no enumeran B ni metadata.
Dominio / subdominio / rutas	Verificación DNS+TLS y host permitido; dominio selecciona contexto, no privilegios.	Host spoof, dominio reciclado y slug reservado no ganan acceso.
Cuotas / disponibilidad	Limites por tenant, user, endpoint, pool, storage, jobs y concurrentes.	Tenant A saturando trabajos no inutiliza el servicio global.

J. Ciclo de vida del almacenamiento dedicado

01. Solicitud registrada por propietario autorizado del tenant; CRECISOL valida contrato, capacidad, residencia, compatibilidad, soporte, SLA y motivo.
02. Aprobación de plataforma: estado REQUESTED -> VALIDATED -> PROVISIONING -> READY, con rechazo seguro de configuraciones no aceptadas.
03. Provisionamiento de base vacia con cuenta tenant especifica y migraciones versionadas; seed sin datos reales; health y restauración comprobados.
04. Congelar cambios del tenant origen (o usar sincronizacion verificable con corte), obtener snapshot transaccional y exportar exclusivamente las filas y objetos de su tenant.
05. Importar a staging dedicado; reescribir referencias tecnicas que lo requieran sin modificar el negocio; contar registros, checksum, FK, media, audit y dependencias.
06. Ejecutar suite de autorización y cross-tenant, comparación de datos, rendimiento, backup y restore; registrar evidencia con ID y hash.
07. Cambiar placement solo mediante switch atomico del control plane tras lectura final; drenar conexiones/colas, versionar ruta y purge de caches de scope anterior.
08. Mantener rollback controlado y retención conforme contrato; no sostener dual-write permanente no probado; alertar, auditar y retirar residuo antiguo cuando corresponda.
09. BYODB: aplicar validación extra de red segura, identidad del servidor, privilegios, backups y recuperación, cifrado, control de cambios y responsabilidades; no permitir conexiones arbitrarias desde la UI.

K. Esquema de claves y relaciones obligatorio

- Tabla tenant-owned: PK(tenant_id,id) o clave candidata equivalente con UNIQUE(tenant_id,id). Todo enlace entre recursos del tenant usa FK(tenant_id,resource_id) hacia el mismo tenant cuando MySQL lo permite.
- Tenant_id no es editable desde entidad expuesta a usuarios; lo inyecta el TenantContext verificado. Ninguna FK de tenant business a platform_secret o platform_admin.
- En dedicated se conserva tenant_id por compatibilidad y defensa de contexto, pero se deniega a esa credencial acceder a bases de otro tenant.
- MySQL: transacciones InnoDB, DECIMAL para moneda, UTC y zona de negocio, versiones de fila para concurrencia y restricciones de estado; no blob JSON sustituyendo relaciones de negocio.
- Cache y eventos: keys tenantId + placementVersion + resourceId + authorized actor/permissionVersion cuando corresponda; outbox con idempotencyKey tenant-specific.
- Todos los modelos de permisos y bitácoras deben incluir pruebas negativas y prohibicion de mezclas por join, paginacion, aggregate o export.

L. Matriz de pruebas P0 de separación

ID	Intento real a ejecutar	Resultado obligatorio
TEN-001	API GET id recurso B desde A	No devuelve cuerpo ni existencia privada.
TEN-002	POST/PATCH/DELETE B con token A	Denegado; B sin mutaciones.
TEN-003	List, search, filtro, agregacion B desde A	No datos, conteos ni sugerencias B.
TEN-004	Cambiar tenant_id/host/slug/headers	No altera el tenant autorizado.
TEN-005	Token A con role claim fabricado de plataforma	No concede ninguna acción global.
TEN-006	Usuario compartido A+B, login contextual	Sin selector: con dominio A solo A, con dominio B solo B; sin contexto único se deniega.
TEN-007	Tenant A lista módulos B	Ni entitlements ni configuración B disponibles.
TEN-008	Lectura audit B desde A	Denegado, incluso export y filtros.
TEN-009	Escritura/alteracion audit B desde A	Denegado; bitácora B intacta.
TEN-010	Audit plataforma desde owner tenant	Denegado; metadatos no expuestos.
TEN-011	Cache A caliente seguido de lectura B	Valores A nunca aparecen en B.
TEN-012	Thumbnail/preview/descarga URL B desde A	Denegado aun con identificador conocido.
TEN-013	Worker reinyecta evento con tenantId B	Descarta o rechaza el contexto falsificado.
TEN-014	Idempotency key repetida A vs B	No colision entre tenants.
TEN-015	Restore A desde backup compartido	B no se ve, modifica ni filtra.
TEN-016	Migrar A shared->dedicated	Checksum/FK/audit de A correctos; B no afectado.
TEN-017	Rollback placement A	No lecturas cruzadas ni inconsistencias de revisión.
TEN-018	Rutas de MySQL DEDICATED A hacia B	Grants y conexiones impiden acceso.
TEN-019	Connection pool A/B secuencial	Ninguna conexión conserva sesion o estado ajeno.
TEN-020	SSRF en BYODB host provisto	No sale a destinos no autorizados ni metadata endpoints.
TEN-021	SuperAdmin vista demos	Solo datos sintéticos por defecto.
TEN-022	SuperAdmin soporte real sin grant	Denegado y registrado.
TEN-023	SuperAdmin soporte con grant temporal	Solo scope aprobado; expiracion y doble audit.
TEN-024	Empleado de A lee finanzas de otra sucursal	Solo permiso por acción y branch autorizado.
TEN-025	Suspension de tenant o revocación miembro	Sesiones, cache y trabajos dejan de autorizar.
TEN-026	Backup / retención / borrado legal	Se aplica a un tenant sin destruir otro.
TEN-027	Sobrecarga de recursos tenant A	Cuotas previenen degradacion descontrolada del resto.
TEN-028	HTML/JS arbitrario en constructor tenant	Rechazado y sin ejecución.
TEN-029	Editar nombre/logo de A	Solo interfaces de A cambian, B y plataforma no.
TEN-030	Export de reporte y pdf A	Solo emisor, datos, branding, audit y descarga de A.
TEN-031	Admin tenant intenta usar endpoint plataforma	403/404 uniforme, sin leak de metadata.
TEN-032	Falla conexión dedicada	Fail-closed sin redirigir silenciosamente a shared u otro DB.

Estado de los 32 escenarios: DEFINIDOS, NO EJECUTADOS. Todo resultado requiere test registrado y log reproducible. Un defecto P0 de tenant/identidad/audit bloquea certificación y avance de capítulo.

M. Parametrización integral sin código comercial incrustado

Ambito	Ajustes administrables	Nunca heredado o mezclado
PLATFORM	Nombre, dominio verificado, SEO, footer/copyright, mensajes, landing, planes, navegacion, módulos globales, branding e iconos.	No heredar datos legales ni contenido privado de tenant.
TENANT	Nombre propio, logo, tema, plantillas, catálogo, módulos adquiridos, usuarios, permisos autorizados, facturas y bitácora.	No heredar contratos, usuarios, facturacion o auditoría de otros tenants.
BRANCH	Horarios, estacionamiento, ubicación, personal, disponibilidad y recursos por sucursal.	No sobreescribir configuraciones globales no delegadas.
USER	Idioma, accesibilidad, preferencias de tabla/panel dentro de su cuenta.	No elevar permisos ni mutar configuración de otro usuario.
SYSTEM	Validaciones inmutables, seguridad, antifraude, migraciones, SQL y contratos internos.	No editable desde CMS ni json arbitrario.

- Un ConfigKeyRegistry único define cada clave, tipo, limite, owner, scopes admitidos, herencia y reglas de publicación. No repetir "Crecisol" o copyright en decenas de archivos de UI.
- Draft -> validar -> preview antes -> confirmar -> guardar versión y audit -> preview después -> aprobar -> publicar -> invalidar caches -> rollback versionado.
- Sitios tipo revista, UX responsive con tokens, ActionRegistry semantico único e iconos accesibles: no mezclar colecciones visuales incompatibles por pantalla.
- Modales estándar XS/SM/MD/LG/XL y flujos sin perdida de cambios; acceso teclado, aria, focus trap y pruebas en movil/tablet/escritorio.
- Subidas, edicion y descargas con preview fiel cuando aplica: imagen, PDF, DOCX, XLSX, CSV, reportes; conversion Office aislada y sin macros; nunca fingir vista previa.
- La personalizacion de cada empresa no puede alterar seguridad ni que un tenant vea o modifique una revisión ajena.

N. Estándares de calidad y gobernanza secuencial

- Unidad de trabajo: capítulo actual. Los 37 capítulos solo se cierran uno por uno; se lee contexto futuro sin implementarlo ni certificarlo antes.
- Cada entrega por capítulo contiene frontend/, backend/, database/ segun impacto, contratos, tests, README de alcance, hallazgos, rollback y pruebas negativas tenant.
- Pasada A: integridad funcional, relaciones con requisitos originales, parametrización, accesibilidad y experiencias de negocio.
- Pasada B: seguridad, aislamiento, autorización, datos, logs, secretos, idempotencia, cargas maliciosas y privacidad.
- Pasada C: arquitectura limpia, rendimiento, código muerto, calidad visual, regresion, normalización SQL y documentación.
- Sin ejecución real de tests y evidencia de compilacion/DB/UI, el estado es DOCUMENTADO o NO CERTIFICADO; la firma final exige pruebas y aprobación.
- Tras 37/37: auditoría transversal de rutas, roles, permisos, tenants SHARED/DEDICATED, SuperAdmin, backups, todos los formatos, limites y SLA; sin promesas de ausencia absoluta de fallos.

O. Discrepancias conciliadas y criterios de precedencia

ID / tension entre fuentes	Resolución vinculante	Impacto y estado
D-00 - Plan anterior: selector si hay varias membresias; nuevo requisito: nunca selector de empresas en login.	Resolución contextual automática y backend-only; con multiscope ambiguo fail-closed y enlace oficial. SuperAdmin opera desde gestor central.	Afecta C02/C04/C05/C06/C07/C26/C27/C33/C36. Prioridad normativa nueva; AUTO-001..012 pendientes.
D-01 - Original: DB compartida; nueva instruccion: DB propia opcional.	SHARED predeterminada, DEDICATED opcional (managed/customer-hosted condicionado). Un código, placement por backend.	Afecta C03/C04/C06/C07/C24/C26/C27/C33/C35/C36. Diseño aprobado por nueva instruccion; pruebas pendientes.
D-02 - SuperAdmin ve todo vs privacidad de consumidores.	SuperAdmin ve todos los módulos/interfaces, estado/operación; datos reales bajo soporte scoped, step-up/break-glass, auditoría.	C02/C05/C06/C07/C08/C17/C23/C27/C36. Sin acceso irrestricto silencioso.
D-03 - Usuario solicita usuarios propios e historias privadas.	Modelo tenant principal separado, roles, sesiones, módulos, configuraciones y audit por tenant; login global no concede membresia.	Todos los capítulos; particularmente C04-07, C17 y C33.
D-04 - Monolito modular vs microservicios pequenos.	Servicios de código pequenos y vertical slices dentro de un monolito modular; microservicios distribuidos solo con justificacion.	C03 y C26. Evitar sobrecarga operativa prematura.
D-05 - Infra futura documentada vs "solo código" actual.	Describir contratos de GitHub/Hostinger/Cloudflare/Google Drive sin desplegar, crear repositorio, DB remota ni cambiar DNS.	C24/C25/C35: entregables de código y runbooks, no acciones reales.
D-06 - "Todo parametrizado" vs lógica sensible.	Editable el contenido, diseño y negocio permitido; nunca autorización, JWT, firmas, secretos, controles SQL y antifraude.	C01/C09/C23/C34 + auditoría transversal.
D-07 - PDF consolidated como tercer plan.	PDF repite plan+original; no genera un tercer conjunto independiente de requisitos.	Se integra una vez sin anexos duplicados.
D-08 - "Cero deuda" vs ausencia de pruebas reales.	Obligacion de listar y cerrar problemas P0/P1 con evidencia; riesgos residuales y pruebas pendientes no se llaman resueltos.	Todos los capítulos; cierre de código y produccion son hitos diferentes.

INTEGRACIÓN DEL PLAN DE DESARROLLO

Reglamento y contratos técnicos previos preservados

Los siguientes apartados incorporan la redaccion normativa sustantiva del Plan de Desarrollo Local anterior. Se interpretan bajo las decisiones D-01 a D-08, que precisan los nuevos limites de tenant y SuperAdmin.

I · Reglamento maestro y directrices obligatorias

Fecha de consolidación: 7 de noviembre de 2026

Estado: baseline documental propuesta; requiere aceptación del propietario y pruebas de implementación por capítulo.

Fuente: CRECISOL_Diseno_Maestro_SaaS_Multitenant_FINAL.docx, 05-11-2026. La copia original se conserva inalterada con SHA-256 en referencias/.

Precedencia: seguridad/legal obligatorios > documento maestro original > instrucciones explícitas posteriores del propietario > ADR técnicos aprobados > recomendaciones no aprobadas. Si hay contradicción de igual rango, abrir decisión; no inventar cierre.

1. Objetivo y límite de fase

- Desarrollar todo el código fuente de CRECISOL, de forma progresiva, privada y local. No publicar, configurar ni operar GitHub, VPS, dominio, DNS, Cloudflare, Google Drive o cobros reales en esta etapa.
- Aun cuando el documento maestro incluya capítulos 24, 25 y 35 sobre infraestructura futura, ahora únicamente se redactan contratos, archivos de configuración y pruebas locales pertinentes; no se ejecutan despliegues ni se crean cuentas remotas.
- Crear una aplicación SaaS única, multitenant, modular y ligera para comercio, servicios y membresías. Cada sector es un preset de capacidades, nunca una instalación distinta.
- La identidad actual propuesta es CRECISOL, "Tu negocio, a tu manera"; la identidad comercial puede administrarse centralmente con controles de versión. El propietario informa que ya posee el dominio crecisol.com: registrar como titularidad declarada, no como verificación técnica DNS/TLS.
- SOLQARYN es una relación institucional y de marca; repo, skills, secretos, bases, personas, endpoints, documentación privada e infraestructura de SOLQARYN son SOLO LECTURA cuando exista permiso para consultar. Prohibidas escrituras, PR, commits, cambios de settings o automatizaciones. Sin dependencias técnicas compartidas por inferencia.

2. Tres áreas de código obligatorias

- frontend/ — Angular 22 standalone, Signals y módulos lazy; sitios públicos, landing SaaS, SuperAdmin, negocio, empleado y consumidor; design system, editor visual y tests UI.
- backend/ — ASP.NET Core 10, arquitectura limpia, monolito modular y vertical slices; Domain, Application, Infrastructure, API, workers desacoplados. Controladores y servicios pequeños. Node 24 exclusivamente tooling del frontend salvo decisión explícita.
- database/ — MySQL 8.4 LTS InnoDB; modelo 3FN, relaciones y FK por tenant, índices medidos, seeds no sensibles, SQL y migraciones versionadas, tests de integridad, scripts de restore local.

docs/, qa/ y referencias/ contienen documentación, matrices y pruebas y NO son fases de producto. Una característica puede requerir cambios pequeños en las tres áreas, pero la unidad de avance es el capítulo, nunca desarrollar varios a la vez.

Monolito modular vs microservicios: el propietario solicita servicios diminutos y menciona microservicios; para esta fase local se propone monolito modular con fronteras extraíbles, evitando procesos, redes, bases y

observabilidad repetidos. La decisión de microservicios distribuidos queda ABIERTA: solo migrar si pruebas de carga/equipo/aislamiento justifican el coste. No convertir por defecto cada módulo en microservicio.

3. Parametrización exhaustiva y segura

- Todos los valores editables de negocio se almacenan una sola vez por clave, ámbito y revisión: nombre, siglas, eslogan, idioma, dominio verificado, enlaces, SEO, copyright, emisor legal, redes, banners, textos, plantillas, imágenes, tablas configurables, menús, temas, colores, iconos semánticos, formularios, bloques, catálogos, promociones, horarios y ajustes permitidos.
- Ámbitos independientes: Platform (SaaS), Tenant (empresa contratante), Branch (sucursal) y usuario cuando proceda. Un pie/copyright del tenant nunca hereda datos legales de la plataforma por accidente. Los contratos firmados conservan snapshots, aunque luego cambien textos o marcas.
- Single source of truth: el componente solicita config.get(key, scope, publishedRevision) y no repite literales. Resolución por precedencia definida en esquema: defaults tipados → plataforma → tenant → sucursal, solo para claves declaradas sobreescribibles. No inferir dominios a partir del nombre: DNS/TLS requiere verificación independiente.
- Valores administrables ≠ lógica arbitraria. Autenticación, autorizaciones, aislamiento, antifraude, máquinas de estados críticas, validación, SQL, tokens y límites de seguridad quedan en código probado y protegidos por RBAC/ABAC; el administrador controla solo políticas y opciones permitidas.
- Todos los cambios editables: borrador → validar → preview previo → confirmar → guardar versión + auditoría → preview posterior → aprobar/publicar → invalidar caché → rollback. Guardar ≠ publicar.
- Nunca usar JavaScript/HTML/CSS, SQL o expresiones ejecutables proporcionadas por clientes. Bloques de diseño y componentes mediante esquemas JSON tipados y allowlist.
- Los catálogos comerciales y opciones de formularios pertenecen a datos administrables; los códigos de errores, permisos base, transiciones ilegales y reglas antifraude se definen en código.

4. Diseño editorial y estándares visuales

- Sitio público y landings: experiencia editorial tipo revista, fotografías optimizadas, jerarquía tipográfica, contraste, layouts cambiantes por bloques, animaciones sutiles y respeto de prefers-reduced-motion.
- Paneles administrativos: densidad controlada, cards y tablas ligeras, vistas responsive, vacíos útiles, feedback sin recargas innecesarias, formularios por pasos y menús por entitlements del servidor.
- Design System único: paleta por tokens, tipografía, espaciado, sombras, radios, densidad, iconografía, estados, foco, hover, carga, errores, breakpoints, modales y navegación. Nada de estilos inventados en cada pantalla.
- ActionRegistry con IDs estables (save, edit, preview, download, upload, delete, cancel, close, restore, publish, approve, search, filter, share, copy, history, permissions). Cada acción tiene icono único, semántica, tooltip, nombre accesible, severidad y confirmación. Se permiten botones solo-icono si son inequívocos, accesibles y comprensibles en móvil.
- Modales XS ~380 px, SM ~520 px, MD ~720 px, LG ~960 px, XL ~1180 px como tokens iniciales propuestos, sujetos a pruebas responsive. Focus trap, Escape según seguridad, manejo scroll, acciones claras y móvil full screen si conviene.
- Todo flujo de subida, edición, guardado y descarga relevante debe ofrecer vistas previas antes y después según formato (imagen, PDF, Word, Excel, CSV, TXT, reportes), autorización y resultado real. Sin motor seguro/fiel de preview, la UI no simula que verificó el documento; se bloquea cuando así lo exige la política de operación.

5. Arquitectura de rendimiento

- Sin duplicar reglas entre frontend/backend/BD. Dominio independiente de HTTP/ORM/servicios externos; aplicación con un caso de uso por intención; infraestructura tras puertos; API delgada; workers solo tareas asíncronas.
- Angular lazy loading, páginas públicas ligeras, imágenes responsive/caché, Signals y carga de bibliotecas por necesidad; virtualización de tablas grandes. Un solo cliente OpenAPI tipado.

- Backend: paginación y filtros server-side, proyecciones DTO, consultas parametrizadas, sin N+1, jobs/outbox idempotentes, límites, timeouts y reintentos con backoff. Un controller/grupo de endpoints por recurso, no controllers gigantes.
- MySQL normalizado ≥3FN cuando aporta integridad, DECIMAL para dinero, UTC con zona explícita para agenda, InnoDB, índices compuestos tenant/sucursal/recurso/estado/fecha. Medir antes de denormalizar.
- No prometer 0 ms, 0 bugs ni escalabilidad infinita. Fijar presupuestos de rendimiento por ADR y test de carga representativo antes de certificar.

6. Seguridad, privacidad, documentos y multimedia

- Backend resuelve tenant mediante host verificado + pertenencia + permiso vigente + sucursal + recurso; URL/ID no son autorización. Aislar consultas, cache, eventos, archivos, dominios, dashboards y exportaciones.
- Administradores MFA/passkey según riesgo, sesiones revocables, recuperación sin preguntas de seguridad, secretos fuera del código, logs sin PII innecesaria, antifraude y auditoría.
- Archivos: cuarentena y verificación MIME real, tamaño, malware según tipo, control de conversión y cuota; previews autorizadas y render seguro (PDF, DOCX, XLSX); descargas temporales y auditadas. Evitar macros/enlaces externos en Office.
- Consentimiento y texto legal versionados por relación contractual; tres planos diferenciados (SaaS, tenant, consumidor) con propietarios/autores reales y evidencias históricas.
- Sin contraseñas reales, bases de usuarios reales, cobros reales ni conectores de producción en pruebas locales.

7. Secuencia de trabajo obligatoria: un capítulo a la vez

- El capítulo N solo pasa a EN_DESARROLLO cuando N-1 tenga cierre técnico documentado y aceptado. Se permite leer capítulos futuros para comprender dependencias, pero no cerrar ni declarar implementado N+1 prematuramente.
- Partir cada capítulo en microtareas con un resultado comprobable; cada microtarea define: objetivo, módulos/rutas permitidas, contratos, datos, permisos/PII, riesgo, prueba positiva y negativa, prueba de rendimiento/UI, reversibilidad, evidencia, responsable y estado.
- Triple auditoría por capítulo: (A) funcional/negocio y trazabilidad íntegra; (B) seguridad y pruebas negativas (incluye tenant y roles cuando aplica); (C) arquitectura, rendimiento, UX/visual, regresiones y documentación. Después ejecutar relectura final de integración y firmar acta.
- Los estados son PENDIENTE, ANALIZADO, EN_DESARROLLO, EN_PRUEBAS, AUDITORIA_1, AUDITORIA_2, AUDITORIA_3, LISTO_PARA_APROBACION, CERTIFICADO. La mera revisión documental no confiere ninguna certificación de software.
- Para CERTIFICADO exigir: código compilado realmente con versiones aprobadas, tests ejecutados y logs, cobertura de criterios incluyendo negativos, análisis de diff/archivos, vulnerabilidades P0/P1 resueltas, UI escritorio/tablet/móvil revisada si aplica, métricas/impacto medidos, rollback, hash local del snapshot de código, documentación sincronizada, aprobación del responsable.
- Si falla un gate: BLOQUEADO con causa concreta, acción correctiva, regresión tras fix; no avanzar al capítulo siguiente. La palabra "perfecto" debe ser criterio verificable, no garantía infundada.

8. Entregables por capítulo

Cada capítulo entrega: Cxx_SCOPE.md, casos de uso/API/DTO, frontend y migraciones según impacto, Cxx_TESTS.md, Cxx_AUDIT_1_2_3.md, evidencias de ejecución y capturas, Cxx_OPEN_ISSUES.md, Cxx_CHANGELOG.md, Cxx_CERTIFICATION.md. Si no aplica alguna capa, declarar "NO APLICA" con explicación; no dejar archivos vacíos como evidencia.

9. Fin de programa y auditoría transversal final

Tras el capítulo 37: auditoría cruzada de 37/37 con lectura de cada archivo/contrato/tabla/ruta, auditoría de seguridad integral, dependencia, dead code, SQL, a11y, pruebas de carga locales, export/preview, copia y

restauración, permisos A/B, diseño responsive, documentación y cobertura de 30 mejoras. Solo entonces podrá existir un dictamen de código local preparado; no equivale a certificación de operación productiva.

II · Arquitectura técnica y tres áreas del código

Topología del código fuente (único proyecto, tres áreas)

```
CRECISOL/
├── frontend/
│   ├── apps/public-web/          # Marketing SaaS y publicaciones tenant
│   ├── apps/admin-web/           # SuperAdmin/tenant/empleados (fase posterior)
│   ├── libs/design-system/       # tokens, iconos, modales, accesibilidad
│   ├── libs/config-runtime/      # marca, menús, temas, i18n, caché por revisión
│   └── tests/                    # unit/component/e2e/visual
├── backend/
│   ├── src/Api/                  # HTTP delgado, composition root, contrato
│   ├── src/Domain/               # invariantes de negocio puros
│   ├── src/Application/          # un use case por intención + puertos
│   ├── src/Infrastructure/       # adaptadores MySQL/medios/PSP/email
│   ├── src/Modules/              # módulos de aplicación/organización
│   ├── src/Workers/              # Outbox/reintentos (fase posterior)
│   └── tests/                    # unit/integration/security/contract
├── database/
│   ├── schema/                   # diccionario relacional y propiedad de tablas
│   ├── migrations/               # SQL reversible o migraciones con hash
│   ├── seeds/                    # solo datos sintéticos de desarrollo
│   └── tests/                    # integridad, FK, concurrencia, restore
├── docs/                         # normas y fichas de 37 capítulos
├── qa/                           # scripts locales, matrices y reportes
└── referencias/                  # master original inmutable y evidencia hash
```

El árbol presenta destinos previstos. Al entregar un capítulo, solo se materializan los componentes implementados; no crear decenas de proyectos vacíos para aparentar progreso.

Reglas de dependencia

- Domain no referencia Application, Infrastructure, Api ni frameworks concretos.
- Application conoce Domain y contratos/puertos, no implementaciones EF/HTTP.
- Infrastructure implementa puertos de Application y accede a MySQL/adaptadores; no dicta reglas de dominio.
- Api ensambla DI y traduce HTTP a casos de uso; prohibido SQL o lógica comercial compleja en controladores.
- Workers usa casos de uso, Outbox y reintentos idempotentes; no alterar tablas de módulos ajenos.
- En Angular, features dependen de contratos y componentes de UI; no de clases internas de API o de almacenamiento.
- En MySQL, cada tabla tiene módulo propietario; claves ajenas protegidas por FK, sin escrituras cruzadas directas desde otros módulos.

UI de parametrización

KeyCatalog (tipos y permisos) -> ScopeResolver (plataforma/tenant/sucursal) -> DraftEditor -> PreviewService -> PublishUseCase -> ImmutablePublishedSnapshot -> caché por revisión. Los clientes solo reciben proyección pública segura; credenciales y datos privados nunca son settings públicos.

Ejemplo de ámbito: platform.brand.name y tenant.brand.name son distintas claves, y lo mismo platform.footer.copyright / tenant.footer.copyright. Un cambio central de platform.brand.name no edita 50 fuentes y no cambia el historial firmado previo.

Persistencia de parametrización

- Preferir entidades relacionales tipadas para dominios/roles/contratos/revisiones, no una tabla de EAV sin restricciones.
- Puede utilizarse un registro JSON validado solo para bloques de contenido o temas con versión de esquema, tipos y tamaño máximos definidos.
- Cualquier consulta/índice/clave externa crítica permanece relacional y tenant-scoped; auditar todos los cambios.
- Modelar draft, pendingApproval, published, archived con versiones inmutables para snapshots. El contenido del cliente no se interpola como código.

Ligereza y escalabilidad

Monolito modular evita costos de microservicios separados ahora; módulos con contratos internos y límites claros permiten extracción futura. Contenedores y hosting son posteriores. Node 24 es entorno de compilación Angular, no backend paralelo. OpenAPI define el cliente tipado. Métricas objetivo se fijan tras medir MVP sintético: LCP, INP, CLS, JS por ruta, p95 de API, queries, RAM, concurrencia y tiempo de recuperación.

Versiones de trabajo para análisis y pruebas (07-11-2026)

Capa	Referencia estable	Estado
Angular	22.x (22.2.x como rama activa)	Propuesta; probar paquetes alineados
TypeScript	>=6.0.0 y <6.1.0	Restricción publicada por Angular 22
Node.js	24.22.2 LTS	Fijación de major 24 solicitada
ASP.NET Core	10.0.14 LTS	Línea base propuesta
EF Core Microsoft	10.0.14	Línea base propuesta
MySql.EntityFrameworkCore Oracle	10.0.12	Candidato a validar contra EF 10.0.14 y MySQL real
MySQL	8.4.13 LTS (InnoDB)	Línea base propuesta
Docker	Compose solamente en desarrollo futuro	No iniciar contenedores remotos

Estas no son versiones instaladas ni compilaciones certificadas. Validar todas mediante instalaciones y pruebas de migraciones reales antes de pin final. No cambiar Node a 26 sin orden del propietario.

Referencias públicas consultadas

- https://angular.dev/reference/versions
- https://angular.dev/reference/releases
- https://nodejs.org/en/download
- https://dotnet.microsoft.com/en-us/platform/support/policy
- https://www.nuget.org/packages/Microsoft.EntityFrameworkCore/10.0.14
- https://www.nuget.org/packages/MySql.EntityFrameworkCore/10.0.12
- https://dev.mysql.com/doc/relnotes/mysql/8.4/en/

III · Parametrización, diseño UI y vistas previas

La obligación es permitir toda modificación de contenido y presentación comercial permitida sin editar código fuente, no permitir que un editor ejecute código ni altere las invariantes. Un ConfigKeyRegistry define tipos, validación, herencia, roles y efecto de publicación por clave. La implementación es progresiva por capítulos.

Jerarquía, propiedad y aprobación

Ámbito	Propietario lógico	Ejemplos de contenido	Regla obligatoria
PLATFORM	SuperAdmin CRECISOL	nombre, footer, copy, SEO, menús SaaS, landing, planes, copyright global	Solo permisos de plataforma; publicar no cambia contratos históricos
TENANT	Empresa contratante	marca, pie legal propio, web, catálogo, promociones, textos, horarios, diseño	Nunca lee/escribe otros tenants
BRANCH	Encargado autorizado	ubicación, parking, horarios y recursos de sede	Heredar únicamente propiedades permitidas
USER	Identidad autenticada	idioma, accesibilidad y distribución privada de panel	No eleva permisos ni modifica política del tenant
SYSTEM	Código revisado	autorización, estados críticos, antifraude, límites de entrada, firmas, migrations	No editable por constructor visual

Catálogo inicial por familias; no valores en archivos de UI

- Marca: brand.name, brand.shortName, brand.tagline, brand.descriptor, brand.logoAsset, brand.faviconAsset, brand.palette, brand.typography, brand.coverAsset, brand.altText.
- Identidad digital: domain.canonical, domain.verifiedAt, site.path, seo.titlePattern, seo.description, seo.openGraph, seo.robotsPolicy, site.language, site.defaultLocale.
- Legal y pie: legal.ownerName, legal.contact, legal.address, legal.registrationData, footer.sections, footer.copyrightTemplate, footer.links, footer.visibleModules, privacy.documentVersion. Diferenciar información confirmada de pendiente.
- Comercial: site.hero, site.ctas, site.sections, site.nav, site.promotions, site.testimonials, site.news, site.maps, site.parking, site.contact, site.hours.
- UX: theme.tokens, ui.density, ui.cardLayout, ui.fontScale, ui.iconRegistryVersion, ui.modalSizeTokens, ui.animations, ui.reducedMotionDefault, ui.tablePreferences, ui.emptyStateContent.
- Contenido: content.pages, content.blocks, content.translations, content.reviewState, content.publishAt, content.mediaRefs.
- Recursos administrativos: catalog.categories, catalog.attributes, forms.schemas, forms.selectOptions, staff.displaySettings, schedule.publicHours, pricing.publishedLists, notifications.templates.
- Emisores: platform.copyright y tenant.copyright separados. La palabra "empresa" puede referirse al operador SaaS o al tenant: cada documento y pantalla tiene issuerScope explícito.

Contrato de publicación

- PATCH draft por dueño autorizado con optimistic concurrency / ETag y auditoría.
- Validador: tipos, tamaño, esquema, accesibilidad, permisos, relaciones de medios, legalidad y dominio.
- preview(draftVersion) privada, no indexada, sujeta a permiso y sesión.
- Confirmación explícita y guardado de revisión; vista previa posterior del contenido realmente persistido.
- publish(savedVersion) con permiso superior si sensible y snapshot inmutable.
- Invalidación por clave de revisión/tenant/sucursal; rollback con nueva revisión, no historia reescrita.

Iconos y modales

- ActionRegistry: registro semántico versionado y único. Botón solo-icono debe tener etiqueta accesible y tooltip, foco visible, variante táctil. Acciones ambiguas llevan texto visible.
- XS 380 / SM 520 / MD 720 / LG 960 / XL 1180 px: valores de diseño propuestos, no umbrales de compatibilidad acreditados. Cada modal en móvil adapta altura, focus trap, scroll, Escape, backdrop, submit, prevención de pérdida de cambios.
- Componentes canon: ActionButton, ConfirmDialog, PreviewDialog, FormField, CrudTable, SearchToolbar, Tag, Status, SidePanel, Card, Toast, FileUploader, DocumentViewer, ImageViewer.

Preview de archivos por tipo

Formato	Antes subir / guardar	Antes descargar	Motor previsto
PNG/JPG/ WebP/AVIF	miniatura + dimensiones/MIME	render del asset exacto	navegador seguro + metadata servidor
PDF	render paginado seguro	versión exacta autorizada	visor sandbox sin JS activo
DOCX	conversión fiel aislada, sin macros	snapshot renderizado	conversor aislado a PDF bajo cuota
XLSX	hojas, filas limitadas y fórmulas no ejecutables	snapshot de hoja o PDF seguro	parser server-side con límites/expurgo
CSV/TXT	tabla/texto truncado con aviso	vista fiel del archivo exportado	parser seguro y encoding verificado
Reportes	borrador de parámetros y resultado persistido	snapshot exacto generado	servicio de informes con revalidación

Fail-closed: si no existe preview suficiente para una operación donde es obligatoria, no ofrecer acción de descarga como si estuviera validada; mostrar causa y acción correctiva. El original siempre permanece auditable según retención.

IV · Calidad, evidencias y triple auditoría

Regla: no declarar "certificado" antes de compilar, probar y revisar realmente el código. Cada prueba tiene id, chapter, requirement_id, positive_or_negative, tool, commit_or_local_hash, actual_result, log_path, timestamp_utc, reviewer y status.

Pasada A | Producto y trazabilidad

- Mapa de cada tabla/párrafo del original a requisito, implementación, test y responsable.
- Casos de negocio completos; preview antes de guardar/editar/exportar y después de guardar cuando proceda.
- Verificar textos y contenido editable desde una fuente por ámbito, no literales dispersos.
- Tres planos: platform, tenant y consumidor; tres zonas: frontend, backend y base de datos.
- Pruebas positivas y estados límite; verificar pantallas con datos vacíos, medianos y abundantes.

Pasada B | Seguridad y datos

- Roles/ABAC, aislamiento tenant/sucursal, BOLA/IDOR, SSRF/XSS/CSRF, validación y rate limiting cuando aplique.
- Descargas privadas y vistas previas aisladas; firmas temporales; sin macros ni enlaces activos en Office.
- Idempotencia pagos, QR, agenda, stock y webhooks; no secreto ni PII en logs.
- Concurrencia y transacciones MySQL; rollback de migración; relectura SQL generado.

Pasada C | Arquitectura, rendimiento y UX

- Dependencias limpias, un caso de uso por intención, controller delgado, sin duplicación de reglas.

- Bundle/paint/a11y/reduced motion, diseño tipo revista en público y eficiencia en paneles; iconos semánticos y modales de token.
- Comportamiento responsive en viewport escritorio, tablet y móvil; E2E reproducibles y revisión de capturas.
- Análisis de consultas, índices, p95, RAM, red y degradación bajo errores; umbrales sujetos a línea base medida.
- Archivos permitidos, tests de regresión, código muerto, docs actualizadas y retroceso verificable.

Cierre

La certificación de capítulo necesita triple evidencia distinta, acta con alcance y riesgos remanentes, verificación de versiones y hash de archivos (sin Git obligatorio), aprobación. El título CERTIFICADO se reserva a una ejecución comprobada; todo lo demás es DISEÑADO o PENDIENTE.

Auditoría global final (después de C37)

- Revisión carpeta por carpeta, archivo por archivo, contratos API/DTO, tablas/FK, claves/tokens, permisos por acción y tenant, editor visual y todos los canales de preview/download.
- Conciliar 37 capítulos, 30 mejoras, matrices P0/P1 originales y suite ampliada del capítulo 36.
- Local: e2e de demos, restauración de backup sintético, controles de seguridad, accesibilidad y cargas representativas. Producción queda fuera del alcance.

No se implementan dos capítulos a la vez. Las 37 fichas siguientes son objetivos de implementación, no certificaciones. Cada ficha exige las tres áreas técnicas cuando corresponda, aunque no exista backend/bd funcional todavía.

Para cada capítulo: planificar microtareas Cxx-01 a Cxx-08, ejecutar pruebas, auditoría A, auditoría B y auditoría C, resolver hallazgos, generar acta; solo entonces avanzar. Las microtareas pueden subdividirse sin alterar el orden de capítulos.

CAPÍTULO 01 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

01. CRECISOL: identidad, visión, alcance y principios

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

CRECISOL es una plataforma SaaS universal para pequeñas y medianas empresas de comercio, servicios y membresías. Cada negocio configura su marca, sitio web, panel, catálogo, recursos, empleados y reglas comerciales. La complejidad técnica permanece oculta detrás de flujos sencillos, consistentes y accesibles.

Se desarrollará una sola base de producto con capacidades compartidas y módulos especializados por rubro; no una colección de instalaciones diferentes, tampoco un ERP corporativo de propósito ilimitado. La modularidad debe permitir crecer sin heredar contabilidad avanzada, nómina integral ni procesos industriales como requisitos de toda empresa.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Público objetivo	Comercios, profesionales y negocios con una o varias sucursales; posibilidad de crecer a empresas medianas.	Catálogo de capacidades universal; límites comerciales configurables; sin dependencia artificial de un sector.
Producto y servicio mixtos	Un mismo negocio puede vender productos, ofrecer servicios y cobrar membresías.	Venta, reserva y suscripción utilizan contratos y reglas distintas con cliente e historial común.
Diseño sin código	Propietario reorganiza tarjetas, páginas, secciones, tipografías, banners y dashboard por medio de editor visual.	Esquemas seguros, vista previa, publicación versionada y rollback.
Seguridad por defecto	Autenticación y autorización del lado del servidor; mínima exposición de datos y privilegios.	Puertas P0 de aislamiento, identidad, pagos, privacidad y respaldo.
Performance percibida	Páginas públicas ligeras, acciones rápidas y administrativos compactos y responsivos.	Presupuestos de tamaño, rendimiento y pruebas en móvil real.
Rapidez controlada	Trabajo en microtareas independientes, pequeñas, revisadas y con evidencia.	Un solo objetivo verificable por PR; ningún bypass de seguridad para desplegar antes.
No-limitación artificial	Diseñar extensiones, atributos, plantillas y rubros como catálogos administrables.	Cuotas técnicas honestas, límites por plan y reglas legales explícitas; no promesas de capacidad infinita.

1.1. Invariantes de diseño

- Ningún dato privado de un tenant se entrega a otro, incluso ante cambio de URL, parámetro, encabezado, caché, evento o archivo.
- No existe cobro real sin confirmación confiable del proveedor y operación idempotente; no se almacenan CVV ni números completos de tarjeta.
- Una URL no representa autorización y un identificador aleatorio tampoco sustituye el permiso.
- El sitio público y los dashboards se personalizan como datos validados, jamás como JavaScript o consultas SQL enviadas por el cliente.
- El SuperAdmin gobierna la plataforma y puede acceder a diagnósticos y operaciones autorizadas; los datos personales de consumidores mantienen controles y accesos excepcionales auditados.
- Una modificación de horario, contrato, inventario o derecho de membresía conserva trazabilidad y no borra evidencia histórica.

- Los recursos operativos deben poder recuperarse: respaldos, restauración verificada, procedimientos de emergencia y despliegue reversible.

1.2. Límites deliberados

Este diseño no pretende sustituir sistemas hospitalarios, historia clínica, nómina avanzada, contabilidad corporativa, gestión tributaria integral, banca, pasarela agregadora de fondos o procesos manufactureros complejos. Esas áreas son extensiones condicionadas a requerimientos legales y operativos; no se habilitan implícitamente por la etiqueta “universal”.

1.3. Identidad oficial y posicionamiento comercial

CRECISOL es el nombre comercial definitivo del producto. Su promesa de marca es “Tu negocio, a tu manera.” y su descriptor es “Comercio · Servicios · Membresías · Crecimiento”. La plataforma permite que cada pequeña o mediana empresa configure su presencia digital y gestión comercial con herramientas universales, seguras y adaptables al rubro. La comunicación comercial debe hablar de resultados y facilidad de uso, sin prometer rendimientos, resultados garantizados ni capacidades no implementadas.

Significado de la marca: “CRECI” evoca crecimiento y evolución empresarial; “SOL” evoca claridad, energía e identidad vinculada a SOLQARYN. Esta es una narrativa de marca adoptada para el producto, no una etimología registral ni una garantía de resultados.

Elemento	Identidad aprobada	Regla de uso y verificación
Nombre público	CRECISOL	Escritura exacta en mayúsculas para logotipo; Crecisol en prosa cuando corresponda; evitar nombres provisionales.
Lema	Tu negocio, a tu manera.	Promesa principal en página comercial, demos y campañas; no debe confundirse con garantías contractuales.
Descriptor	Comercio · Servicios · Membresías · Crecimiento	Describe familias de valor. No impone exclusividad de capacidades por rubro.
Relación de marca	CRECISOL, una plataforma de SOLQARYN	Respaldo institucional y origen de marca. No implica dependencia de código, usuarios, base de datos ni infraestructura.
Público objetivo	Pequeñas y medianas empresas	Comercio, servicios y membresías; cada tenant activa sus capacidades según su operación.
Dominio comercial elegido	crecisol.com	No afirmar compra, titularidad o disponibilidad marcaria sin evidencia del registrador y consulta legal.
Identidad del negocio	Marca propia del tenant	Los sitios, correos, documentos, QR y pagos del negocio no deben aparentar ser emitidos por la plataforma cuando no corresponda.
Naturaleza del producto	SaaS multitenant comercial universal	No describirlo como ERP corporativo ilimitado, entidad financiera, pasarela de fondos ni sistema médico.

1.4. Relación institucional con SOLQARYN y aislamiento absoluto

CRECISOL se comercializa como producto respaldado por SOLQARYN y posee identidad de producto independiente. La relación es de marca, portafolio y eventual titularidad corporativa, sujeto a la formalización legal. No autoriza reutilizar credenciales, repositorios, documentación sensible, claves, datos de clientes,

entornos o servicios de SOLQARYN. Las referencias a SOLQARYN en CRECISOL deben limitarse al aval de marca y a la información institucional autorizada.

- Repositorio GitHub propio, pipeline CI/CD y permisos propios. La documentación de CRECISOL debe conservarse en espacio o carpeta separados, con acceso según rol.
- Frontend, API, workers y MySQL propios en Hostinger VPS. No usar conexión transversal ni integración no aprobada con sistemas de SOLQARYN.
- Buckets, claves, rutas y políticas de Cloudflare R2 de CRECISOL separados; documentos privados de cada tenant bajo autorización y expiración, nunca bajo enlaces públicos permanentes.
- El SuperAdmin de CRECISOL solo puede operar el producto y sus tenants mediante autorizaciones trazables; no obtiene acceso automático a otras plataformas por ser una marca relacionada.
- En contratos, facturas y privacidad deberán aparecer la persona jurídica responsable, datos de contacto y relación de encargo de tratamiento reales, una vez acreditados. “Una plataforma de SOLQARYN” no sustituye estos datos.

1.5. Identidad digital, lanzamiento y anticlonación

- Dominio raíz crecisol.com: reservado para presencia comercial y puntos de entrada oficiales una vez comprobada su titularidad. Los dominios propios de los negocios requieren verificación de control y resolución de tenant; la coincidencia visual del dominio no concede permisos.
- Publicar identidad coherente en favicon, título y metadatos SEO, Open Graph, encabezados, correo transaccional, notificaciones, recibos, plantillas de pago, centro de ayuda, aplicaciones y QR generados por la plataforma. En sitios de negocios manda la marca del tenant y se informa el proveedor tecnológico solo cuando proceda.
- Correo de plataforma: seleccionar y verificar direcciones reales antes de publicar; configurar SPF, DKIM y DMARC, enlaces absolutos seguros y protección contra phishing. Nunca inventar cuentas de soporte ni usar direcciones no verificadas.
- Separar enlaces de autenticación, enlaces de pago y QR por propósito, contexto, audiencia, expiración y emisor. No incrustar secretos permanentes en logos, correos, códigos QR o metadatos compartibles.
- Reservar en la plataforma los slugs administrativos y de sistema (www, api, admin, auth, pagos, ayuda y equivalentes) sin impedir que una empresa defina su marca; validar IDN/punycode, homoglifos, redirecciones, colisiones y host headers.
- Verificar antes del lanzamiento antecedentes de marca en el mercado objetivo, titularidad del dominio, protección de cuentas del registrador, renovaciones y recuperación, perfiles sociales y políticas de uso institucional. No asumir aprobación marcaria ni propiedad jurídica por la selección del nombre.

1.6. Mensajes comerciales de referencia

Encabezado comercial principal: CRECISOL — Tu negocio, a tu manera. / Subtítulo: Comercio · Servicios · Membresías · Crecimiento.

Propuesta de valor: “Crea tu presencia digital, organiza tus ventas, reservas y membresías, conoce a tus clientes y administra tu empresa desde un solo lugar. CRECISOL se adapta a tu forma de trabajar.” Esta redacción es material de marca planificado y debe ajustarse a las funcionalidades efectivamente publicadas, los términos y las pruebas del producto.

Llamados a la acción sugeridos: “Conoce CRECISOL”, “Explora las soluciones”, “Solicita una demostración” y “Conoce nuestros planes”. El panel no debe presentar como comprable una función aún deshabilitada, ni registrar datos de pago fuera de un proveedor autorizado.

1.7. Pruebas de aceptación de marca e identidad digital

Control	Escenario verificable	Criterio de aceptación
Marca global	Landing, onboarding, SuperAdmin, correos, SEO y documentos	Todos muestran CRECISOL, eslogan/descriptor coherentes; sin denominaciones provisionales ni marcas ajenas no autorizadas.
Marca del tenant	Sitios públicos, portal, pagos, reseñas y QR por negocio	Cada tenant conserva su identidad, políticas y destinatario del pago; se impide fuga de branding y datos entre empresas.
Relación matriz	Footer, contratos y página institucional	La relación con SOLQARYN se expresa como respaldo comercial; el documento contractual identifica a la persona jurídica real.
Dominio y seguridad	Dominio raíz, subdominios y dominios propios verificados	Host canónico, TLS y resolución determinista; host malicioso, redirección abierta o slug reservado no otorgan acceso.
Mensajería y enlaces	Enlace de acceso, recuperación, cobro y notificación	Plantilla identifica emisor y propósito; tokens no se exponen en logs, referers, capturas o enlaces compartidos indebidamente.
Comprobación previa al lanzamiento	Marca, titularidad de dominio, datos fiscales y medios oficiales	Se archiva evidencia verificable y responsable de revisión, sin afirmar derecho de marca o compra inexistente.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. CRECISOL es una plataforma SaaS universal para pequeñas y medianas empresas de comercio, servicios y membresías. Cada negocio configura su marca, sitio web, panel, catálogo, recursos, empleados y reglas comerciales. La complejidad técnica permanece oculta detrás de flujos sencillos, consistentes y accesibles.

FRONTEND	**Shell público de CRECISOL, cabecera, pie, SEO y pantallas de identidad como componentes vinculados a PlatformBrandStore; selector de idioma y modo vista previa.**
BACKEND	Identidad comercial versionada; lectura pública del snapshot aprobado; endpoints delgados, validación tipada, contrato de marca; ningún campo sensible en respuesta.
BASE DE DATOS	Esquema normalizado de perfil de plataforma y revisiones de marca; identidad comercial, textos y emisor jurídico en entidades distintas; migraciones reversibles.

Prueba de aceptación y riesgo

Positivas / negativas. Modificar una única clave de nombre se refleja en cabecera/pie/SEO; copyright plataforma distinto de copyright tenant; dominio solo tras verificación; no reescribir contratos históricos.

Control crítico. Identidad confundida con autorización o datos jurídicos inventados; contrato de marca hardcoded.

Requisitos de origen que deben rastrearse

PÚBLICO OBJETIVO	Comercios, profesionales y negocios con una o varias sucursales; posibilidad de crecer a empresas medianas.
PRODUCTO Y SERVICIO MIXTOS	Un mismo negocio puede vender productos, ofrecer servicios y cobrar membresías.
DISEÑO SIN CÓDIGO	Propietario reorganiza tarjetas, páginas, secciones, tipografías, banners y dashboard por medio de editor visual.

Fuente completa: 3 tabla(s), 24 filas, 34 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C01-01 Extraer / C01-02 Diseñar / C01-03 Codificar / C01-04 Probar / C01-05 Auditar A / C01-06 Auditar B / C01-07 Auditar C / C01-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Editar un nombre global en una clave única no cambia identidad de tenant, ni le da acceso a bitácoras de CRECISOL.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 01, rutas y componentes; 34 parrafos sustantivos y 3 tablas originales (24 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CAPÍTULO 02 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

02. Personas, experiencias y arquitectura de producto

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

PRECEDENCIA NORMATIVA 07-11-2026: cualquier texto anterior que permitiera seleccionar empresa durante el inicio de sesión queda sustituido. El acceso tenant se resuelve automáticamente, sin selector, exclusivamente desde identidad y contexto verificados; si es ambiguo, se rechaza y se solicita la URL oficial del negocio. Véase G.6 y AUTO-001..012.

CRECISOL expone seis experiencias coherentes: landing pública del SaaS, registro/contratación de empresas, consola central SuperAdmin, panel del negocio, puesto de empleado y sitio/portal del consumidor. La identidad visual podrá variar por tenant, pero controles de autorización, componentes nucleares y contratos permanecen estandarizados.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Visitante del SaaS	Explora propuesta comercial, paquetes, testimonios moderados, demostraciones y contratación.	Contenido editable por SuperAdmin; seguridad, SEO, consentimiento y analítica limitada.
SuperAdmin de plataforma	Gestiona empresas, planes, contratos, pagos SaaS, dominios, métricas, costos, integraciones, seguridad, soporte y catálogo de módulos.	MFA resistente a phishing, segregación de funciones, auditoría y acceso excepcional a información sensible.
Propietario de negocio	Administra sus sucursales, branding, empleados, permisos, menú, catálogo, reservas, finanzas y experiencias públicas.	Solo su tenant; confirmación adicional para acciones financieras o destructivas.
Empleado	Ve tareas, clientes y operaciones conforme a permisos por acción, sucursal y asignación.	Sin finanzas ni expedientes ajenos por defecto; acceso revocable al instante.
Cliente final	Reserva, compra, solicita cotizaciones, consulta historial, administra consentimiento, valoraciones y recompensas.	Identidad contextual vinculada al negocio; segregación del historial entre tenants.
Centro de demostración	Muestra versiones ilustrativas de todos los módulos por sector y rol, en escritorio, tablet y móvil.	Solo datos sintéticos, escenarios reproducibles, sin credenciales reales ni cobros.

2.1. Flujo omnicanal representativo

01. El visitante accede al sitio del negocio por su ruta, subdominio o dominio propio.
02. El servidor resuelve un dominio verificado y aplica configuración publicada del tenant.
03. El visitante navega catálogo, mapa, horarios y servicios sin acceso a datos privados.
04. Al reservar, comprar o autenticarse, se comprueba identidad y permisos en backend.
05. La acción se persiste transaccionalmente y se genera evento recuperable para notificar.
06. El negocio ve los cambios en el panel; el cliente consulta exclusivamente sus comprobantes e historial.
07. La operación alimenta métricas, auditoría y, cuando proceda, un flujo de pagos o fidelización.

2.2. Requisitos de UX no negociables

Botones de acción predominantemente iconográficos, con nombre accesible, tooltip al pasar el cursor y alternativa de comprensión en móvil. Formularios en pasos, modales focalizados, pantallas vacías orientativas, estados de carga claros y mensajes útiles. El diseño debe respetar teclado, lectores de pantalla, WCAG 2.2 AA y preferencia de movimiento reducido.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. CRECISOL expone seis experiencias coherentes: landing pública del SaaS, registro/contratación de empresas, consola central SuperAdmin, panel del negocio, puesto de empleado y sitio/portal del consumidor. La identidad visual podrá variar por tenant, pero controles de autorización, componentes nucleares y contratos permanecen estandarizados.

FRONTEND	**Seis experiencias: landing SaaS, onboarding, SuperAdmin, propietario, empleado, cliente; shells, rutas lazy y diseño editorial; iconos semánticos y estados UI.**
BACKEND	Contratos BFF/API por experiencia con proyección por permisos; una operación por caso de uso; no entregar PII por convenience.
BASE DE DATOS	Modelos de preferencias de experiencia y layouts, evitando duplicar usuarios/tenants; datos de demo segregados.

Prueba de aceptación y riesgo

Positivas / negativas. Navegación teclado/móvil, permisos de acceso negativos por rol y experiencia, no fuga de datos entre shells.

Control crítico. Seis experiencias no equivalen a seis aplicaciones pesadas o seis microservicios.

Requisitos de origen que deben rastrearse

VISITANTE DEL SAAS	**Explora propuesta comercial, paquetes, testimonios moderados, demostraciones y contratación.**
SUPERADMIN DE PLATAFORMA	Gestiona empresas, planes, contratos, pagos SaaS, dominios, métricas, costos, integraciones, seguridad, soporte y catálogo de módulos.
PROPIETARIO DE NEGOCIO	Administra sus sucursales, branding, empleados, permisos, menú, catálogo, reservas, finanzas y experiencias públicas.

Fuente completa: 1 tabla(s), 7 filas, 11 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C02-01 Extraer / C02-02 Diseñar / C02-03 Codificar / C02-04 Probar / C02-05 Auditar A / C02-06 Auditar B / C02-07 Auditar C / C02-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

El SuperAdmin enumera todas las experiencias mediante catálogo sin PII; cada shell tenant oculta rutas ajenas por backend.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 02, rutas y componentes; 11 parrafos sustantivos y 1 tablas originales (7 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Implementar panel de seguimiento por rol con vistas distintas cliente/empleado/propietario. Un cliente solo ve sus expedientes y eventos publicados; no existe selector de empresas. Verificar UC-036..UC-040.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 03 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

03. Arquitectura técnica limpia y dependencias

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Se propone un monolito modular sobre ASP.NET Core con contratos explícitos y vertical slices para casos de uso. El frontend Angular se organiza en aplicaciones públicas y privadas que comparten un design system. MySQL almacena datos transaccionales normalizados; workers ejecutan actividades asíncronas; la infraestructura externa se integra por adaptadores reemplazables.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Domain	Entidades, invariantes, operaciones de negocio y eventos de dominio; sin HTTP, ORM ni SDK de infraestructura.	Pruebas unitarias puras; dependencia hacia el núcleo.
Application	Casos de uso, reglas de orquestación, validación, autorización, transacciones y puertos de salida.	Un caso de uso por responsabilidad; sin controladores masivos.
Infrastructure	MySQL/EF, email, pagos, QR, archivos, social APIs, mapas, eventos y clock vía interfaces.	Providers sustituibles, manejo de fallos, timeouts, reintentos seguros.
API	Entradas HTTP tipadas, contratos/versiones, validación de petición, auth, límites y errores consistentes.	Controladores delgados; no cálculos sensibles ni SQL directo.
Workers	Outbox, notificaciones, publicaciones programadas, recordatorios, vencimientos y conciliaciones.	Idempotencia, reintentos acotados, dead-letter y observabilidad.
Frontend público	Páginas SEO, comercio, servicios, reservas, ubicación, login contextual y portal de cliente.	SSR/híbrido evaluado según hosting; carga diferida de galerías y módulos.
Frontend privado	Shell SuperAdmin, negocio, empleado y editor; menús por permisos, gráficos y modales uniformes.	Seguridad efectiva en servidor; guards solo mejoran la experiencia.
Shared contracts	DTO versionados, eventos y cliente API generados desde OpenAPI.	Sin referencias circulares; revisiones de compatibilidad en CI.

3.1. Árbol recomendado del repositorio

```
apps/
  public-web/              # Sitio de plataforma y sitios por negocio
  admin-web/               # SuperAdmin, negocio y personal
backend/
  src/Api/                 # Entradas HTTP y composition root
  src/BuildingBlocks/      # TenantContext, Auth, Outbox, Clock
  src/Modules/Identity/
  src/Modules/Tenants/
  src/Modules/Billing/
  src/Modules/Catalog/
  src/Modules/Orders/
  src/Modules/Scheduling/
  src/Modules/Memberships/
```

```
  src/Modules/Media/
  src/Modules/Social/
  src/Modules/Analytics/
  src/Infrastructure/
  tests/Unit/Integration/Security/Contract/
infra/
  docker/compose.dev.yml
  docker/compose.prod.yml
  nginx/ or reverse-proxy/
docs/
  architecture/adr/
  security/threat-models/
  product/ux/
  operations/runbooks/
.github/workflows/
```

3.2. Dependencias y límites entre módulos

Identity emite identidad verificada; Tenants resuelve membresía, permisos y dominios; Catalog es dueño de artículos y servicios; Orders controla pedidos; Payments registra intención y conciliación; Scheduling controla agenda y recursos; Memberships calcula derechos; Media almacena metadatos; Analytics consume eventos o vistas autorizadas. Los módulos no modifican tablas ajenas directamente: utilizan contratos internos o procesos de aplicación.

3.3. Decisiones abiertas

Las versiones exactas de Angular/Node/.NET, el proveedor EF Core MySQL, el reverse proxy, la estrategia SSR, Cloudflare R2 y las características del VPS se validarán antes de crear el repositorio. La arquitectura evita acoplar el dominio a una marca o producto de infraestructura.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Se propone un monolito modular sobre ASP.NET Core con contratos explícitos y vertical slices para casos de uso. El frontend Angular se organiza en aplicaciones públicas y privadas que comparten un design system. MySQL almacena datos transaccionales normalizados; workers ejecutan actividades asíncronas; la infraestructura externa se integra por adaptadores reemplazables.

FRONTEND	**Workspaces Angular standalone, shared UI Kit, lib de configuración, routing lazy, Signals; presupuestos de bundle.**
BACKEND	Monolito modular con Domain/Application/Infrastructure/API/Workers, vertical slices pequeños, puertos/adaptadores, OpenAPI y contrato de errores.
BASE DE DATOS	Límites de ownership del esquema por módulo; claves/cambios transaccionales, scripts aislados y migraciones auditables.

Prueba de aceptación y riesgo

Positivas / negativas. Pruebas de dependencias sin ciclos, límites de capa, compilación independiente, smoke local y benchmark inicial.

Control crítico. No confundir servicios pequeños con microservicios de red ni introducir duplicación Node + .NET.

Requisitos de origen que deben rastrearse

DOMAIN	Entidades, invariantes, operaciones de negocio y eventos de dominio; sin HTTP, ORM ni SDK de infraestructura.
APPLICATION	Casos de uso, reglas de orquestación, validación, autorización, transacciones y puertos de salida.
INFRASTRUCTURE	MySQL/EF, email, pagos, QR, archivos, social APIs, mapas, eventos y clock vía interfaces.

Fuente completa: 1 tabla(s), 9 filas, 7 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C03-01 Extraer / C03-02 Diseñar / C03-03 Codificar / C03-04 Probar / C03-05 Auditar A / C03-06 Auditar B / C03-07 Auditar C / C03-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Escaneo de dependencias: ningun caso de uso construye URL de DB, salta TenantContext ni consulta módulo sin puerto.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 03, rutas y componentes; 7 parrafos sustantivos y 1 tablas originales (9 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Definir módulo Cases separado de Orders, Scheduling y Billing; contratos internos con outbox, casos de uso pequeños y modelo de eventos versionado; prohibido controller/service monolítico. Verificar UC-029..UC-034.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 04 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

04. Multitenancy, dominios y aprovisionamiento

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

PRECEDENCIA NORMATIVA 07-11-2026: cualquier texto anterior que permitiera seleccionar empresa durante el inicio de sesión queda sustituido. El acceso tenant se resuelve automáticamente, sin selector, exclusivamente desde identidad y contexto verificados; si es ambiguo, se rechaza y se solicita la URL oficial del negocio. Véase G.6 y AUTO-001..012.

Identidad canónica de la plataforma: CRECISOL. El dominio comercial elegido es crecisol.com, sujeto a validación de titularidad. Los negocios acceden por rutas y dominios propios verificados, conservan su identidad de marca y no obtienen privilegios por el dominio, la referencia a SOLQARYN ni un identificador público.

El sistema tendrá una sola identidad de plataforma y fronteras explícitas para cada negocio. Un usuario puede pertenecer a varios tenants, pero las operaciones siempre se ejecutan dentro de un TenantContext autorizado, con sucursal y privilegios efectivos. La resolución del host solo determina el sitio visitado; nunca concede acceso a datos privados.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Modalidad A - ruta	El negocio publica mediante una ruta bajo el dominio SaaS.	Slug único, redirección canónica, reserva de nombres sensibles y validación de tenant.
Modalidad B - subdominio	El negocio utiliza subdominio propio de la plataforma.	Provisionamiento DNS y certificado, lista de hosts permitidos.
Modalidad C - dominio propio	El negocio utiliza dominio adquirido y controlado por él.	Verificación de propiedad DNS, HTTPS, ciclo de renovación y desaprovisionamiento.
Alta de empresa	Crear tenant, dueño, plan, contrato, dominio provisional y defaults de forma atómica o saga compensable.	No publicar tenant parcialmente creado; auditoría y reintento idempotente.
Login contextual	Inferir negocio por host y membresías del usuario; si pertenece a varios, selector autorizado.	No pedir código de empresa; nunca confiar en tenant_id aportado por navegador.
Tenancy de datos	Filtrar datos y relaciones por tenant y alcance de sucursal en backend y persistencia.	FK compuestas con tenant cuando aplique; claves únicas por tenant.
Tenancy de eventos	Todos los eventos llevan tenant verificado, productor autorizado y destinatario controlado.	No usar tenant del mensaje como prueba de autorización; consumo con contexto revalidado.
Tenancy de caché/archivos	Partition key por tenant, usuario, versión de permiso, recurso y visibilidad.	Pruebas de contaminación de caché, CDN, colas y carpetas.
Offboarding	Suspender sin borrar; exportar conforme contrato y retirar dominios/secrets de forma controlada.	Retención, datos legales, cancelaciones, notificaciones y destrucción verificable.

4.1. Protección MySQL

MySQL requiere un diseño explícito de aislamiento por tenant en aplicación, persistencia y permisos de conexión. Implementaremos filtrado obligatorio en casos de uso, protección por repositorios tenant-aware, FK compuestas, claves únicas y políticas de acceso a tablas con privilegios mínimos. Toda ruta unscoped será

explícita, reservada a operaciones globales con autorización especial y auditoría. Un tenant_id aleatorio no es una autorización.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Identidad canónica de la plataforma: CRECISOL. El dominio comercial elegido es crecisol.com, sujeto a validación de titularidad. Los negocios acceden por rutas y dominios propios verificados, conservan su identidad de marca y no obtienen privilegios por el dominio, la referencia a SOLQARYN ni un identificador público.

FRONTEND	**Resolución visual por ruta/subdominio/dominio propio verificado; selector de contexto autorizado; alta guiada y estado tenant.**
BACKEND	TenantContext obligatorio en aplicación; host no autoriza; provisioning compensable, permisos por tenant/sucursal, offboarding.
BASE DE DATOS	Tenants, branches, domains, memberships; índices únicos y FK compuestas por tenant; pruebas negativas intertenant.

Prueba de aceptación y riesgo

Positivas / negativas. Alterar host, id, slug, cache, evento o archivo nunca concede acceso; registro parcial se compensa; tenant A no ve B.

Control crítico. Fuga entre empresas mediante URLs, caché, consultas sin scope o workers.

Requisitos de origen que deben rastrearse

MODALIDAD A - RUTA	**El negocio publica mediante una ruta bajo el dominio SaaS.**
MODALIDAD B - SUBDOMINIO	El negocio utiliza subdominio propio de la plataforma.
MODALIDAD C - DOMINIO PROPIO	El negocio utiliza dominio adquirido y controlado por él.

Fuente completa: 1 tabla(s), 10 filas, 4 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C04-01 Extraer / C04-02 Diseñar / C04-03 Codificar / C04-04 Probar / C04-05 Auditar A / C04-06 Auditar B / C04-07 Auditar C / C04-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

SHARED A/B y DEDICATED C: login sin selector, CRUD, dominios, sesiones, provisionamiento, migración y offboarding cruzados quedan aislados.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 04, rutas y componentes; 4 parrafos sustantivos y 1 tablas originales (10 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Caso, nota, adjunto, aprobación, timeline, websocket y worker siempre tenant-scoped en SHARED y DEDICATED. No consultar DB por URL/ID; deny-by-default y FK compuestas. UC-019..UC-028/UC-034..035.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 05 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

05. Identidad, autenticación y recuperación segura

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

PRECEDENCIA NORMATIVA 07-11-2026: cualquier texto anterior que permitiera seleccionar empresa durante el inicio de sesión queda sustituido. El acceso tenant se resuelve automáticamente, sin selector, exclusivamente desde identidad y contexto verificados; si es ambiguo, se rechaza y se solicita la URL oficial del negocio. Véase G.6 y AUTO-001..012.

El módulo de seguridad será un producto transversal con experiencia simple y protección profesional. Prioriza passkeys/WebAuthn y MFA para administradores, facilita recuperación segura por correo y códigos de respaldo, registra dispositivos y sesiones y aplica autenticación adicional a cambios sensibles. Las preguntas de seguridad no serán mecanismo de recuperación autorizado: las respuestas suelen ser adivinables o públicas y OWASP/NIST no las consideran una opción robusta.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Registro e invitaciones	Alta contextual por negocio, correo verificado, invitación única y aceptación de términos vigentes.	Tokens de un solo uso, expiración, rate limit y registro sin enumeración de usuarios.
Contraseñas	Política de longitud adecuada, gestor compatible, bloqueo de claves comprometidas y hash resistente (Argon2id preferente).	Nunca guardar texto plano; secretos externos al repositorio; protección de credenciales en tránsito.
Passkeys WebAuthn	Inicio de sesión sin contraseña mediante autenticadores vinculados al dominio legítimo.	Relying Party ID, challenge, origen y firma validados por servidor; registro/revocación auditados.
MFA para administradores	TOTP o passkey de segundo factor; se requiere MFA para SuperAdmin y administradores con operaciones sensibles.	Step-up para cambio de permisos, facturación, exportaciones y cambio de métodos de recuperación.
Recuperación por correo	Formulario neutro, token de alta entropía con hash y vigencia corta, uso único y comunicación al correo registrado.	No revelar existencia de la cuenta, no iniciar sesión automáticamente, invalidar tokens/sesiones tras restablecer.
Códigos de respaldo	Códigos de recuperación generados al enrolar MFA; visualizados una vez y guardados por el usuario.	Cada código sirve una sola vez, almacenado como hash y revocable.
Recuperación de MFA	Uso de passkey alternativa o códigos preemitidos; soporte asistido con identidad verificada y ventana de enfriamiento según riesgo.	No permitir que correo recientemente modificado sea única evidencia; registro e informe de incidente.
QR para inicio o vinculación	QR como forma de iniciar emparejamiento entre dispositivo autenticado y navegador, o para acceso físico autorizado.	Challenge de corta duración, confirmación explícita, no contiene contraseña ni concede sesión sin prueba criptográfica.
Preguntas de seguridad	No incluir como factor de acceso o recuperación; pueden documentarse solo como antipatrón a evitar.	Prueba: una respuesta adivinada nunca permite restablecer credenciales.
Sesiones y dispositivos	Inventario de sesiones activas, revocación propia/global, límites de inactividad y absolutos por riesgo.	Cookies Secure, HttpOnly, SameSite apropiado, protección CSRF y rotación de tokens.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Prevención de abuso	Rate limit por cuenta/IP/tenant/ruta, detección de credenciales expuestas y anomalías.	Evitar bloqueos que habiliten denegación de servicio; alertas sin revelar datos.
SSO futuro	OIDC/SAML para clientes que lo requieran, con proveedores confiables y claims mínimos.	Validación de issuer, audience, expiración, nonce y asignación de roles independiente del IdP.

5.1. Secuencia segura: restablecer contraseña

01. Solicitar recuperación desde una pantalla que nunca confirma públicamente si existe el correo.
02. Aplicar protección de abuso y emitir un token aleatorio, único, breve, guardado como hash y ligado al propósito.
03. Enviar enlace por canal previamente verificado; impedir filtración de token en Referer o logs.
04. Validar token en backend sin reutilización; requerir nueva clave conforme política y registrar evidencia de cambio.
05. Revocar sesiones, refresh tokens y enlaces de recuperación anteriores; notificar al titular y facilitar denuncia si no fue él.
06. Para SuperAdmin y cuentas de alto riesgo, exigir un segundo factor o procedimiento de recuperación reforzado si se perdió el MFA.

5.2. Secuencia segura: pérdida total de acceso

01. Verificar que los métodos automáticos seguros (passkey secundaria, código de respaldo y correo previamente verificado) no estén disponibles.
02. Iniciar un caso de soporte aislado del negocio y recopilar pruebas de identidad proporcionales al riesgo, minimizando datos personales.
03. Aplicar revisión de doble control a privilegios globales o activos financieros; no conceder acceso en base a preguntas personales.
04. Imponer retraso de seguridad cuando corresponda y notificar a canales preexistentes; permitir reporte de uso fraudulento.
05. Reenrolar autenticadores, revocar todos los anteriores y emitir registro de auditoría y notificación de cierre.

5.3. Diseño de interacción

Formularios cortos, iconos con ayuda accesible, progreso claro y errores neutrales. El usuario puede elegir entre sus métodos de autenticación disponibles. No se obligará a escanear un QR desde el mismo dispositivo que muestra el código. Los mecanismos de recuperación se explican antes de que el usuario pierda acceso.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. El módulo de seguridad será un producto transversal con experiencia simple y protección profesional. Prioriza passkeys/WebAuthn y MFA para administradores, facilita recuperación segura por correo y códigos de respaldo, registra dispositivos y sesiones y aplica autenticación adicional a cambios sensibles. Las preguntas de seguridad no serán mecanismo de recuperación autorizado: las respuestas suelen ser adivinables o públicas y OWASP/NIST no las consideran una opción robusta.

FRONTEND	**Login contextual, passkeys, MFA, recuperación, sesiones/dispositivos y errores neutrales; controles accesibles.**
BACKEND	Identity module, secretos con hashes resistentes, tokens un solo uso, cookies seguras, rate limiting, sesión revocable.

FRONTEND	**Login contextual, passkeys, MFA, recuperación, sesiones/dispositivos y errores neutrales; controles accesibles.**
BASE DE DATOS	Users, authenticators, passkey credentials, recovery tokens hashed, sessions y security events.

Prueba de aceptación y riesgo

Positivas / negativas. Cuenta inexistente no revelada, token caducado inutilizable, MFA admin, recuperación sin preguntas personales, revocación total.

Control crítico. Suplantación, enumeración, bypass MFA y persistencia de sesión revocada.

Requisitos de origen que deben rastrearse

REGISTRO E INVITACIONES	**Alta contextual por negocio, correo verificado, invitación única y aceptación de términos vigentes.**
CONTRASEÑAS	Política de longitud adecuada, gestor compatible, bloqueo de claves comprometidas y hash resistente (Argon2id preferente).
PASSKEYS WEBAUTHN	Inicio de sesión sin contraseña mediante autenticadores vinculados al dominio legítimo.

Fuente completa: 1 tabla(s), 13 filas, 16 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C05-01 Extraer / C05-02 Diseñar / C05-03 Codificar / C05-04 Probar / C05-05 Auditar A / C05-06 Auditar B / C05-07 Auditar C / C05-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Usuarios con misma identidad en dos negocios no heredan permisos; login automático sin selector, tokens y restablecimientos tenant-contextuales.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 05, rutas y componentes; 16 parrafos sustantivos y 1 tablas originales (13 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Autorización de cliente requiere principal autenticado y pertenencia contextual; MFA/step-up según riesgo, sesión verificable y revocación. UC-024, UC-028.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 06 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

06. Autorización fina, protección de datos y privacidad

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

El acceso se determina mediante usuario autenticado + tenant verificado + pertenencia vigente + rol/permiso de acción + sucursal + propiedad/estado del recurso + condición comercial. Los privilegios se evalúan en backend para cada operación, incluidos archivos, reportes, exportaciones y canales en tiempo real.

Capacidad / regla	Comportamiento funcional	Control / aceptación
RBAC + ABAC	Roles configurables combinados con atributos del usuario, recurso, sucursal, estado y contexto.	Denegación por defecto; permisos explícitos y versionados.
Permisos por acción	Ver, crear, actualizar, aprobar, exportar, reembolsar, borrar lógicamente, publicar y administrar según módulo.	Matrices de acceso con casos negativos de cada operación.
Separación financiera	Empleados no ven ingresos o márgenes por defecto; caja y reembolsos requieren permisos específicos.	Pruebas por rol y por campos de respuesta.
Campo por campo	PII, historial de salud y datos de cliente limitados por necesidad.	Serialización selectiva; minimización de datos; ocultación de campos.
Soporte SaaS	Ver metadatos operativos globales; acceder al tenant de forma temporal solo tras autorización, causa y auditoría.	Acceso break-glass con expiración y revisión independiente cuando aplique.
Permisos delegados	Propietario asigna permisos dentro de su techo; no eleva privilegios de la plataforma.	Evitar escaladas mediante APIs, importaciones y copias de roles.
Revocación inmediata	Baja de empleado, cierre de sesión o suspensión de contrato cambia permisos efectivos.	Invalidar tokens/revalidad sesiones, cachés y grupos realtime.
Retención y derechos	Portal de privacidad y flujo de acceso, rectificación, eliminación y oposición cuando proceda.	Base legal y retención documentadas, respuesta verificable y borrado seguro.
Logs y métricas	Auditoría estructurada con actor/tenant/acción/recurso/contexto; sin secretos ni contenido sensible en claro.	Integridad del registro, retención y segregación de accesos.

6.1. Ejemplo de autorización

Una recepcionista de sucursal A solicita descargar un informe de ingresos de sucursal B. El backend verifica su pertenencia al tenant y su permiso de finanzas, detecta que no tiene el alcance solicitado y rechaza la descarga, independientemente de que el frontend haya ocultado el botón. El intento se audita sin registrar datos confidenciales.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. El acceso se determina mediante usuario autenticado + tenant verificado + pertenencia vigente + rol/permiso de acción + sucursal + propiedad/estado del recurso + condición comercial. Los privilegios se evalúan en backend para cada operación, incluidos archivos, reportes, exportaciones y canales en tiempo real.

FRONTEND	**Editor de roles y permisos por acción con alcance claro; filas/campos visibles solo si autorizados; privacidad.**
BACKEND	Policies RBAC+ABAC por tenant/sucursal/recurso/acción; exportaciones y media protegidos; soporte break-glass auditado.
BASE DE DATOS	Role, permission, role-grant, resource scope, consent, access log y retention policies.

Prueba de aceptación y riesgo

Positivas / negativas. Empleado no descarga finanzas, A no consulta B, restricción por sucursal, revocación efectiva en UI/API/cache.

Control crítico. ID aleatorio no sustituye autorización, ni ocultar botones asegura endpoints.

Requisitos de origen que deben rastrearse

RBAC + ABAC	**Roles configurables combinados con atributos del usuario, recurso, sucursal, estado y contexto.**
PERMISOS POR ACCIÓN	Ver, crear, actualizar, aprobar, exportar, reembolsar, borrar lógicamente, publicar y administrar según módulo.
SEPARACIÓN FINANCIERA	Empleados no ven ingresos o márgenes por defecto; caja y reembolsos requieren permisos específicos.

Fuente completa: 1 tabla(s), 10 filas, 3 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C06-01 Extraer / C06-02 Diseñar / C06-03 Codificar / C06-04 Probar / C06-05 Auditar A / C06-06 Auditar B / C06-07 Auditar C / C06-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Matriz RBAC/ABAC por acción, sucursal, campo y tenant; SuperAdmin requiere soporte grant para PII real.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 06, rutas y componentes; 3 parrafos sustantivos y 1 tablas originales (10 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Permisos específicos por acción y relación con caso: cases.read, note.create, diagnosis.publish, quote.request, approval.decide, delivery.confirm, case.close y dispute.manage. El cliente no controla estado ni precio. UC-021..028.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 07 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

07. Ciberseguridad integral y respuesta a incidentes

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La gestión de seguridad se construirá como proceso continuo: políticas, amenazas, pruebas, monitoreo, prevención, detección, recuperación y revisión. Objetivo: seguridad alta verificable y riesgo residual conocido; prometer “cero errores” absolutos sería técnicamente irresponsable.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Inventario y amenazas	Mapear activos, actores, límites de confianza, datos sensibles, STRIDE/abuso y riesgos de cada módulo.	Registro por amenaza con propietario, mitigación y prueba negativa.
Secure SDLC	Análisis de dependencias, secretos, contenedores, SAST, validación de contratos, pruebas E2E y revisión de cambios.	P0/P1 de seguridad bloquean publicación hasta resolver o decisión formal excepcional muy restringida.
Autenticación y autorización	OWASP ASVS como marco, sesiones sólidas, control de permisos por objeto y operación.	Pruebas de BOLA/IDOR, SSRF, inyección, XSS, CSRF, control de tenant y MFA.
Entrada de datos	Validación server-side, tamaño/rango/tipo, consultas parametrizadas y encoding contextual.	Fuzzing limitado y pruebas con cargas maliciosas.
Infraestructura	Firewall de puertos mínimos, SSH por llave, MFA en panel VPS, Docker sin privilegios y actualizaciones.	Hardening verificable; MySQL no expuesto; secretos fuera de imágenes.
Resiliencia	Backups cifrados externos, restauración, monitorización, rate limiting y protección del origen.	Pruebas DR periódicas con RPO/RTO medidos.
Fraude comercial	Idempotencia en pagos/QR, límites de reembolso, comprobación de recibos y doble aprobación cuando proceda.	Pruebas de repetición, manipulación de total y condición de carrera.
Fuga multimedia	URLs firmadas según visibilidad, verificación de propietario y expiración, antivirus/validación.	Prueba de ID de archivo ajeno y filtración por CDN.
Gestión de incidentes	Clasificar impacto, contener, preservar evidencia, comunicar, recuperar y aprender.	Runbooks por credenciales, fuga de tenant, ransomware, corrupción DB y caída VPS.
Privacidad desde diseño	Minimización de datos, consentimiento específico, cifrado y borrado verificable.	Evaluación de impacto cuando se procesen datos sensibles o de menores.

7.1. Taxonomía de riesgos P0

Amenaza	Mitigación obligatoria	Prueba de aceptación
BOLA / IDOR cross-tenant	Scope por tenant + recurso + sucursal en servidor y datos.	Cambiar identificadores y hosts nunca expone recursos de otro tenant.
Toma de SuperAdmin	Passkey/MFA, sesiones cortas, step-up y alerta por acceso anómalo.	No se puede operar una cuenta global sin factores y contexto vigentes.

Amenaza	Mitigación obligatoria	Prueba de aceptación
QR reproducido	Token firmado/aleatorio de un uso, expiración, revocación y antifraude.	Un canje repetido o cambiado entre empresas es rechazado.
Manipulación de pagos	Precio/tax calculados en servidor, webhook autenticado e idempotencia.	Alterar importe del navegador no altera monto liquidado.
Escape desde CMS	Sin HTML/script arbitrario, sanitización, CSP y componentes allowlist.	Un bloque configurado no ejecuta script ni consulta datos privados.
Exposición de DB	Red privada, mínima superficie, credenciales dedicadas y backups cifrados.	Escaneo externo no encuentra MySQL publicado.
Acceso indebido a medios	ACL en servicio de archivos, almacenamiento privado y firma temporal.	Copiar URL privada entre cuentas no entrega archivo si caducó o no está autorizado.
Resiliencia VPS	Backups fuera del host, política DR y pruebas de restauración.	Restauración documentada y aprobada sobre entorno aislado.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La gestión de seguridad se construirá como proceso continuo: políticas, amenazas, pruebas, monitoreo, prevención, detección, recuperación y revisión. Objetivo: seguridad alta verificable y riesgo residual conocido; prometer “cero errores” absolutos sería técnicamente irresponsable.

FRONTEND	**Patrones UX de seguridad: estados de sesión, errores sin filtraciones, confirmaciones críticas y acceso seguro a archivos.**
BACKEND	Threat model, validaciones server-side, rate limit, CSP, antifraude, scanner de cargas, alertas y manejo uniforme de errores.
BASE DE DATOS	Auditoría inmutable lógica, eventos de seguridad, retenciones y pruebas de restauración con datos sintéticos.

Prueba de aceptación y riesgo

Positivas / negativas. XSS, CSRF, BOLA/IDOR, SSRF, inyección, replay, manipulación de importes, seguridad de archivos; fallos bloquean cierre.

Control crítico. Prometer cero vulnerabilidades absolutas; usar checklist sin ejecutar pruebas.

Requisitos de origen que deben rastrearse

INVENTARIO Y AMENAZAS	**Mapear activos, actores, límites de confianza, datos sensibles, STRIDE/abuso y riesgos de cada módulo.**
SECURE SDLC	Análisis de dependencias, secretos, contenedores, SAST, validación de contratos, pruebas E2E y revisión de cambios.
AUTENTICACIÓN Y AUTORIZACIÓN	OWASP ASVS como marco, sesiones sólidas, control de permisos por objeto y operación.

Fuente completa: 2 tabla(s), 20 filas, 2 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C07-01 Extraer / C07-02 Diseñar / C07-03 Codificar / C07-04 Probar / C07-05 Auditar A / C07-06 Auditar B / C07-07 Auditar C / C07-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Fuzz de BOLA/IDOR/SSRF/XSS, tampering de audit, CORS, caches y BYODB; P0/P1 bloquean cierre.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 07, rutas y componentes; 2 parrafos sustantivos y 2 tablas originales (20 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Añadir threat model de approval tampering, replay, IDOR en timeline, XSS de comentarios, malware de anexos, CSRF, SSRF y carreras de cierre. P0 bloquea cierre. UC-019..035.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 08 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

08. Gobierno central, planes, contratos y facturación SaaS

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

El SuperAdmin gestiona el ciclo de vida completo de las empresas contratantes. La plataforma vende suscripciones con planes versionados, cuotas y add-ons; los negocios tienen su propio circuito de ventas, distinto y aislado de la facturación SaaS.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Alta/autoservicio	Registro de empresa, invitación a propietario, información fiscal necesaria, aceptación de condiciones y selección de plan.	Provisionamiento seguro y consentimiento registrado con versión documental.
Planes y precios	Plantillas comercializables con módulos, límites, tarifas, trial y facturación mensual/anual.	Versionar cambios; no reescribir derechos de contratos anteriores.
Modalidades A/B/C	Dominio por ruta, subdominio o dominio propio, con extras y reglas por plan.	Activación según contrato; certificación DNS y HTTPS.
Contratos digitales	Acuerdo de suscripción y anexos, documento adjunto o firma electrónica; evidencia y autoridad de firmante.	Hash, autor, fecha, versión, retención y acceso documental acotado.
Renovación y prorrateo	Renovar periodo, cambiar paquete, suspender, reactivar o cancelar; manejar saldo/prorrateo si la política lo permite.	Maquinaria de estados, pago confirmado e idempotencia.
Métodos de pago SaaS	Checkout externo alojado, tarjeta tokenizada por PSP, transferencia y efectivo cuando operativamente permitido.	PCI y antifraude; no guardar PAN/CVV; conciliación de cobros.
Gestión de empresas	Ver estado comercial, consumo, módulos, sucursales, incidentes, almacenamiento y salud operativa.	Dashboard sin lectura indiscriminada de datos privados de consumidores.
Catálogo de módulos	SuperAdmin activa capacidades por plan/tenant; negocio habilita funciones adquiridas.	Feature flags y entitlements evaluados por servidor.
Soporte y demo	Centro de demostración con tenants ficticios, reproducción de escenarios y comparación por roles.	Datos sintéticos, aislados, sin acceso real de cliente.
Avisos y vencimientos	Notificaciones por email/panel de expiración, fallos de cobro, renovación y contingencias.	Cola asíncrona, Outbox, idempotencia, trazabilidad.
Término y portabilidad	Exportación del negocio, suspensión proporcional y eliminación al término de retención.	Procedimiento legal y técnico verificable, sin pérdida involuntaria.

8.1. Estados de contrato

Borrador → pendiente de firma/aceptación → pendiente de pago (si aplica) → activo → renovación pendiente o periodo de gracia → suspendido o vencido → cancelado → cerrado/archivado. Solo transiciones válidas y autorizadas; cada periodo y modificación se conserva como versión independiente.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. El SuperAdmin gestiona el ciclo de vida completo de las empresas contratantes. La plataforma vende suscripciones con planes versionados, cuotas y add-ons; los negocios tienen su propio circuito de ventas, distinto y aislado de la facturación SaaS.

FRONTEND	SuperAdmin: empresas, planes, entitlements, contratos, cobros SaaS y soporte; experiencia administrable.
BACKEND	Casos de uso de planes versionados y suscripciones SaaS; separación estricta de ventas tenant; control de acceso.
BASE DE DATOS	Plan, PlanVersion, SaaSSubscription, BillingPeriod, SaaSInvoice, SaaSPayment y ContractAcceptance.

Prueba de aceptación y riesgo

Positivas / negativas. Cambiar plan no altera contratos anteriores; pago SaaS no se confunde con ventas de tenant; suspensión auditable.

Control crítico. Mezclar dinero de plataforma con dinero de negocios; cuotas hardcoded.

Requisitos de origen que deben rastrearse

ALTA/AUTOSERVICIO	Registro de empresa, invitación a propietario, información fiscal necesaria, aceptación de condiciones y selección de plan.
PLANES Y PRECIOS	Plantillas comercializables con módulos, límites, tarifas, trial y facturación mensual/anual.
MODALIDADES A/B/C	Dominio por ruta, subdominio o dominio propio, con extras y reglas por plan.

Fuente completa: 1 tabla(s), 12 filas, 3 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C08-01 Extraer / C08-02 Diseñar / C08-03 Codificar / C08-04 Probar / C08-05 Auditar A / C08-06 Auditar B / C08-07 Auditar C / C08-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Plans/contracts globales inaccesibles a tenant; cada empresa recibe solo sus entitlements y sus pagos separados.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 08, rutas y componentes; 3 parrafos sustantivos y 1 tablas originales (12 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Consola SaaS observa métricas de tiempos y salud de expedientes por tenant; solo entra a casos privados mediante grant excepcional, motivo, expiración, MFA y bitácora de plataforma. UC-027.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 09 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

09. Constructor visual universal y design system

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La personalización integral es diferencial de producto. Cada negocio podrá editar contenido, estructura, colores, branding, navegación y dashboard mediante un editor de bloques. Existirá un editor separado para la landing comercial de nuestro SaaS y otro para cada tenant. La presentación pública nunca ejecuta código proporcionado por clientes.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Branding	Logo, favicon, eslogan, portadas, tipografías, paleta, diseño de botones y estilo de imágenes.	Tokens tipados, validaciones de contraste y límites de formato de archivos.
Bloques y secciones	Mover, duplicar, ocultar, mostrar, reordenar y configurar hero, servicios, catálogo, reseñas, precios, mapa y pie de página.	JSON validado por esquema, whitelist de componentes y permisos de publicación.
Responsive por breakpoint	Diseño y orden adaptables a móvil, tablet y escritorio con vista previa.	Restricciones de accesibilidad, tamaños mínimos y no overflow.
Dashboard ajustable	Tarjetas KPI y vistas del empleado/propietario según módulos y permisos.	No crear consultas ad hoc, no exponer métricas no autorizadas.
Fuentes personalizadas	Catálogo permitido y carga de fuentes bajo dominio autorizado o URL controlada con verificación de licencia y MIME.	Sin CSS/JS arbitrario; sanitización, control CORS/CSP y fallbacks.
Biblioteca de iconos	Una semántica de acciones estándar; icono principal, tooltip y etiqueta aria para controles.	Accesible con teclado, lectura de pantalla y táctil; iconos no reemplazan mensajes obligatorios.
Modales y drawers	Detalles, formularios, confirmaciones, carrito, login y servicios; presentación editorial.	Focus trap, cerrar con Escape cuando proceda, no modales para flujos extremadamente largos.
Vista previa y borradores	Separar draft, preview, publicado y archivado; versionar temas y páginas.	Vista previa privada con token temporal; no afecta sitio público antes de publicar.
Publicación automática	Publicar cambios validados sin redeploy de código; invalidar caché/versiones y registrar auditoría.	Rollback a publicación anterior, revisión y límites de contenido.
Templates por sector	Presets para barbería, retail, gimnasio, restaurantes, spa, talleres y otros; todos editables.	No acoplar la plantilla a módulos ajenos a la necesidad comercial.

9.1. Contrato de componente editable

Cada bloque define: kind, key estable, versión de schema, zona de visualización, propiedades tipadas, controles de visibilidad, fuentes de datos permitidas, roles habilitados, compatibilidad responsive y pruebas de accesibilidad. El usuario edita propiedades; nunca la implementación del componente.

9.2. Política visual y editorial

La interfaz pública se concibe como revista: fotografía prominente, composición flexible, textos breves y narrativas por rubro. El panel administrativo usa tarjetas pequeñas y densidad configurable. Los botones de

acción se representan prioritariamente con iconos, pero su propósito se comunica en tooltip, etiquetas accesibles y confirmaciones claras.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La personalización integral es diferencial de producto. Cada negocio podrá editar contenido, estructura, colores, branding, navegación y dashboard mediante un editor de bloques. Existirá un editor separado para la landing comercial de nuestro SaaS y otro para cada tenant. La presentación pública nunca ejecuta código proporcionado por clientes.

FRONTEND	**Editor visual con bloques tipados, drag-drop accesible, preview antes/después de guardar, draft/published, rollback, temas y modos responsive.**
BACKEND	Schemas allowlist, revisión de publicaciones, validación de contrastes, bloqueo de JS/HTML/CSS arbitrario; CMS por ámbito.
BASE DE DATOS	Themes, ThemeVersions, SitePages, PageVersions, Blocks, PublishedSnapshots y AuditEntries.

Prueba de aceptación y riesgo

Positivas / negativas. Un bloque malicioso no ejecuta script; publicación tenant A no aparece en B; rollback conserva histórico.

Control crítico. Editor visual convertido en motor de ejecución arbitraria o contenido publicado sin preview.

Requisitos de origen que deben rastrearse

BRANDING	**Logo, favicon, eslogan, portadas, tipografías, paleta, diseño de botones y estilo de imágenes.**
BLOQUES Y SECCIONES	Mover, duplicar, ocultar, mostrar, reordenar y configurar hero, servicios, catálogo, reseñas, precios, mapa y pie de página.
RESPONSIVE POR BREAKPOINT	Diseño y orden adaptables a móvil, tablet y escritorio con vista previa.

Fuente completa: 1 tabla(s), 11 filas, 5 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C09-01 Extraer / C09-02 Diseñar / C09-03 Codificar / C09-04 Probar / C09-05 Auditar A / C09-06 Auditar B / C09-07 Auditar C / C09-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Cambio de tema, bloque, SEO, footer o icono A no altera B ni plataforma; preview privado y rollback.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 09, rutas y componentes; 5 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Design system único para timeline, etapas, decisión por renglones, comentarios, vistas previas y modales. Estados editables no alteran reglas de transición. UC-036..040.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 10 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

10. Catálogo universal y taxonomías administrables

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Un negocio podrá vender mercancía, servicios, experiencias, paquetes o membresías. Las entidades se normalizan para evitar una tabla universal con cientos de columnas vacías. Un motor de atributos por categoría permite especializar sin programar cada rubro.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Taxonomías por tenant	Categorías jerárquicas y subcategorías para artículos, servicios, promociones, anuncios y secciones.	CRUD administrable con restricciones de integridad, unicidad y borrado lógico.
Productos y variantes	SKU, código de barras, talla, color, peso, capacidad, marca, compatibilidad, precio, costos y existencias.	Variante identificable; no duplicar combinaciones; reservas de stock transaccionales.
Servicios	Duración, personal/equipo requerido, precio fijo/desde/cotización, materiales y recursos.	Validación de agenda y capacidad antes de confirmar.
Membresías	Planes con vigencia, entitlements, visitas, cobros recurrentes, periodos de gracia y upgrades.	Derechos solo vigentes; cambio de plan versionado.
Paquetes y combos	Agrupar productos, servicios o sesiones con condiciones y precios.	Desglose de impuestos, inventario y descuentos controlados.
Impuestos y precios	Tarifas por listas, fechas, sucursal, método de venta, descuentos y reglas tributarias.	Precio final calculado por servidor, no por navegador.
Atributos dinámicos	Esquema de categorías: tipo, unidad, opciones, mínimo/máximo, visibilidad y obligatoriedad.	Datos tipados, validación fuerte, consulta eficiente.
Contenido enriquecido	Varias imágenes, videos, descripciones, beneficios, restricciones y etiquetas.	Licencias, revisión de contenido, protección de multimedia.
Publicación	Estado visible/oculto/programado por canal público, catálogo y red social.	Auditoría, permisos y coherencia de inventario.
Importación y exportación	Carga validada por lote desde archivos tabulares y exportación filtrada.	Vista previa, mapeo de campos, límites, antivirus y rollback.
Catálogos del sistema	Métodos de pago, estados permitidos, categorías, unidades, barrios y motivos, configurables cuando sean datos de negocio.	Estados de seguridad, protocolos y códigos de error no son libremente editables.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Un negocio podrá vender mercancía, servicios, experiencias, paquetes o membresías. Las entidades se normalizan para evitar una tabla universal con cientos de columnas vacías. Un motor de atributos por categoría permite especializar sin programar cada rubro.

FRONTEND	**Administración de productos, servicios, variantes, taxonomías, campos dinámicos tipados y cargas con preview.**
BACKEND	Casos de uso pequeños para catálogo, precios, estado de publicación, importaciones y exportaciones autorizadas.
BASE DE DATOS	CatalogItem, Product, Variant, Service, Category, AttributeDefinition, AttributeValue, PriceList.

Prueba de aceptación y riesgo

Positivas / negativas. Variante única por SKU/talla/color, validación de campos, precio server-side, importación con rollback.

Control crítico. Tabla única sobrecargada, datos EAV sin tipado ni índices, precios confiados al navegador.

Requisitos de origen que deben rastrearse

TAXONOMÍAS POR TENANT	**Categorías jerárquicas y subcategorías para artículos, servicios, promociones, anuncios y secciones.**
PRODUCTOS Y VARIANTES	SKU, código de barras, talla, color, peso, capacidad, marca, compatibilidad, precio, costos y existencias.
SERVICIOS	Duración, personal/equipo requerido, precio fijo/desde/cotización, materiales y recursos.

Fuente completa: 1 tabla(s), 12 filas, 1 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C10-01 Extraer / C10-02 Diseñar / C10-03 Codificar / C10-04 Probar / C10-05 Auditar A / C10-06 Auditar B / C10-07 Auditar C / C10-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Taxonomias y variantes por tenant; busqueda y filtros no enumeran catálogo privado B.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 10, rutas y componentes; 1 parrafos sustantivos y 1 tablas originales (12 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CAPÍTULO 11 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

11. Inventario, compras y operaciones minoristas

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

El inventario es un servicio compartido para tiendas, ferreterías, joyerías, cafeterías, car wash con insumos y gimnasios con merchandising. Debe funcionar por sucursal y depósito, con control de movimientos, conteos, unidades, proveedores y reservas sin obligar a implementar logística empresarial compleja.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Inventario por ubicación	Sucursal, almacén, zona y existencia por variante con stock disponible, reservado y no vendible.	Todo movimiento posee motivo, actor, fecha, tenant y origen.
Movimientos y kardex ligero	Entradas, salidas, ajustes, traspasos, devoluciones, mermas y apertura de inventario.	Ledger inmutable lógico; saldo proyectado consistente y transaccional.
Recepción y compras	Proveedor, orden de compra simple, recepción parcial, costo, documentos y reclamaciones.	Roles separados para aprobar compra, recibir y corregir discrepancias.
Proveedores	Contactos, condiciones, productos abastecidos, historial comercial y comprobantes.	Información aislada por tenant; no compartir cuentas entre negocios.
Reposición	Mínimos, máximo, sugerencias por rotación y alertas para productos agotados.	Alertas sin generar compras automáticas no aprobadas.
Lotes y fechas	Caducidad, lote, peso, volumen y trazabilidad para alimentos, cosméticos y productos pertinentes.	Bloqueo de lote vencido, FIFO/FEFO cuando se configure.
Series y garantías	Números de serie para electrónica, joyería y reparación, con historial de propietarios y servicios.	Unicidad y control de cambio/devolución.
Transferencias	Mover existencias entre sucursales con envío, recepción y ajuste por diferencia.	Estado doble de transferencia, no doble deducción.
Conteos cíclicos	Inventario físico, diferencias, evidencias, aprobación y ajuste posterior.	Prohibir cambiar saldos sin movimiento auditable.
Concurrencia	Ventas simultáneas reservan o descuentan solo stock existente, respetando política de backorder si se permite.	InnoDB, bloqueos, retrys selectivos, idempotencia y pruebas de carrera.
Retail volumétrico	Variantes talla/color, paquetes, unidades de medida y código de barras para supermercados/tiendas.	Medidas normalizadas; peso/cantidades con precisión decimal.

11.1. Escenarios especializados

Tenis / ropa — Una talla-color distinta tiene su propia variante, SKU, precio, existencia y reservas; el catálogo principal agrupa las variantes.

Joyería — Una pieza serializada puede contener material, peso, certificado, garantía, historial de reparación y condiciones de venta.

Supermercado — Lotes y caducidad, pesables y cajeros concurrentes obligan a transacciones consistentes, reglas fiscales y rendimiento comprobado antes de operar.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. El inventario es un servicio compartido para tiendas, ferreterías, joyerías, cafeterías, car wash con insumos y gimnasios con merchandising. Debe funcionar por sucursal y depósito, con control de movimientos, conteos, unidades, proveedores y reservas sin obligar a implementar logística empresarial compleja.

FRONTEND	**Kardex ligero, inventario por sede, compras/recepción, transferencias, conteos y estados visibles.**
BACKEND	Use cases para reservas de stock, entradas, salidas, transferencias y recepciones transaccionales.
BASE DE DATOS	StockLocation, Balance, Movement, Reservation, Supplier, PurchaseOrder y Receipt con FK tenant.

Prueba de aceptación y riesgo

Positivas / negativas. Venta concurrente de última unidad no genera negativos; movimientos de transferencia conservan historia.

Control crítico. Actualizaciones directas de saldo sin ledger; carreras entre cajas.

Requisitos de origen que deben rastrearse

INVENTARIO POR UBICACIÓN	**Sucursal, almacén, zona y existencia por variante con stock disponible, reservado y no vendible.**
MOVIMIENTOS Y KARDEX LIGERO	Entradas, salidas, ajustes, traspasos, devoluciones, mermas y apertura de inventario.
RECEPCIÓN Y COMPRAS	Proveedor, orden de compra simple, recepción parcial, costo, documentos y reclamaciones.

Fuente completa: 1 tabla(s), 12 filas, 5 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C11-01 Extraer / C11-02 Diseñar / C11-03 Codificar / C11-04 Probar / C11-05 Auditar A / C11-06 Auditar B / C11-07 Auditar C / C11-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Stock/transfers/ledgers entre sucursales y tenants; FK compuesta evita reserva de articulo ajeno.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 11, rutas y componentes; 5 parrafos sustantivos y 1 tablas originales (12 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Inventario y compras consumen líneas concretas autorizadas. Una aprobación parcial no reserva ni descuenta conceptos rechazados; cambios de repuesto vuelven a pedir aprobación. UC-005/009/033.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 12 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

12. Pedidos, cotizaciones, caja y cobros del negocio

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Todo pedido tendrá estado, importes calculados en backend, partidas, impuestos/descuentos aplicados, pagos, entregas, documentos y auditoría. Las cotizaciones podrán convertirse en pedidos sin perder sus versiones. El dinero de clientes finales debe corresponder al negocio receptor, no mezclarse con las suscripciones que cobra nuestro SaaS.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Carrito / checkout	Catálogo público o POS; cantidades y promociones validadas por backend.	El total y moneda no se aceptan del navegador como autoridad.
Cotizaciones	Solicitud, líneas versionadas, vigencia, aceptación, anticipo, conversión y acceso del cliente.	Aprobación vinculada a versión exacta; cambios posteriores no alteran aceptaciones anteriores.
Caja y POS	Apertura, arqueo, movimientos, cobros, cierres, diferencias y caja por usuario/sucursal.	Permisos de supervisor para corregir o anular; auditar todo ajuste.
Efectivo	Recibido, cambio y comprobante; conciliación con caja.	Sin marcar “pagado” antes de recibir; registro de monto real.
Transferencia	Datos bancarios propios del negocio, referencia, carga de comprobante y conciliación.	Comprobante no equivale a pago verificado; estados pendiente/conciliado/rechazado.
Tarjeta presencial POS	Pago en datáfono del negocio, referencia/estado y conciliación manual o integrada.	No procesar ni almacenar tarjeta en el SaaS.
Pago online	Checkout alojado en PSP afiliado, intención de pago, webhook firmado, reembolso y conciliación.	PSP sandbox por defecto; idempotencia, comparación estricta de importe y comerciante.
Contra entrega	Pendiente de cobro hasta entrega y confirmación por personal autorizado.	No reconocer ingreso conciliado antes de evidencia.
Pedidos y despachos	Pendiente, confirmado, preparando, listo, entregado, cancelado o devuelto según flujo.	Transiciones explícitas; eventos Outbox; visibilidad del cliente por operación.
Devoluciones / cambios	RMA o solicitud, verificación de reglas, stock devuelto, reembolso parcial o total, garantía.	Separar rol de venta del de devolución elevada.
Garantías	Plazos, comprobantes, seriales, reclamo, evaluación, resolución y notificación.	Documentos vinculados a operación y tenant.
Exportación	PDF/Excel/CSV con filtros, formato correcto y registro de descarga.	Protección por fila/campo y tenant; descarga temporal.
Fiscalidad	Comprobantes y campos fiscales ajustados al comercio, pendientes de validación hondureña por rubro.	No afirmar certificación fiscal antes de pruebas legales y proveedor.

12.1. Máquina de estados de pagos

CREATED → REQUIRES_ACTION/PENDING → AUTHORIZED (si aplica) → CAPTURED/SETTLED → PARTIALLY_REFUNDED/REFUNDED; CANCELLED o FAILED como salidas. La confirmación proviene de un proveedor autenticado o de una conciliación autorizada según método. Doble webhook, replay o refresh del usuario no crea un segundo cobro.

12.2. Comisiones y bonificaciones

Las comisiones de empleados serán una capacidad optativa: reglas por servicio/venta, fechas, devoluciones y jerarquías. Deben ser explicables, disputables, auditables y no reemplazan nómina ni liquidación laboral sin evaluación de normativa aplicable.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Todo pedido tendrá estado, importes calculados en backend, partidas, impuestos/descuentos aplicados, pagos, entregas, documentos y auditoría. Las cotizaciones podrán convertirse en pedidos sin perder sus versiones. El dinero de clientes finales debe corresponder al negocio receptor, no mezclarse con las suscripciones que cobra nuestro SaaS.

FRONTEND	Carrito, cotizaciones versionadas, POS, caja, devoluciones, pagos y previsualización de comprobantes.
BACKEND	Orders/Payments separados del SaaS, price engine de servidor, checkout y webhook idempotente, reembolsos.
BASE DE DATOS	QuoteVersion, SalesOrder, Lines, CashSession, PaymentIntent, Settlement, Refund y WarrantyCase.

Prueba de aceptación y riesgo

Positivas / negativas. Manipular monto UI no cambia cargo; webhooks duplicados no cobran dos veces; devolución consistente.

Control crítico. Cobrar sin confirmación PSP, almacenar PAN/CVV, mezclar pago plataforma/tenant.

Requisitos de origen que deben rastrearse

CARRITO / CHECKOUT	Catálogo público o POS; cantidades y promociones validadas por backend.
COTIZACIONES	Solicitud, líneas versionadas, vigencia, aceptación, anticipo, conversión y acceso del cliente.
CAJA Y POS	Apertura, arqueo, movimientos, cobros, cierres, diferencias y caja por usuario/sucursal.

Fuente completa: 1 tabla(s), 14 filas, 5 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C12-01 Extraer / C12-02 Diseñar / C12-03 Codificar / C12-04 Probar / C12-05 Auditar A / C12-06 Auditar B / C12-07 Auditar C / C12-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Pedidos y facturas exhiben issuer correcto; caja/cliente B no consultables por A; idempotencia en cada tenant.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 12, rutas y componentes; 5 parrafos sustantivos y 1 tablas originales (14 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Implementar núcleo transversal de expedientes sobre órdenes; estados recibido/en proceso/entregado/cancelado/cerrado, historial de observaciones y checklists de cierre. Cierre no implica recepción. UC-001..018.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 13 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

13. Reservas, horarios, personal y recursos

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La agenda tiene en cuenta la apertura del negocio, horarios especiales y festivos, turnos, vacaciones, capacidades, profesionales, espacios y equipos. No habrá un simple calendario que permita confirmar citas imposibles.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Horarios semanales	Múltiples turnos al día; horario nocturno que cruza medianoche; zonas horarias configuradas.	Cálculo de apertura efectivo y próxima apertura.
Festivos y excepciones	Calendario legal de referencia + decisión del negocio: cerrado, horario parcial o abierto.	Precedencia determinista de excepciones y edición con auditoría.
Recursos reservables	Empleado, silla, cabina, mesa, cancha, bahía, consultorio o equipo.	Disponibilidad concurrente, mantenimiento y bloqueos.
Profesional preferido	Cliente elige persona o “cualquiera disponible”, según política y servicio.	No mostrar datos privados de ausencias; respetar capacidad.
Agenda del empleado	Turnos, descansos, vacaciones, incapacidades y tareas asignadas.	Empleado ve solo detalles habilitados; supervisor opera según alcance.
Disponibilidad en tiempo real	Slots elegibles calculados con duración, buffer, recursos y ocupación.	Bloqueo transaccional en confirmación; revalidar antes de cobrar anticipo.
Reservas y tickets QR	Citas y turnos con token de verificación, check-in, no-show y reprogramación.	QR de uso controlado, revocación, caducidad y validación online.
Cambios excepcionales	Un cierre anticipado detecta reservas afectadas, solicita decisión de administración y avisa.	No modificar silenciosamente reservas vigentes; conservar trazabilidad.
Depósitos y cancelaciones	Anticipos opcionales y condiciones editables conforme política contractual publicada.	Reembolso vinculado a operación y reglas legales.
Estado público	Abierto/cerrado, “cierra a las...”, horario festivo y disponibilidad de citas por servicio.	No confundir edificio abierto con personal o servicio disponible.

13.1. Algoritmo conceptual de reserva

01. Determinar tenant y sucursal, zona horaria y servicio seleccionado.
02. Aplicar calendario habitual + excepción/festivo + apertura y reglas especiales del servicio.
03. Intersectar turnos del personal autorizado con recursos y pausas ocupadas.
04. Ofrecer intervalos disponibles sin exponer motivos privados.
05. Al confirmar, crear reserva transaccional con bloqueo por recurso/slot y clave idempotente.
06. Guardar evento en Outbox; notificar y emitir comprobante QR o email al cliente.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La agenda tiene en cuenta la apertura del negocio, horarios especiales y festivos, turnos, vacaciones, capacidades, profesionales, espacios y equipos. No habrá un simple calendario que permita confirmar citas imposibles.

FRONTEND	**Agenda multirrecurso, franjas, turnos, feriados, estados abierto/cerrado, tickets y QR con previews.**
BACKEND	Scheduling use cases de disponibilidad, bloqueos transaccionales, reprogramación y notificaciones outbox.
BASE DE DATOS	BusinessHours, HolidayRule, Resource, StaffShift, Booking, AvailabilityHold, CheckInToken.

Prueba de aceptación y riesgo

Positivas / negativas. Doble reserva imposible, horas nocturnas correctas, QR ya usado falla, vacaciones ocultan detalles privados.

Control crítico. Disponibilidad calculada sin bloqueo al confirmar.

Requisitos de origen que deben rastrearse

HORARIOS SEMANALES	**Múltiples turnos al día; horario nocturno que cruza medianoche; zonas horarias configuradas.**
FESTIVOS Y EXCEPCIONES	Calendario legal de referencia + decisión del negocio: cerrado, horario parcial o abierto.
RECURSOS RESERVABLES	Empleado, silla, cabina, mesa, cancha, bahía, consultorio o equipo.

Fuente completa: 1 tabla(s), 11 filas, 8 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C13-01 Extraer / C13-02 Diseñar / C13-03 Codificar / C13-04 Probar / C13-05 Auditar A / C13-06 Auditar B / C13-07 Auditar C / C13-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Agenda/recursos y horarios propios; reservas concurrentes no asignan personal de otro tenant.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 13, rutas y componentes; 8 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Enlazar cita, reserva, llegada, check-in físico o QR, profesional, tiempo, atención, no-show, entrega y cierre con estado propio. La reserva no marca atención realizada. UC-001..003/014..018.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 14 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

14. Restaurantes, mesas QR y autoservicio

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Restaurantes y cafeterías dispondrán de menú público por categoría y horarios de cocina, QR propio por mesa, servicio en sitio, para llevar o entrega habilitada, pedidos que llegan al personal en tiempo real y opciones para dividir cuenta cuando correspondan.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Mesa identificada	Cada mesa tiene identificador no sensible y QR persistente que abre el menú asociado.	No permitir pedidos fraudulentos ilimitados desde QR fotografiado; sesiones y límites.
Sesión de mesa	Control de ocupación, apertura/cierre, ordenes y responsables.	QR fijo no equivale a permiso para marcar mesa ocupada ni cobrar.
Menú dinámico	Platos, ingredientes, opciones, extras, disponibilidad y precios vigentes.	Disponibilidad por cocina y franja horaria, validada al confirmar.
Pedido en tiempo real	Orden persistida transaccionalmente y notificación al personal o cocina.	No perder pedidos si SignalR o red falla; polling/recuperación.
Modificadores	Tamaños, adiciones, instrucciones de cocina y alergias informadas con advertencias.	Validaciones, límites y notas sin promesas sanitarias infundadas.
Atención humana	Mesero puede tomar orden, corregir con autorización o consultar estado.	Historial de cambios con actor, sin manipular ventas cerradas.
Modalidad de consumo	Local, para llevar, entrega si negocio la configura; tiempos estimados no garantizados.	No mezclar pedidos entre sucursales.
Capacidad y reserva	Mesas por capacidad, zona, accesibilidad y bloqueo de uso.	Preferencia de mesa/mesero sujeta a disponibilidad.
Facturación	Pago en caja, POS, online o según políticas; detalle y comprobantes.	Cobro solo contra orden validada, sin doble liquidación.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Restaurantes y cafeterías dispondrán de menú público por categoría y horarios de cocina, QR propio por mesa, servicio en sitio, para llevar o entrega habilitada, pedidos que llegan al personal en tiempo real y opciones para dividir cuenta cuando correspondan.

FRONTEND	**Menú por mesa, pedido móvil, carrito, cocina, estados de mesa y diseño restaurante editorial.**
BACKEND	Restaurant workflow con sesión de mesa, orden persistida, aviso en tiempo real no crítico y recuperación.
BASE DE DATOS	RestaurantTable, TableSession, KitchenOrder, OrderModifier referenciando SalesOrder del tenant.

Prueba de aceptación y riesgo

Positivas / negativas. QR fotografiado no cobra ni marca ocupación; websocket caído no pierde pedidos; mesa B no lee A.

Control crítico. QR estático confundido con permiso para cobros o cambios de mesa.

Requisitos de origen que deben rastrearse

MESA IDENTIFICADA	Cada mesa tiene identificador no sensible y QR persistente que abre el menú asociado.
SESIÓN DE MESA	Control de ocupación, apertura/cierre, ordenes y responsables.
MENÚ DINÁMICO	Platos, ingredientes, opciones, extras, disponibilidad y precios vigentes.

Fuente completa: 1 tabla(s), 10 filas, 1 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C14-01 Extraer / C14-02 Diseñar / C14-03 Codificar / C14-04 Probar / C14-05 Auditar A / C14-06 Auditar B / C14-07 Auditar C / C14-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

QR mesa A no pública orden/menu B ni redirige a cuenta B; vigencia e idempotencia por tenant.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 14, rutas y componentes; 1 parrafos sustantivos y 1 tablas originales (10 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

En cocina: pedido QR -> recibido -> preparando -> listo -> servido/entregado -> incidencia resuelta -> cierre; rol cocina/mesero/cliente y notificaciones. QR público no autoriza datos privados. UC-012..013.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 15 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

15. Membresías y acceso físico universal; perfil gimnasio

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La capacidad de membresías, suscripciones, pases y acceso físico mediante QR está disponible para TODAS las empresas, sin depender de su rubro. Cada tenant habilita modalidades, derechos, sedes, horarios, dispositivos y políticas propias. Gimnasios, clubes y academias son configuraciones sectoriales, no dueños exclusivos de esta funcionalidad.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Planes de gimnasio	Por visita, día, semana, mes, trimestre, año, familiar, corporativo, básico/intermedio/premium.	Tabla de derechos versionados, sin cambios retroactivos ocultos.
Socio y expediente	Datos generales mínimos, alta, contacto, contrato, consentimiento, foto opcional e historial de membresías.	Privacidad estricta; no recopilar diagnósticos o biometría sin base legal.
Derechos de acceso	Sede, horario, número de accesos, clases incluidas, entrenador, acompañantes o congelamientos.	Derecho evaluado online a la hora de ingresar.
Renovación	Pagos mensuales/anuales, autopago cuando autorizado, periodos de gracia y facturas.	Sin renovar por simple redirección; pago liquidado y evidencias.
Cambio de plan	Upgrade/downgrade, fecha efectiva, prorrateo, diferencia, límites y notificación.	Doble cobro imposible; reglas comerciales versionadas.
QR para acceso	Token dinámico temporal o presentación segura; lector autorizado en recepción/torniquete.	Antipassback opcional, replay detection, revocación y logs de entradas.
Modo emergencia	Conexión caída: política de acceso de contingencia segura y auditada.	No confiar indefinidamente en QR estáticos; procedimiento manual documentado.
Clases grupales	Capacidad, aforo, entrenador, lista de espera, check-in, penalización de no-show configurada.	Capacidad y derecho de plan verificados transaccionalmente.
Entrenamiento	Paquetes personalizados, calendarios, progreso comercial opcional y documentos autorizados.	Datos de salud separados y solo con evaluación legal/especializada.
Mantenimiento	Equipos, revisión preventiva, fuera de servicio, repuestos, incidentes y costos.	Equipo fuera de servicio bloquea reserva cuando corresponda.
Cobros adicionales	Inscripción, matrícula, mantenimiento, locker, clases premium, evaluación, toallas y accesorios.	Reglas claras y consentimiento contractual de cobros recurrentes.
Sucursales	Derechos intersede, horarios y capacidad según membresía.	No presentar entrada válida para sede no contratada.
Dashboard del gimnasio	Retención, membresías por vencer, accesos, ocupación por franja, clases, ingresos conciliados y bajas.	Gráficos por período y permisos granulares.

15.1. Estados de una membresía

PENDIENTE → ACTIVA → PAUSADA/CONGELADA cuando política lo permite → GRACIA → SUSPENDIDA/VENCIDA → RENOVADA/CANCELADA. Toda modificación agrega un nuevo evento y conserva el periodo original. No borrar historia para “reactivar” una membresía.

15.2. Antifraude en controles de acceso

El lector no acepta QR indefinidos como prueba completa de identidad: token efímero, verificación de titular cuando el riesgo lo exige, validación del plan, sede, horario, cupo y uso anterior. El personal podrá registrar excepciones justificadas sujetas a auditoría. No retener ni compartir imágenes del socio sin necesidad.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La capacidad de membresías, suscripciones, pases y acceso físico mediante QR está disponible para TODAS las empresas, sin depender de su rubro. Cada tenant habilita modalidades, derechos, sedes, horarios, dispositivos y políticas propias. Gimnasios, clubes y academias son configuraciones sectoriales, no dueños exclusivos de esta funcionalidad.

FRONTEND	**Portal membresías universal, gimnasio como plantilla, clase/cupo, acceso físico QR y historial transparente.**
BACKEND	Membership entitlement evaluator, renovación, congelamiento, canje/anti-replay con transacción.
BASE DE DATOS	MembershipPlan, MemberSubscription, Period, AccessCredential, Attempt, ClassSession, Booking.

Prueba de aceptación y riesgo

Positivas / negativas. Vencido no ingresa; doble acceso rechazado; cambio de plan no duplica cuota; cupos concurrentes seguros.

Control crítico. Acoplar membresías solo a gimnasios o usar QR ilimitado.

Requisitos de origen que deben rastrearse

PLANES DE GIMNASIO	**Por visita, día, semana, mes, trimestre, año, familiar, corporativo, básico/intermedio/premium.**
SOCIO Y EXPEDIENTE	Datos generales mínimos, alta, contacto, contrato, consentimiento, foto opcional e historial de membresías.
DERECHOS DE ACCESO	Sede, horario, número de accesos, clases incluidas, entrenador, acompañantes o congelamientos.

Fuente completa: 1 tabla(s), 14 filas, 5 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C15-01 Extraer / C15-02 Diseñar / C15-03 Codificar / C15-04 Probar / C15-05 Auditar A / C15-06 Auditar B / C15-07 Auditar C / C15-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Membresias, accesos y QR de A no canjeables en B; derechos sin compartir saldo ni historia.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 15, rutas y componentes; 5 parrafos sustantivos y 1 tablas originales (14 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Registrar asistencia y check-in idempotente con efecto en derecho de membresía; historia de sesiones, reclamos, reingresos según política; no compartir registros entre negocios.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 16 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

16. Extensiones por sector comercial

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Los rubros son plantillas de capacidades, no instalaciones aisladas. Cada plantilla establece módulos recomendados, campos y flujos, sin impedir que un negocio combine categorías. La entrada comercial debe indicar qué operaciones se pueden ofrecer y qué obligaciones adicionales requieren evaluación.

Sector / familia	Capacidades activables	Matices y controles
Barberías, peluquerías, salones	Citas, profesionales, servicios, catálogo, promociones, fotos, ventas, fidelidad.	Recursos de trabajo, preferencias de profesional, privacidad de clientes.
Spa y estética	Cabinas, tratamientos, paquetes, agenda, ventas de productos, bonos.	Consentimientos específicos para procedimientos; datos sensibles separados.
Odontología / consultorios	Especialistas, agenda, paquetes informativos, sede, cobros de citas.	Sin historia clínica integral por defecto; evaluación sanitaria y legal.
Restaurantes y cafeterías	Menú, QR mesa, cocina, pedidos, caja, reservas, delivery opcional.	Alérgenos, capacidad y horarios de cocina.
Estudios de tatuaje	Portafolio por artista, cotizaciones, reservas, depósitos, consentimiento.	Edad legal, bioseguridad y registros específicos sujetos a revisión.
Talleres auto/moto	Citas, técnicos, órdenes de reparación, repuestos, presupuestos, seguimiento.	Autorización de reparación, garantías y custodia de vehículos.
Car wash / detailing	Tipo vehículo, paquetes, bahías, turnos, insumos y fidelidad.	Duración y capacidades por tipo de automóvil.
Joyerías y relojerías	Variantes, serie, materiales, garantía, certificados, reparación y tasación si aplica.	Inventario de alto valor y controles antifraude.
Ropa, tenis y calzado	Tallas, colores, colecciones, cambios, ventas y disponibilidad omnicanal.	Reservas de stock, política de cambios y devoluciones.
Electrónica y gaming	Compatibilidad, series, garantías, mantenimiento, bundles y accesorios.	Trazabilidad y cumplimiento de garantías.
Juguetes	Categorías por edad, inventario, promociones, fichas de seguridad.	Advertencias normativas de productos; protección de menores.
Pulperías y minimarkets	POS, códigos barras, proveedores, stock, ofertas, arqueo.	Rendimiento de caja y precisión de inventario.
Supermercados / tiendas de departamento	Variantes, lotes, departamentos, pesables, múltiples cajas, sucursales.	Piloto de carga, impuestos y hardware POS antes de operar.
Gimnasios, yoga, pilates, clubes	Planes, QR acceso, clases, entrenadores, turnos, retención y cobros.	Afiliación, uso único, seguridad física y datos personales.
Academias y escuelas de baile	Inscripciones, paquetes de clases, cuotas, cupos, calendario.	Permisos de representantes y protección reforzada de menores.
Veterinarias y mascotas	Servicios, productos, agenda, mascota vinculada a responsable, recordatorios.	Datos del tutor/cliente; registros clínicos regulados fuera de base sin validación.
Ferreterías y repuestos	SKU, compatibilidad, proveedores, inventario, POS y garantías.	Unidades de medida y productos de riesgo especial.

Sector / familia	Capacidades activables	Matices y controles
Lavanderías / tintorerías	Tickets, prendas, estados, fecha entrega, daños, cobros.	Cadena de custodia de artículos.
Panaderías y reposterías	Pedidos a medida, fecha entrega, catálogo, inventario, pagos, promociones.	Caducidad, alergénicos y capacidad de producción.
Imprentas y servicios personalizados	Cotizaciones, adjuntos, aprobaciones de diseño, anticipo y seguimiento.	Propiedad intelectual y privacidad de archivos de clientes.
Ópticas	Citas, productos, tallas, accesorios, ventas y garantías.	Datos de graduación clínicos requieren tratamiento especial.
Pequeños hospedajes / eventos	Reservas, disponibilidad de espacios, anticipos, extras y políticas.	Identidad de huéspedes y obligaciones específicas sujetas a validación.
Otros rubros	Composición de módulos, atributos y diseños desde el catálogo universal.	Analizar legalidad, seguridad y flujo de negocio antes de activar funciones sensibles.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Los rubros son plantillas de capacidades, no instalaciones aisladas. Cada plantilla establece módulos recomendados, campos y flujos, sin impedir que un negocio combine categorías. La entrada comercial debe indicar qué operaciones se pueden ofrecer y qué obligaciones adicionales requieren evaluación.

FRONTEND	**Plantillas editoriales por sector configurables (barbería, retail, taller, gimnasio, restaurante y demás) sin bifurcar código.**
BACKEND	Feature entitlements universales, reglas sectoriales como validaciones tipadas y extensiones autorizadas.
BASE DE DATOS	SectorTemplate, ModuleCatalog, CapabilityGrant, AttributeSchema; ningún schema por tenant duplicado.

Prueba de aceptación y riesgo

Positivas / negativas. Un negocio mezcla productos/servicios/membresías; no se activa dato clínico sin autorización especial.

Control crítico. Clonar aplicaciones por rubro o prometer historia clínica integral.

Requisitos de origen que deben rastrearse

BARBERÍAS, PELUQUERÍAS, SALONES	**Citas, profesionales, servicios, catálogo, promociones, fotos, ventas, fidelidad.**
SPA Y ESTÉTICA	Cabinas, tratamientos, paquetes, agenda, ventas de productos, bonos.
ODONTOLOGÍA / CONSULTORIOS	Especialistas, agenda, paquetes informativos, sede, cobros de citas.

Fuente completa: 1 tabla(s), 24 filas, 1 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C16-01 Extraer / C16-02 Diseñar / C16-03 Codificar / C16-04 Probar / C16-05 Auditar A / C16-06 Auditar B / C16-07 Auditar C / C16-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Presets sectoriales usan mismo código, pero sus atributos, permisos y datos se almacenan por tenant.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 16, rutas y componentes; 1 parrafos sustantivos y 1 tablas originales (24 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

TODOS los 23 sectores de la tabla original usan el mismo módulo universal; preset de estado, campos, adjuntos, aprobaciones y checklist por configuración. Ninguno duplica código o abre módulos clínicos sin ley. UC-041.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 17 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

17. Historial del cliente y CRM en dos planos

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Existen dos historias y dos relaciones jurídicas distintas. A nivel SaaS, nuestros clientes son las empresas contratantes: sus planes, contratos, pagos, soporte y uso del sistema. A nivel tenant, los clientes son las personas o entidades atendidas por cada negocio: pedidos, citas, servicios, ventas y comunicaciones. Ninguna consulta ordinaria combina esos planos.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Historial comercial SaaS	Empresa contratante: registro, planes, pagos, cambios, dominios, soporte, tickets e incidencias.	Solo roles globales autorizados; acceso al soporte separado de datos finales.
Historial de cliente del negocio	Cliente final: compras, reservas, cotizaciones, consumos, devoluciones, recompensas y consentimientos.	Visible únicamente en tenant autorizado y por personal con permiso.
Cuentas del cliente final	Registro y login opcionales por negocio, vinculación segura a operaciones anteriores.	No unir identidades de tenants sin base legal y autorización.
Favoritos	Servicios, productos, empleados preferidos, sucursal y recordatorios cuando haya consentimiento.	No mostrar detalles de terceros; derecho de desactivación.
Cotizaciones persistentes	Cliente consulta versiones, acepta una vigente, descarga comprobantes y revisa historial.	Firma/aceptación vinculada a versión exacta y permiso.
Perfil configurable	Datos generales proporcionados, idioma, notificaciones, preferencias y privacidad.	Solicitar solo datos necesarios; trazabilidad de modificaciones.
Historial de membresías	Alta, renovación, cambio de plan, pausas, QR, visitas y facturas según rubro.	No mostrar a personal no autorizado datos de salud o motivos privados.
Atención y quejas	Casos de soporte, solicitudes, estado, resolución y evidencia para el cliente o administración.	Retención acorde a finalidad y derecho de revisión.
Unificación dentro de tenant	Deduplicar contactos si existe prueba segura de identidad y se respetan contratos.	No fusionar por nombre o teléfono únicamente.
Exportación del titular	Descarga y solicitudes de derechos del interesado con verificación adicional.	Excluir datos de terceros y secretos de plataforma.

17.1. Separación de identidad entre contextos

Una persona puede ser propietaria de un negocio, empleada de otro y consumidora de un tercero. Su identidad autenticada puede ser común, pero cada contexto tendrá membresía, permisos y finalidades independientes; los historiales permanecen separados por tenant, alcance y política de privacidad.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Existen dos historias y dos relaciones jurídicas distintas. A nivel SaaS, nuestros clientes son las empresas contratantes: sus planes, contratos, pagos, soporte y uso del sistema. A nivel tenant, los clientes son las personas o entidades atendidas por cada negocio: pedidos, citas, servicios, ventas y comunicaciones. Ninguna consulta ordinaria combina esos planos.

FRONTEND	Cuenta cliente final, historial, favoritos, consentimientos y cotizaciones con vista previa de descargas.
BACKEND	CRM tenant-aware y SaaSCRM físicamente/lógicamente separados; acceso de cliente solo a recursos propios.
BASE DE DATOS	BusinessCustomer, CustomerEvent, CustomerAccountLink, Favorite, Consent, SupportCase.

Prueba de aceptación y riesgo

Positivas / negativas. Cliente de tenant A no ve historia B; no fusionar personas solo por nombre o teléfono.

Control crítico. Cruce de planos jurídicos SaaS / consumidor.

Requisitos de origen que deben rastrearse

HISTORIAL COMERCIAL SAAS	Empresa contratante: registro, planes, pagos, cambios, dominios, soporte, tickets e incidencias.
HISTORIAL DE CLIENTE DEL NEGOCIO	Cliente final: compras, reservas, cotizaciones, consumos, devoluciones, recompensas y consentimientos.
CUENTAS DEL CLIENTE FINAL	Registro y login opcionales por negocio, vinculación segura a operaciones anteriores.

Fuente completa: 1 tabla(s), 11 filas, 3 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C17-01 Extraer / C17-02 Diseñar / C17-03 Codificar / C17-04 Probar / C17-05 Auditar A / C17-06 Auditar B / C17-07 Auditar C / C17-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Cliente con membresia A/B nunca ve historia combinada; soporte CRECISOL muestra PII solo con grant auditable.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 17, rutas y componentes; 3 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Portal de consumidor muestra expediente, línea de tiempo, decisiones, presupuestos versionados y evidencias propias; historial de cada tenant totalmente separado. UC-007..009/019..021.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 18 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

18. Fidelización, promociones, reseñas y atención

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

El motor promocional combina campañas, reglas de vigencia, visitas, puntos y recompensas; las reseñas y quejas constituyen flujos independientes para evitar manipulación de reputación. Una evaluación de empleado debe provenir de una atención verificable; los incidentes con clientes deberán basarse en hechos y permitir corrección.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Programas de visitas	Cada N visitas/compras genera beneficio sujeto a condiciones, reglas de puntos y vencimiento.	Eventos verificables; una visita no se acredita dos veces.
QR de fidelidad	Credencial reutilizable para identificar cuenta; QR/código de recompensa separado de un solo canje.	Antifraude, nonce, expiración, revocación y transacción única.
Wallet	Pases en Apple/Google Wallet solo si proveedor, región y afiliación lo permiten.	Pases firmados; registro de canje autoritativo en servidor.
Promociones	Descuentos, cupones, packs, fechas, límites por cliente, segmento y sucursal.	Recalcular precio en backend; explicar restricciones al consumidor.
Cliente califica empleado	Rúbrica de atención con experiencia verificable, comentarios, moderación y derecho de réplica.	Sin exponer identidad innecesaria, antifraude y revisión de sesgos.
Empleado registra incidente	Hechos operativos verificables: no-show, incumplimiento de reserva, daño documentado y resolución.	No calificación pública ni lista negra automática; acceso restringido y derecho de impugnación.
Reseñas del negocio	Opiniones verificadas, moderación transparente, señalización de contenido destacado.	No presentar selección editorial como muestra completa de satisfacción.
Quejas y reclamaciones	Caso, categoría, evidencia, responsable, plazo interno, escalamiento y resolución.	Protección de datos, auditoría y trazabilidad.
Reembolsos por incidencias	Reembolso o bonificación vinculado a un caso y pago real.	Doble control según monto; devolución no altera historia comercial.
Métricas de atención	Satisfacción y tiempos agregados, segmentados sin estigmatizar a empleados.	Tamaño mínimo de muestra y no usar calificaciones aisladas como juicio laboral automático.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. El motor promocional combina campañas, reglas de vigencia, visitas, puntos y recompensas; las reseñas y quejas constituyen flujos independientes para evitar manipulación de reputación.

Una evaluación de empleado debe provenir de una atención verificable; los incidentes con clientes deberán basarse en hechos y permitir corrección.

FRONTEND	**Editor de promociones, QR fidelidad, recompensas, reseñas moderables y quejas.**
BACKEND	Loyalty rules versionadas; redenciones idempotentes; workflow justo para incidentes y reseñas.
BASE DE DATOS	LoyaltyProgram, Rule, Account, Reward, Redemption, Review, Complaint.

Prueba de aceptación y riesgo

Positivas / negativas. Un QR de premio no se canjea dos veces; reseña requiere experiencia válida; sin blacklist automática.

Control crítico. Fraude de recompensas, manipulación de reputación y sanciones injustificadas.

Requisitos de origen que deben rastrearse

PROGRAMAS DE VISITAS	**Cada N visitas/compras genera beneficio sujeto a condiciones, reglas de puntos y vencimiento.**
QR DE FIDELIDAD	Credencial reutilizable para identificar cuenta; QR/código de recompensa separado de un solo canje.
WALLET	Pases en Apple/Google Wallet solo si proveedor, región y afiliación lo permiten.

Fuente completa: 1 tabla(s), 11 filas, 1 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C18-01 Extraer / C18-02 Diseñar / C18-03 Codificar / C18-04 Probar / C18-05 Auditar A / C18-06 Auditar B / C18-07 Auditar C / C18-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Lealtad, reseñas y cupones por tenant; intento de usar código/QR A en B denegado.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 18, rutas y componentes; 1 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Incidencias, quejas, cambios, garantías y devoluciones abren caso vinculado; no reescriben entrega o aprobación histórica. UC-015..018.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 19 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

19. Marketing, Social Hub y mensajería multicanal

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La plataforma tendrá un espacio social propio, y cada empresa su Social Hub aislado. Permitirá administrar campañas, creatividad, calendarios y respuestas donde las APIs autorizadas lo permitan. El sistema no promete acciones imposibles o no aprobadas por Meta, TikTok y otros proveedores.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Cuentas conectadas	Conexión OAuth/oficial por empresa y canal: WhatsApp Business, Facebook, Instagram, TikTok u otros.	Tokens cifrados, alcance mínimo, renovación/revocación y permisos granulares.
Calendario editorial	Borrador, revisión, aprobado, programado, enviado, publicado, fallido, cancelado.	Estado por red y publicación individual; no falso “publicado en todas”.
Inventario de contenido	Lista de productos y servicios con contenido publicado, pendiente o no publicado por canal.	Fuente única de catálogo y snapshots de campaña.
Campañas y anuncios	Banners internos, promociones, creatividades, enlaces medidos y anuncios pagados opcionales.	Ads externas requieren cuenta, políticas y APIs del proveedor; sandbox por defecto.
Respuestas automáticas	Saludo, horario, catálogo, preguntas frecuentes, derivación a humano y estados de conversación.	Consentimiento, plantillas oficiales, límites y listas de exclusión.
WhatsApp	Respetar ventana de 24 h y plantillas autorizadas según modalidad oficial vigente.	No enviar publicidad masiva sin opt-in; privacidad y registro de consentimientos.
Bandeja unificada	Conversaciones autorizadas, etiquetas, prioridad, asignación a empleado y estado.	Aislamiento y retención por canal, métricas sin leer mensajes ajenos.
Biblioteca creativa	Subida de banners, imágenes y videos con licencia y aprobación.	Protección de contenido, propiedad intelectual y cuotas de almacenamiento.
Análisis por campaña	Publicaciones, clics medidos, conversiones atribuibles, costos y resultados disponibles de APIs.	Distinguir métricas estimadas de reales, permisos y versiones.
Fallas de integración	Reintentos y estados claros cuando expiran tokens o cambian políticas de canales.	Outbox y cola segura; usuario ve fallos sin perder el borrador.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La plataforma tendrá un espacio social propio, y cada empresa su Social Hub aislado. Permitirá administrar campañas, creatividad, calendarios y respuestas donde las APIs autorizadas lo permitan. El sistema no promete acciones imposibles o no aprobadas por Meta, TikTok y otros proveedores.

FRONTEND	**Social Hub separado por empresa, calendario editorial, mensajería y vistas previas de publicaciones.**
BACKEND	Adaptadores OAuth por canal, programación Outbox, estados por red y consentimiento verificable.
BASE DE DATOS	SocialConnection, Campaign, Post, Publication, MessageThread, Template, OptIn.

Prueba de aceptación y riesgo

Positivas / negativas. Token social no sale a navegador, fallos por canal no simulan publicación, no spam sin opt-in.

Control crítico. APIs o permisos externos no garantizados y envíos masivos ilegales.

Requisitos de origen que deben rastrearse

CUENTAS CONECTADAS	**Conexión OAuth/oficial por empresa y canal: WhatsApp Business, Facebook, Instagram, TikTok u otros.**
CALENDARIO EDITORIAL	Borrador, revisión, aprobado, programado, enviado, publicado, fallido, cancelado.
INVENTARIO DE CONTENIDO	Lista de productos y servicios con contenido publicado, pendiente o no publicado por canal.

Fuente completa: 1 tabla(s), 11 filas, 1 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C19-01 Extraer / C19-02 Diseñar / C19-03 Codificar / C19-04 Probar / C19-05 Auditar A / C19-06 Auditar B / C19-07 Auditar C / C19-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Plantillas y colas social/media aisladas; tokens externos nunca expuestos a empresa vecina.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 19, rutas y componentes; 1 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Notificaciones al cliente y al personal por cambios, preguntas y aprobación; Outbox, deduplicación, revalidación y privacidad por destinatario. UC-010..011/026/032.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 20 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

20. Sitios públicos, mapas y contenido editorial

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La landing de CRECISOL utilizará el nombre oficial, “Tu negocio, a tu manera.” y el descriptor “Comercio · Servicios · Membresías · Crecimiento”. Su navegación comercial, planes, demos, políticas y contactos mostrarán únicamente servicios efectivamente habilitados. Las páginas de cada negocio conservarán su marca, no la marca global como protagonista.

CRECISOL tendrá su landing comercial principal editable por SuperAdmin; cada negocio tendrá sitio público editorial y portal personal. La localización será configurable por sucursal y el negocio decidirá qué información pública mostrar. El mapa se basará en tecnología libre y proveedor intercambiable.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Landing de la plataforma	Misión, visión, capacidades, paquetes, sectores, publicidad, reseñas, registro y contacto.	CMS con control editorial, vista previa, versionado y publicación.
Landing del negocio	Logo, eslogan, fotografías, oferta, precios, promociones, galería, equipo, experiencia y CTA.	Cada bloque publicable conforme a su propio plan y permisos.
Mapas gratuitos	MapLibre/OpenFreeMap como opción inicial si términos, disponibilidad y consumo lo permiten.	Atribución, fallback y límites razonables; no depender de geocodificación comunitaria intensiva.
Ubicaciones	Dirección, coordenadas, indicaciones, zona, referencias, teléfono y WhatsApp.	Sucursales y horarios propios; validación de coordenadas.
Estacionamiento	Privado, cercano, descripción de acceso, capacidad estimada e información accesible.	Cada campo visible/oculto desde editor; oculto no aparece en API pública.
Redes y contacto	Enlaces oficiales, correo, teléfono, mensajería, formulario y pie de página editable.	Enlaces seguros y políticas anti-spam.
Horarios públicos	Abierto/cerrado real, horario especial, próximas aperturas y disponibilidad por servicio.	Caché invalidada y zona horaria correcta.
SEO técnico	Metadata por tenant, sitemap, canonical, schema según negocio y páginas indexables.	Evitar indexar sitios privados o duplicaciones de dominios.
Portales	Cuenta cliente, historial, cotizaciones, reservas, privacidad y recompensas.	Acceso solo por identidad autorizada y contexto.
Carga eficiente	Imágenes responsive, lazy loading, cache HTTP y presupuestos de performance.	No romper CSP/HTTPS con widgets de terceros.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La landing de CRECISOL utilizará el nombre oficial, “Tu negocio, a tu manera.” y el descriptor “Comercio · Servicios · Membresías · Crecimiento”. Su navegación comercial, planes, demos, políticas y contactos mostrarán únicamente servicios efectivamente habilitados. Las páginas de cada negocio conservarán su marca, no la marca global como protagonista.

FRONTEND	**Landings plataforma/tenant, mapas, estacionamiento, SEO, horarios, accesibilidad, medios e información editorial.**
BACKEND	Read model público limitado por publicación, canonical/verificación dominio, mapas adapter con fallback.
BASE DE DATOS	SitePage, BranchLocation, BusinessHours, ParkingDetails, SEO metadata y PublishedSnapshot.

Prueba de aceptación y riesgo

Positivas / negativas. Ocultar parking lo elimina de API y render; SEO no indexa borradores; mapas con fallback.

Control crítico. Publicar datos ocultos, dominio ajeno o sobrecargar la landing.

Requisitos de origen que deben rastrearse

LANDING DE LA PLATAFORMA	**Misión, visión, capacidades, paquetes, sectores, publicidad, reseñas, registro y contacto.**
LANDING DEL NEGOCIO	Logo, eslogan, fotografías, oferta, precios, promociones, galería, equipo, experiencia y CTA.
MAPAS GRATUITOS	MapLibre/OpenFreeMap como opción inicial si términos, disponibilidad y consumo lo permiten.

Fuente completa: 1 tabla(s), 11 filas, 2 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C20-01 Extraer / C20-02 Diseñar / C20-03 Codificar / C20-04 Probar / C20-05 Auditar A / C20-06 Auditar B / C20-07 Auditar C / C20-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Dominios verificados, SEO y parking A no afectan B; cache SSR con tenant/host valido.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 20, rutas y componentes; 2 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

En web del negocio, el portal público no expone seguimiento privado. Acceso por identidad contextual y links expirables. SEO nunca indexa datos privados.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 21 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

21. Cloudflare R2: imágenes, videos, documentos y archivos

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La gestión multimedia utiliza una abstracción de storage: Cloudflare R2 es el almacén de objetos para imágenes, videos, documentos y archivos. Los recursos públicos se publican por rutas controladas; contratos, identificaciones y archivos privados permanecen en buckets privados con entrega autorizada y temporal. El tenant posee los metadatos en MySQL; el enlace del proveedor es un atributo técnico, no prueba de acceso.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Upload seguro	Cliente autorizado obtiene permiso temporal, carga y finaliza con validación server-side.	Extensiones/MIME reales, antivirus cuando proceda, cuotas, descompresión controlada.
Almacenamiento por tenant	Ruta lógica opaca por tenant y tipo; metadatos de propietario, tamaño, hash, clasificación y ciclo de vida.	La carpeta no es barrera de seguridad; permisos en backend y proveedor.
Publicación pública	Logo, portada, productos, catálogo, galerías y anuncios servidos por CDN.	Optimización de formato/resolución sin exponer archivos privados.
Documentos privados	Contratos, firmas, adjuntos de reclamo, expedientes y comprobantes sensibles.	Almacenamiento privado y descarga temporal autorizada, con auditoría.
Medios de clientes	Fotos de trabajos, cotizaciones, documentos de servicio con autorización específica.	Acceso por cliente, negocio, empleado asignado y finalidad.
Consumo de almacenamiento	Contar bytes por tenant, tipo y fuente; conciliar con registros del proveedor.	Distinguir bytes propios, cuota, delivery y facturación efectiva.
Retención	Ciclo activo → archivado → purga conforme política, contrato y obligación legal.	Borrado verificable del proveedor y cachés; legal holds separados.
Licencia de fuentes/medios	El negocio garantiza derechos de fotos, logos, videos y fuentes externas.	Avisos y mecanismos de reclamación; no usar archivos ajenos sin autorización.
Protección de videos	Controlar transcodificación, duración, tamaños, privacidad y costos.	Límites por plan y alertas de exceso; streaming seguro si es privado.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La gestión multimedia utiliza una abstracción de storage: Cloudflare R2 es el almacén de objetos para imágenes, videos, documentos y archivos. Los recursos públicos se publican por rutas controladas; contratos, identificaciones y archivos privados permanecen en buckets privados con entrega autorizada y temporal. El tenant posee los metadatos en MySQL; el enlace del proveedor es un atributo técnico, no prueba de acceso.

FRONTEND	Biblioteca multimedia y preview de imágenes, PDF, Office y vídeos según permiso.
BACKEND	Media service con cuarentena, firma temporal, análisis de contenido y límites de tamaño; R2 por adaptador.
BASE DE DATOS	MediaAsset, Versions, Metadata, AccessPolicy, Quota, MediaUsage.

Prueba de aceptación y riesgo

Positivas / negativas. Archivo tenant A rechazado desde B; documentos privados no van a CDN público.

Control crítico. Extensión falsa, procesamiento peligroso y URLs privadas permanentes.

Requisitos de origen que deben rastrearse

UPLOAD SEGURO	Cliente autorizado obtiene permiso temporal, carga y finaliza con validación server-side.
ALMACENAMIENTO POR TENANT	Ruta lógica opaca por tenant y tipo; metadatos de propietario, tamaño, hash, clasificación y ciclo de vida.
PUBLICACIÓN PÚBLICA	Logo, portada, productos, catálogo, galerías y anuncios servidos por CDN.

Fuente completa: 1 tabla(s), 10 filas, 1 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C21-01 Extraer / C21-02 Diseñar / C21-03 Codificar / C21-04 Probar / C21-05 Auditar A / C21-06 Auditar B / C21-07 Auditar C / C21-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

R2 objetos, miniaturas, preview y URL firmada asociados a tenant; enumeración por path o ID ajeno falla.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 21, rutas y componentes; 1 parrafos sustantivos y 1 tablas originales (10 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Adjuntar fotos, PDF y documentos con cuarentena, conversión/preview segura, ACL y URL de corta vida; no entregar evidencia de otro caso. UC-025/038..039.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 22 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

22. Finanzas ligeras, analítica y dashboards

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Se separan ingresos del SaaS de los ingresos comerciales de cada empresa. Las métricas tienen definiciones contables transparentes: vendido, cobrado, conciliado, devuelto y pendiente no son sinónimos. Los dashboards mostrarán gráficos filtrables y exportables, con granularidad consistente y control de permisos.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Panel global	Clientes SaaS activos, MRR/ARR estimado y reconocido según política, churn, renovación, pagos SaaS y costos.	Excluir ventas de tenants salvo métricas de salud agregadas autorizadas.
Panel del tenant	Ventas, ingresos conciliados, margen aproximado, métodos, devoluciones, clientes, servicios, empleados y existencias.	Permisos financieros por acción y campos; no disponible para todos los empleados.
Filtros temporales	Día, semana, mes, bimestre, trimestre, semestre, año y fechas personalizadas.	Zonas horarias y periodos de comparación definidos.
Gráficas dinámicas	Línea, barra, área, tabla de desglose, selección de series y drill-down controlado.	Datos server-side filtrados por tenant; sin consultas generadas desde texto sin validar.
Productividad por empleado	Atenciones, ventas atribuibles, pedidos y servicio; reconocer colaboración y devoluciones.	Solo métricas apropiadas, con explicaciones y sin sesgos por muestra reducida.
Finanzas básicas	Ingresos, egresos registrados, caja, cuentas por cobrar simples, reembolsos y gastos.	No sustituye contabilidad corporativa o declaraciones fiscales.
Alertas por anomalías	Caída en ventas, existencias bajas, pagos fallidos, clientes inactivos, ocupación anómala.	Umbrales editables y sin decisiones automáticas irreversibles.
Supervisión técnica VPS	CPU, RAM, disco, I/O, MySQL, latencias API, colas, errores, respaldos y tráfico por tenant.	Telemetría agregada; no exponer secretos, datos personales o payloads completos.
Costos/consumo por empresa	Media, storage, requests y procesamiento medidos; estimación de costo por tenant cuando sea atribuible.	Etiquetar estimación vs medición confirmada.
Exportaciones	PDF, Excel, CSV con permisos, límites, filtros y fechas visibles.	Registros de exportación; redacción de datos ajenos y enlaces temporales.

22.1. Definiciones de indicadores

KPI	Definición operacional	Regla de seguridad
Ventas brutas	Suma de líneas de pedidos completados antes de descuentos/devoluciones según política.	Excluir pedidos borrador y pruebas.
Ingreso conciliado	Importe de pagos capturados/cobrados y conciliados menos reembolsos aplicados, por periodo.	No contar transferencias solo notificadas.
Ticket promedio	Ingreso por ventas elegibles dividido por número de transacciones elegibles.	Filtrar correctamente devoluciones y ventas anuladas.

KPI	Definición operacional	Regla de seguridad
Conversión	Sesiones/visitas medibles que culminan en acción definida; métricas aproximadas indicadas.	Consentimiento y cookies según obligación aplicable.
Ocupación	Reservas confirmadas o check-ins frente a capacidad elegible por periodo.	No exponer identidad de clientes en cuadros públicos.
Retención gimnasio	Miembros con membresía vigente y renovaciones dentro de cohorte definida.	No utilizar registros médicos personales para segmentación comercial sin base legal.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Se separan ingresos del SaaS de los ingresos comerciales de cada empresa. Las métricas tienen definiciones contables transparentes: vendido, cobrado, conciliado, devuelto y pendiente no son sinónimos. Los dashboards mostrarán gráficos filtrables y exportables, con granularidad consistente y control de permisos.

FRONTEND	**Dashboards por rol con filtros, gráficas ligeras, exportaciones previsualizadas, KPIs consistentes.**
BACKEND	Analytics read models autorizados; separar ingreso vendido, cobrado y conciliado; agregados/paginación.
BASE DE DATOS	Read projections y métricas derivadas reconciliables; no escrituras directas desde dashboard.

Prueba de aceptación y riesgo

Positivas / negativas. Periodo diario/mensual consistente, finanzas invisibles para empleado, export autorizado por fila/campo.

Control crítico. Consultas N+1, gráficos pesados o KPIs ambiguos.

Requisitos de origen que deben rastrearse

PANEL GLOBAL	**Clientes SaaS activos, MRR/ARR estimado y reconocido según política, churn, renovación, pagos SaaS y costos.**
PANEL DEL TENANT	Ventas, ingresos conciliados, margen aproximado, métodos, devoluciones, clientes, servicios, empleados y existencias.
FILTROS TEMPORALES	Día, semana, mes, bimestre, trimestre, semestre, año y fechas personalizadas.

Fuente completa: 2 tabla(s), 18 filas, 2 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C22-01 Extraer / C22-02 Diseñar / C22-03 Codificar / C22-04 Probar / C22-05 Auditar A / C22-06 Auditar B / C22-07 Auditar C / C22-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Dashboards tenant, ingresos, margen y empleados no filtran agregados de B ni metricas globales sensibles.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 22, rutas y componentes; 2 parrafos sustantivos y 2 tablas originales (18 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Medir tiempo por estado, espera del cliente, retrasos, tasas de resolución y reclamaciones por empresa/sucursal/rol; agregados sin fuga cross-tenant.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 23 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

23. Legislación, políticas y consentimiento

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La marca comercial CRECISOL y la leyenda institucional “una plataforma de SOLQARYN” no sustituyen los datos de la persona jurídica prestadora, el responsable del tratamiento, el domicilio legal y los contratos correspondientes. Antes de publicar se verifica el registro/titularidad del dominio, las autorizaciones de uso de marca y la exactitud de datos fiscales y de contacto.

La plataforma tendrá políticas contractuales propias y cada negocio tendrá documentos legales separados, configurables con mínimos obligatorios y revisión jurídica. El producto permite gestión, publicación, aceptación y evidencia; no garantiza cumplimiento normativo por simplemente mostrar un texto de privacidad.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Términos SaaS	Contrato, planes, facturación, renovaciones, suspensión, cancelación, SLA cuando se ofrezca y responsabilidades.	Versiones firmadas/aceptadas y registro de vigencia.
Privacidad del SaaS	Finalidades, responsables/encargados, bases legales, cesiones, retención, derechos y contacto.	Control de minimización y medidas técnicas verificables.
Políticas del negocio	Privacidad, términos de venta/servicio, cancelación, devolución, garantía, promociones y cookies.	No publicar operaciones sin información mínima aplicable.
Consentimiento explícito	Marketing, comunicaciones comerciales y datos sensibles separados de aceptación contractual.	Opt-in trazable, retiro fácil y no utilizar casillas preseleccionadas cuando se requiera consentimiento.
Documentos de aceptación	Guardar versión, fecha/hora, usuario, método, propósito, contexto y evidencia proporcional.	Verificación de integridad; no depender solo de un checkbox.
Firma electrónica	Proveedor o mecanismo adecuado a nivel legal, evidencia de identidad, consentimiento y documento firmado.	Verificar asesoría legal y normas de firma de Honduras antes de contratos reales.
Derechos del titular	Solicitudes de acceso, rectificación, supresión, oposición y portabilidad según legislación aplicable.	Autenticar al solicitante y auditar; excluir datos de terceros.
Menores y salud	Bloquear procesamiento de datos sensibles de menores sin marco legal, permisos parentales y evaluación de impacto.	No publicar historial médico/biométrico por defecto.
Reclamaciones	Canal visible para quejas, disputas de compras, reseñas, decisiones de moderación y soporte.	Estados, plazos internos, registro y revisión imparcial.
Pagos e impuestos	Información de precios, impuestos, facturación y obligaciones del comercio.	Verificar condiciones del PSP y normativa fiscal por sector.
Transferencias internacionales	Trazar proveedores extranjeros para imágenes, email y pagos, y obligaciones contractuales.	DPA, controles de acceso y análisis jurídico.
Retención y eliminación	Política por clase de dato; legal hold; baja de tenant; backup y eliminación programada.	Conservar evidencia requerida sin exponerla indebidamente.

23.1. Paquete de documentos publicables

- Términos del SaaS y contrato digital de suscripción; política de privacidad y cookies propias; aviso de seguridad; condiciones de uso aceptable; DPA/encargo de tratamiento cuando proceda.
- Políticas de privacidad y venta de cada negocio; reservas, cancelación, devoluciones, garantías, promociones y mecanismos de queja.
- Texto específico para programas de fidelidad, recordatorios y mensajería; aceptación separada para publicidad por WhatsApp, email u otras redes.
- Condiciones de membresías y acceso físico aplicables a cualquier negocio, incluidas reglas especiales de gimnasios, clases, QR, pagos, renovaciones, congelamientos, menores y seguridad física.
- Historial de documentos firmado/aceptado, idioma, fecha, vigencia, evidencias y cambio de consentimiento.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La marca comercial CRECISOL y la leyenda institucional “una plataforma de SOLQARYN” no sustituyen los datos de la persona jurídica prestadora, el responsable del tratamiento, el domicilio legal y los contratos correspondientes. Antes de publicar se verifica el registro/titularidad del dominio, las autorizaciones de uso de marca y la exactitud de datos fiscales y de contacto.

FRONTEND	**Editores de términos, privacidad y consentimiento por plataforma/tenant con preview y publicación controlada.**
BACKEND	Contract/Consent use cases, control de versión, aceptación y derechos del titular.
BASE DE DATOS	LegalDocument, Version, AcceptanceEvidence, ConsentRecord, RetentionRule.

Prueba de aceptación y riesgo

Positivas / negativas. Cambios legales no sobrescriben consentimientos históricos; export privado sin PII ajena.

Control crítico. Publicar textos legales no revisados como cumplimiento automático.

Requisitos de origen que deben rastrearse

TÉRMINOS SAAS	**Contrato, planes, facturación, renovaciones, suspensión, cancelación, SLA cuando se ofrezca y responsabilidades.**
PRIVACIDAD DEL SAAS	Finalidades, responsables/encargados, bases legales, cesiones, retención, derechos y contacto.
POLÍTICAS DEL NEGOCIO	Privacidad, términos de venta/servicio, cancelación, devolución, garantía, promociones y cookies.

Fuente completa: 1 tabla(s), 13 filas, 8 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C23-01 Extraer / C23-02 Diseñar / C23-03 Codificar / C23-04 Probar / C23-05 Auditar A / C23-06 Auditar B / C23-07 Auditar C / C23-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Consentimientos, terminos y emisor legal versionados por tenant; GDPR/derechos de consumidor no mezclados.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 23, rutas y componentes; 8 parrafos sustantivos y 1 tablas originales (13 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Conservar evidencia de autorizaciones de presupuesto y términos específicos; no confundir clic con firma jurídica especial o consentimiento clínico; retención y privacidad.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 24 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

24. VPS Hostinger y Docker: front, API y MySQL privados

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Infraestructura objetivo: un VPS de Hostinger bajo administración propia y contenedores aislados por servicio. Los contenedores frontend, API, worker, MySQL y reverse proxy comparten host físico; en consecuencia, la tolerancia a caída del host dependerá de un plan explícito de recuperación y de respaldos externos.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Host y acceso	Linux soportado, SSH por llaves, deshabilitar autenticación de contraseña cuando corresponda, cuentas sin privilegios y MFA panel.	Hardening, inventario de accesos, parches y bitácora.
Docker Compose	Servicios separados con redes internas, salud, restart policies, límites de recursos y volúmenes.	Imágenes firmadas/versionadas; no usar latest sin control.
Proxy público	HTTPS automático, HSTS cuando aplique, redirecciones, límites HTTP y configuración de hosts.	Solo publicar 80/443, no MySQL ni administración del contenedor.
API y workers	Contenedores separados con puertos privados y secretos montados mediante mecanismo protegido.	Sin privilegios root ni acceso innecesario a socket Docker.
MySQL InnoDB	Volumen persistente, versión fijada, usuario de aplicación de mínimo privilegio, cifrado en tránsito interno según riesgo.	Sin puerto 3306 público, migraciones controladas, backups consistentes.
Redes privadas	DMZ del proxy, red API y red DB; permisos de conexión solo entre servicios necesarios.	Prueba de reachability desde Internet y entre contenedores.
Backups externos	Copia programada de MySQL y archivos críticos fuera del VPS, cifrada y versionada.	Restauraciones periódicas aisladas; RPO/RTO objetivos acordados.
Observabilidad	Logs centralizados filtrados, métricas host/contenedores/MySQL, alertas de expiración TLS y disco.	Alertas por saturación y revisión de capacidad.
Seguridad en despliegue	Secrets fuera del repositorio e imágenes, firewall, SCA y rollback preparado.	Separación DEV/PRUEBAS/PROD al menos lógica; evitar conectar datos reales a pruebas.
Evolución futura	Migrar MySQL a servicio gestionado o host separado si crecimiento/riesgo lo exige.	Interfaz de persistencia modular, pruebas de carga y plan de migración.

24.1. Topología lógica de redes

Internet / HTTPS
|
Reverse proxy + TLS [servicio público]
|--- *Frontend Angular público [red frontal]*
|--- *Frontend Angular administrativo [red frontal]*
|
ASP.NET Core API [red privada app] ---> Workers / Outbox [red privada app]

| ---> Adaptadores: pagos, email, medios
MySQL InnoDB [red privada db, sin puertos públicos]
|
Backups cifrados y verificados a ubicación EXTERNA al VPS

24.2. Respaldo y restauración

01. Definir RPO y RTO según contrato y criticidad (no inventar valores garantizados sin dimensionar VPS).
02. Programar copia consistente de MySQL con estrategia compatible con tamaño/carga y binlogs si se requiere recuperación puntual.
03. Encriptar en tránsito y reposo, almacenar fuera del VPS y restringir llaves de respaldo.
04. Simular pérdida de servidor: restaurar en entorno aislado, validar integridad, tenants, documentos y últimos eventos conciliados.
05. Registrar duración real y fallos, corregir la política de respaldo antes de utilizar datos productivos.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Infraestructura objetivo: un VPS de Hostinger bajo administración propia y contenedores aislados por servicio. Los contenedores frontend, API, worker, MySQL y reverse proxy comparten host físico; en consecuencia, la tolerancia a caída del host dependerá de un plan explícito de recuperación y de respaldos externos.

FRONTEND	**Solo contratos de configuración local, indicadores de salud en desarrollo; cero trabajo de despliegue ahora.**
BACKEND	Archivos Docker/compose de desarrollo **diferidos a integración local si se aprueban**, health endpoints y configuración segura.
BASE DE DATOS	SQL local, respaldo/restauración de prueba con datos sintéticos y plan futuro sin tocar VPS.

Prueba de aceptación y riesgo

Positivas / negativas. Comprobaciones locales de ports y secretos; pruebas de restore aislado cuando exista DB local.

Control crítico. Capítulo documental en desarrollo local: no contratar ni configurar Hostinger todavía.

Requisitos de origen que deben rastrearse

HOST Y ACCESO	**Linux soportado, SSH por llaves, deshabilitar autenticación de contraseña cuando corresponda, cuentas sin privilegios y MFA panel.**
DOCKER COMPOSE	Servicios separados con redes internas, salud, restart policies, límites de recursos y volúmenes.
PROXY PÚBLICO	HTTPS automático, HSTS cuando aplique, redirecciones, límites HTTP y configuración de hosts.

Fuente completa: 1 tabla(s), 11 filas, 9 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C24-01 Extraer / C24-02 Diseñar / C24-03 Codificar / C24-04 Probar / C24-05 Auditar A / C24-06 Auditar B / C24-07 Auditar C / C24-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Solo contratos Docker y MySQL locales; DB compartida/dedicada arranca con cuentas separadas, nunca expone puerto.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 24, rutas y componentes; 9 parrafos sustantivos y 1 tablas originales (11 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CAPÍTULO 25 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

25. GitHub, CI/CD y disciplina de microtareas

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La velocidad se obtiene reduciendo el tamaño de cada cambio y automatizando pruebas, no saltándose validaciones. GitHub será la fuente única del código de este proyecto; el flujo de producción utilizará commits y artefactos verificables con control de acceso al VPS.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Rama protegida	PR obligatoria, revisión proporcional, checks requeridos y rechazo de force-push.	No permitir bypass para cambios de seguridad o pagos.
Microtarea	Objetivo acotado de pocas líneas/rutas cuando sea posible, dependencias y aceptación.	Una entrega con pruebas reproducibles; dividir si atraviesa varios dominios.
Tests por cambio	Unit, integration, tenant-negative, contract, UI/E2E y seguridad según alcance.	No exigir batería innecesaria en cada cambio trivial, pero sí todas las pruebas causales.
Build Docker	Crear imagen inmutable con tag SHA y escanear dependencias y secretos.	Conservar digest y reporte; no compilar arbitrariamente en producción.
Deploy VPS	CI aprueba, despliegue por SSH de servicio dedicado o runner controlado, health checks y smoke test.	Secretos minimizados, rollback a imagen previa y aprobación en PROD.
Migraciones MySQL	Expand/contract cuando aplique, respaldo antes de cambio riesgoso y retrocompatibilidad.	Sin migraciones destructivas no reversibles durante despliegue automático.
Pipeline P0	Tests aislamiento tenant, auth, cambios de plan, QR y pagos sandbox.	Falla = no publicar; evidencia de SHA exacto.
Observabilidad postdeploy	Métrica de errores, logs, health checks y alertas tras publicación.	Rollback por umbral documentado; bitácora de release.
Documentación viva	ADR, mapa de módulos, contratos y runbooks actualizados en el mismo PR.	No introducir dependencias sin registrar.
Contención de fallos	Deploy parcial no debe dejar DB o API incoherentes.	Health check por servicio y liberación por etapas.
Secrets	Gestor de secretos o archivos protegidos por host; rotación y separación de entornos.	Escaneo del repositorio/artefactos por credenciales.

25.1. Contrato de una microtarea

ID único, motivación, owner, archivos y módulos permitidos, precondiciones, dependencia, datos afectados, riesgo P0/P1/P2, prueba positiva y negativa, evidencia de revisión, resultado de CI, estrategia de rollback, documentación y estado. Ninguna microtarea “terminada” carece de readback del artefacto construido.

25.2. Reglas para desarrollo rápido

- Primero componentes compartidos: identidad, tenant, permisos, catálogo, diseño, reservas; evitar rehacer cada rubro.
- Crear contratos API y ejemplos automatizados antes de desarrollar pantallas masivas.
- Automatizar generación de cliente HTTP, lint, formatter, pruebas de módulos y despliegue a entorno de pruebas.

- Mantener una sola definición de cada regla y una matriz de pruebas, no múltiples documentos contradictorios.
- Evitar migrar o reescribir tecnología hasta medir la necesidad; toda dependencia lleva dueño y pin aprobado.
- Priorizar demostraciones completas verticales: negocio registrado -> personalizado -> transacción real sandbox -> historial -> análisis -> respaldo.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La velocidad se obtiene reduciendo el tamaño de cada cambio y automatizando pruebas, no saltándose validaciones. GitHub será la fuente única del código de este proyecto; el flujo de producción utilizará commits y artefactos verificables con control de acceso al VPS.

FRONTEND	Pruebas de compilación, lint, accesibilidad y test UI locales; sin publicación.
BACKEND	Scripts reproducibles unit/integration/security, verificación de artefactos y trazabilidad por cambio.
BASE DE DATOS	Migraciones validadas por script local, test de consistencia y rollback.

Prueba de aceptación y riesgo

Positivas / negativas. Comandos reproducibles en máquina local; comprobación de archivos permitidos y diff; nada de repo remoto.

Control crítico. No crear repositorio GitHub ahora; diseñar workflow futuro sin ejecutarlo.

Requisitos de origen que deben rastrearse

RAMA PROTEGIDA	PR obligatoria, revisión proporcional, checks requeridos y rechazo de force-push.
MICROTAREA	Objetivo acotado de pocas líneas/rutas cuando sea posible, dependencias y aceptación.
TESTS POR CAMBIO	Unit, integration, tenant-negative, contract, UI/E2E y seguridad según alcance.

Fuente completa: 1 tabla(s), 12 filas, 10 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C25-01 Extraer / C25-02 Diseñar / C25-03 Codificar / C25-04 Probar / C25-05 Auditar A / C25-06 Auditar B / C25-07 Auditar C / C25-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Pruebas locales/CI definidas: scope de repo CRECISOL futuro, sin cambios reales en GitHub/SOLQARYN.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 25, rutas y componentes; 10 parrafos sustantivos y 1 tablas originales (12 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CAPÍTULO 26 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

26. API, eventos y modelos de datos MySQL

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La base de datos se diseñará normalizada como mínimo hasta 3FN donde aporte consistencia, con excepciones controladas para reporting y rendimiento. Los catálogos comerciales se administran como datos; la lógica de seguridad y estados transaccionales permanece gobernada por código probado. Cada entidad tenant-owned incluye claves y relaciones verificables.

26.1. Catálogo lógico de entidades principales

Dominio	Entidades sugeridas	Responsabilidad principal
Identidad	IdentityUser, EmailAddress, Authenticator, PasskeyCredential, RecoveryCode, Session, SecurityEvent	Usuario global, autenticadores, recuperación y sesiones.
Multiempresa	Tenant, TenantMembership, TenantRole, Permission, RolePermission, Branch, DomainBinding	Identidad comercial, dominio, permisos efectivos y alcance.
Comercial SaaS	Plan, PlanVersion, Entitlement, TenantSubscription, BillingPeriod, SaaSInvoice, SaaSPayment	Planes versionados, contratación y cobro de nuestra plataforma.
Legal	LegalDocument, DocumentVersion, AcceptanceEvidence, ConsentRecord, RetentionPolicy	Documentación, aceptación verificable y privacidad.
CMS	Theme, ThemeVersion, SitePage, SitePageVersion, PageBlock, PublishingJob	Constructor visual, preview y publicación.
Catálogo	CatalogItem, Product, ProductVariant, Service, Category, ItemCategory, AttributeDefinition, AttributeValue, PriceList	Productos/servicios/variantes, taxonomías y precios.
Inventario	StockLocation, StockBalance, StockMovement, StockReservation, Supplier, PurchaseOrder, PurchaseReceipt	Inventario, reservas, proveedores y compras.
Ventas	Cart, SalesOrder, SalesOrderLine, Quote, QuoteVersion, Fulfillment, ReturnCase, WarrantyCase	Carritos, cotizaciones, pedidos y garantías.
Pagos negocio	PaymentIntent, PaymentTransaction, PaymentMethod, PaymentWebhook, Settlement, Refund	Operaciones de pago de clientes finales separadas de SaaS.
Agenda	BusinessHours, HolidayRule, StaffShift, Leave, Resource, AvailabilityHold, Booking, CheckInToken	Horarios, recursos y reservas.
Gimnasios	MembershipPlan, MemberSubscription, MembershipPeriod, AccessCredential, AccessAttempt, ClassSession, ClassBooking, Equipment, MaintenanceCase	Socios, derechos, QR y mantenimiento.

Dominio	Entidades sugeridas	Responsabilidad principal
Clientes	BusinessCustomer, CustomerAccountLink, CustomerEvent, Favorite, SupportCase, CustomerConsent	Historial comercial por tenant.
Fidelidad	LoyaltyProgram, LoyaltyRule, LoyaltyAccount, Reward, RewardRedemption	Puntos, recompensas y usos únicos.
Marketing	SocialConnection, SocialCampaign, SocialPost, SocialPublication, MessageThread, MessageTemplate, OptIn	Calendario, mensajería y campañas por empresa.
Medios	MediaAsset, MediaVersion, StorageQuota, MediaUsageRecord	Archivos y consumo por tenant.
Plataforma	OutboxEvent, InboxReceipt, AuditEntry, BackgroundJob, TenantUsage, Alert	Eventos, auditoría, observabilidad y cuotas.

26.2. Reglas de normalización e integridad

01. Claves internas robustas (UUID/ULID según soporte y decisión); los IDs públicos no revelan secuencia y no sustituyen permisos.
02. Foreign keys incluyen tenant como componente cuando el acceso puede cruzar entidades de negocio; no se permite FK de pedido hacia cliente de otro tenant.
03. Índices únicos tenant-scoped para slug, código comercial, categoría, SKU y claves de idempotencia; índices compuestos para tenant + branch + status + date.
04. FK, CHECK cuando sea adecuado, DECIMAL para importes, zona horaria explícita y timestamps UTC; sin montos flotantes.
05. Soft delete donde exista historia comercial, evitando eliminar vínculos de transacciones; retención conforme a políticas legales.
06. No meter valores de select en arrays de frontend; usar catálogos tipados con estados publicados y permisos de edición.
07. Los reportes usan vistas/proyecciones derivadas de fuentes transaccionales con reconciliación y trazabilidad, no actualizaciones directas del dashboard.

26.3. Contratos API ilustrativos

Operación lógica	Recurso	Autorización obligatoria
Alta negocio	POST /api/platform/tenants	SuperAdmin o onboarding de autoservicio autorizado.
Permisos negocio	PUT /api/tenant/roles/{publicId}/permissions	Administrador tenant, sin exceder sus propias facultades.
Publicar diseño	POST /api/tenant/site/publish	Responsable autorizado y esquema validado.
Consulta catálogo	GET /api/public/catalog	Resolución de dominio y solo contenido publicado.
Guardar reserva	POST /api/tenant/bookings	Tenant, recurso, horario y acceso comercial verificados.
Cobrar pedido	POST /api/tenant/orders/{id}/payments	Operación válida, price server-side, PSP o método autorizado.
Check-in de membresía universal	POST /api/tenant/access/checkins	Lector autorizado, QR válido, derecho de acceso y antireplay.
Descargar contrato	GET /api/platform/contracts/{id}/download	Permiso SuperAdmin/firmante por contrato y vínculo.
Historial cliente	GET /api/tenant/me/history	Usuario cliente verificado y registros propios.

Operación lógica	Recurso	Autorización obligatoria
Solicitar contraseña	POST /api/auth/recovery	Protección anti-enumeración y rate limit.
Revocar sesión	DELETE /api/auth/sessions/{id}	Titular autenticado con autenticación adicional según riesgo.

26.4. Eventos y consistencia

Usar Outbox dentro de la misma transacción de pedido, reserva o renovación. Worker marca entrega, mantiene Inbox/deduplicación cuando recibe webhooks y reintenta con política de backoff. Los mensajes llevan id de evento, idempotency key, contexto tenant verificado, versión de schema, tiempo UTC y correlation ID. La ejecución externa nunca se hace irreversible antes de registrar el estado local y su plan de compensación.

26.5. MySQL y transacciones críticas

InnoDB proporciona transacciones y bloqueo de filas. En reservas, canjes y ventas, implementar orden de adquisición de locks, transacciones breves, índices adecuados, restricción de unicidad, política de retry frente a deadlocks y pruebas de concurrencia. Una búsqueda previa de disponibilidad no autoriza por sí sola la venta: la transacción de confirmación debe revalidar bajo bloqueo.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La base de datos se diseñará normalizada como mínimo hasta 3FN donde aporte consistencia, con excepciones controladas para reporting y rendimiento. Los catálogos comerciales se administran como datos; la lógica de seguridad y estados transaccionales permanece gobernada por código probado. Cada entidad tenant-owned incluye claves y relaciones verificables.

FRONTEND	**Cliente HTTP tipado por OpenAPI, manejo de errores consistente y peticiones paginadas.**
BACKEND	Contratos API versionados, Outbox/Inbox, bounded contexts y transacciones breves.
BASE DE DATOS	MySQL 3FN y FK tenant-aware; decimal para dinero; UTC; índices según consultas medidas.

Prueba de aceptación y riesgo

Positivas / negativas. OpenAPI contract tests, retry idempotente, FK cross-tenant negativa y prueba de concurrencia.

Control crítico. Duplicar lógica de precios/tenancy y compartir tablas entre módulos.

Requisitos de origen que deben rastrearse

IDENTIDAD	**IdentityUser, EmailAddress, Authenticator, PasskeyCredential, RecoveryCode, Session, SecurityEvent**
MULTIEMPRESA	Tenant, TenantMembership, TenantRole, Permission, RolePermission, Branch, DomainBinding

IDENTIDAD	**IdentityUser, EmailAddress, Authenticator, PasskeyCredential, RecoveryCode, Session, SecurityEvent**
COMERCIAL SAAS	Plan, PlanVersion, Entitlement, TenantSubscription, BillingPeriod, SaaSInvoice, SaaSPayment

Fuente completa: 2 tabla(s), 29 filas, 15 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C26-01 Extraer / C26-02 Diseñar / C26-03 Codificar / C26-04 Probar / C26-05 Auditar A / C26-06 Auditar B / C26-07 Auditar C / C26-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

OpenAPI y events incluyen scope seguro; consumer valida tenancy y storage placement; raw SQL bloqueado.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 26, rutas y componentes; 15 parrafos sustantivos y 2 tablas originales (29 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Especificar rutas de Cases, ApprovalRequests, Decisions, Timeline y Events con idempotencia, versionado, ETag, errores uniformes y tenant context. UC-029..034.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 27 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

27. Aceptación funcional y seguridad: pruebas

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Estas pruebas constituyen requisitos futuros, no resultados ejecutados. Cada escenario deberá vincularse a automatización o evidencia de prueba manual controlada. P0 obliga a detener publicación si falla. La calidad se declara por evidencia, no por la ausencia de errores en una demostración.

SEC — autenticación y recuperación

Nivel	Escenario de aceptación
P0	Solicitar recuperación por un correo no registrado no revela si existe cuenta.
P0	Un enlace de recuperación caducado, usado o alterado no cambia contraseña.
P0	Al restablecer contraseña se revocan todas las sesiones previas y los tokens de recuperación.
P0	No se recupera cuenta respondiendo una pregunta personal predecible.
P0	Registrar passkey exige desafío válido, origen correcto y control del autenticador.
P0	Autenticación del SuperAdmin requiere MFA/passkey según política.
P0	Cambio de correo/MFA requiere reautenticación reforzada y notificación a canal previo.
P0	Un QR fotografiado no autoriza por sí solo sesión o restablecimiento de contraseña.
P1	Los códigos de respaldo son únicos, de un solo uso y pueden revocarse.
P1	Usuario puede ver y revocar sesiones activas y dispositivos confiables.

TEN — aislamiento y permisos

Nivel	Escenario de aceptación
P0	Tenant A no consulta por API pedidos, empleados, fotos, clientes o finanzas de B.
P0	Cambiar slug, host, header, ID o caché no transfiere pertenencia.
P0	FK o escritura intertenant falla incluso si se manipula un cuerpo JSON válido.
P0	Empleado sin permiso financiero no puede exportar ni consultar reportes monetarios.
P0	Un trabajador de sucursal A no puede intervenir agenda de B sin atribución.
P0	Acceso global para soporte requiere razón, duración, permiso y auditoría.
P0	Token revocado no mantiene acceso a SignalR, archivos o API.
P0	El sistema deniega una operación nueva cuyo rol no contiene el permiso necesario.
P1	Un usuario en varios negocios escoge solo entre los que está autorizado a operar.
P1	No hay fuga por claves de caché ni workers con tenant mal propagado.

PAY — pagos, compras y suscripciones

Nivel	Escenario de aceptación
P0	Modificar el precio del navegador no cambia el total en backend.
P0	Webhook falsificado sin firma válida no confirma pago.
P0	Dos webhooks iguales no producen doble factura ni doble cobro.
P0	No se guardan PAN ni CVV en DB, logs o archivos.
P0	Renovación de SaaS fallida no concede periodo pagado.
P0	Pago de empresa A no puede liquidar una orden de empresa B.
P1	Transferencia pendiente no figura como cobrada antes de conciliación.
P1	POS presencial acepta referencia y estado sin capturar datos de tarjeta.
P1	Reembolso parcial conserva saldo y conciliación coherentes.
P1	Cambio de plan registra prorrateo y fecha de aplicación explicables.

INV — inventario, ventas y devoluciones

Nivel	Escenario de aceptación
P0	Dos ventas simultáneas de última unidad no provocan stock negativo.
P0	Movimiento entre sucursales no deja saldos inconsistentes si falla recepción.
P0	Ajustar stock requiere permiso, razón y movimiento auditable.
P1	Una variante de tenis talla/color guarda SKU y saldo independientes.
P1	Lote caducado bloqueado no aparece como vendible cuando se configura.
P1	Serie de garantía no se asigna a dos ventas activas indebidamente.
P1	Cotización aceptada conserva snapshot de precio y condiciones.
P1	Cambio o devolución actualiza pagos, stock y documentos de forma consistente.

SCH — horarios, reservas y QR universales

Nivel	Escenario de aceptación
P0	Dos clientes no confirman el mismo recurso y franja incompatibles.
P0	Empleado de vacaciones no aparece disponible; motivo privado no se muestra.
P0	QR de ticket consumido se rechaza al segundo intento.
P0	QR de otra sucursal/tenant no genera check-in autorizado.
P1	Festivo con horario especial cambia estado público y slots disponibles.
P1	Turno nocturno 20:00–02:00 resuelve correctamente día y zona horaria.
P1	Cierre extraordinario presenta reservas afectadas antes de publicar.
P1	Notificación fallida no borra reserva confirmada.

MEM — membresías, derechos y acceso físico universales

Nivel	Escenario de aceptación
P0	Socio vencido o plan no habilitado no obtiene acceso por QR.
P0	Reutilización de token efímero de entrada se rechaza según política.
P0	Upgrade/downgrade no duplica cuotas ni asigna derechos antes de pago requerido.
P1	Congelamiento preserva historia y calcula nueva vigencia bajo reglas firmadas.
P1	Clase completa no admite inscripción extra por carrera simultánea.
P1	Equipo fuera de servicio no se ofrece como recurso disponible.
P1	Afiliación multisede se verifica por plan, horario y sucursal.
P1	Historial de ingreso se consulta solo por roles y titular autorizados.

UI — editor, gráficos y experiencia

Nivel	Escenario de aceptación
P0	Un bloque de contenido no puede inyectar JavaScript o CSS arbitrario ejecutable.
P0	Vista previa de un tenant no se vuelve visible en sitio ajeno o sin publicar.
P1	Reordenar tarjetas guarda versión y aparece en móvil y escritorio correctamente.
P1	Rollback restaura publicación anterior sin borrar auditoría.
P1	Acciones iconográficas funcionan con teclado, lector de pantalla y móvil.
P1	Una tipografía externa incompatible se rechaza y utiliza fallback.
P1	Gráfico semestral, mensual o diario ofrece resultados consistentes con el mismo filtro.
P1	Menús de navegación no muestran acciones no contratadas o sin permiso.

MEDIA — archivos, privacidad y CMS

Nivel	Escenario de aceptación
P0	Archivo privado de empresa A no se descarga usando token/URL de B.
P0	Subir archivo con contenido no permitido se bloquea independientemente de extensión.
P0	No se publican documentos contractuales en CDN público.
P1	Consumo por tenant suma bytes y puede reconciliarse con proveedor.
P1	Borrado respeta retención legal y purga medios cuando procede.
P1	Ocultar estacionamiento elimina esa información del render y API pública.
P1	Mapa respeta términos de atribución y muestra fallback ante indisponibilidad.
P1	Variantes de imagen no rompen la experiencia de carga móvil.

SOC — marketing, fidelidad y valoración

Nivel	Escenario de aceptación
P0	Empleado no conecta cuenta de red social de otro negocio.
P0	Token de proveedor social nunca aparece en navegador o logs.
P0	Premio de QR ya canjeado no puede reactivarse por replay.
P1	Estado publicado se guarda por canal, con error específico donde falle.
P1	Bot de WhatsApp respeta ventana/plantilla y consentimiento vigente.
P1	Cliente solo califica una experiencia verificable conforme a política.
P1	Incidente de cliente admite revisión/corrección y no genera bloqueo automático.
P1	Se puede deshabilitar visibilidad de reseñas por negocio sin borrar historia.

OPS — infraestructura, CI/CD y disponibilidad

Nivel	Escenario de aceptación
P0	El puerto MySQL no resulta accesible desde Internet.
P0	Backup externo cifrado se restaura en entorno aislado y pasa integridad.
P0	Un build que falla test intertenant o secret scan no despliega producción.
P0	Imagen Docker no contiene secreto de producción.
P0	El despliegue identifica SHA/digest y permite volver a artefacto previo.
P1	Saturación de RAM/disco genera alerta antes del fallo operativo.
P1	Caída de websocket no pierde pedido ni cobro registrado.
P1	Deadlock MySQL admite retry seguro sin ejecutar doble acción externa.
P1	La app se reinicia sin pérdida de volumen de datos.
P1	El entorno de pruebas usa datos ficticios e integraciones sandbox.

LEGAL — contratos, consentimiento y derechos

Nivel	Escenario de aceptación
P0	La aceptación conserva versión exacta de contrato y fecha.
P0	No se activa negocio comercial sin documentos mínimos requeridos.
P0	Marketing sin opt-in no envía mensajes comerciales no permitidos.
P1	Cliente consulta historial, solicita rectificación y obtiene respuesta auditada.
P1	Cambio de políticas no sobrescribe evidencia de aceptación anterior.
P1	Exportación del titular excluye información de terceros.
P1	Soporte de plataforma no abre historial sensible sin procedimiento autorizado.
P1	Reclamación posee estado, responsable y resolución documentada.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Estas pruebas constituyen requisitos futuros, no resultados ejecutados. Cada escenario deberá vincularse a automatización o evidencia de prueba manual controlada. P0 obliga a detener publicación si falla. La calidad se declara por evidencia, no por la ausencia de errores en una demostración.

FRONTEND	Suites Playwright locales con pruebas responsive, a11y, preview, teclado y visual regression.
BACKEND	Unit, integration, auth, permission, payment sandbox, rate limit y negative tenants.
BASE DE DATOS	Pruebas de integridad, migraciones, deadlock, restore, concurrencia y seeded data.

Prueba de aceptación y riesgo

Positivas / negativas. Cada escenario P0/P1 de matriz con id, runner, resultado y evidencia; no declarar pruebas sin ejecución.

Control crítico. Checklists confundidos con certificación.

Requisitos de origen que deben rastrearse

P0	Solicitar recuperación por un correo no registrado no revela si existe cuenta.
P0	Un enlace de recuperación caducado, usado o alterado no cambia contraseña.
P0	Al restablecer contraseña se revocan todas las sesiones previas y los tokens de recuperación.

Fuente completa: 11 tabla(s), 107 filas, 12 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C27-01 Extraer / C27-02 Diseñar / C27-03 Codificar / C27-04 Probar / C27-05 Auditar A / C27-06 Auditar B / C27-07 Auditar C / C27-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Suites A/B/shared/dedicated, acceso SuperAdmin y cross-tenant en toda ruta; 0 P0/P1 abiertos.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 27, rutas y componentes; 12 parrafos sustantivos y 11 tablas originales (107 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Automatizar matriz UC-001..UC-042, positivas/negativas, regresiones de SHARED y DEDICATED; pruebas pendientes hasta ejecución real.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 28 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

28. Matriz completa de 30 mejoras

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

La matriz es el mapa de cobertura de producto. Cada fila obliga a un requisito funcional, a su control de seguridad y a una prueba; una mención genérica no alcanza para darlo por cumplido. El resultado esperado de diseño es cobertura total de los treinta requerimientos, sin afirmar que estén desarrollados.

ID	Requisito explícito	Cobertura en capítulos	Criterio obligatorio
1	Modelado de amenazas multitenant	04, 05, 06, 07, 27	Registro STRIDE/abuso y prueba BOLA/tenant por módulo.
2	Permisos por acción	04, 06, 08, 26, 27	Matriz por rol, tenant, sucursal, acción y recurso; pruebas negativas.
3	Pruebas negativas entre empresas	04, 06, 07, 27	IDs, URLs, roles, archivos, cola y caché cruzados rechazados.
4	Separación SuperAdmin y negocios	02, 04, 06, 08, 17	Control plane independiente; soporte break-glass auditado.
5	Aprovisionamiento atómico de empresas	04, 08, 26	No publicar tenants parcialmente creados; reintentos idempotentes.
6	Auditoría de operaciones sensibles	05, 06, 07, 21, 26	Actor, tenant, recurso, acción, correlación, política de retención.
7	CI/CD verificado por commit	24, 25, 27	Artefacto/digest y tests P0 por SHA exacto antes de producción.
8	Respaldos con restauración probada	07, 24, 27	Backup cifrado offsite; ensayo de restauración y RPO/RTO medidos.
9	Outbox transaccional	03, 14, 25, 26	Evento junto a transacción de origen, reintentos y deduplicación.
10	Idempotencia	08, 12, 13, 15, 26	Pagos, QR, reservas y renovaciones resistentes a reenvío.
11	Seguridad de archivos por empresa	06, 07, 21, 27	Descarga privada con acceso verificado por tenant y expiración.
12	Despliegues protegidos	07, 24, 25	Aprobaciones, rollback, mínimos privilegios y evidencias.
13	Inventario por sucursal	10, 11, 12	Ledger de movimientos, stock disponible/reservado y concurrencia.
14	Proveedores y compras	11, 26	Proveedor, OC, recepción, costo y permisos diferenciados.
15	Devoluciones, cambios y garantías	11, 12, 16	RMA, reembolso, series, historial y pruebas transaccionales.
16	Exportaciones seguras PDF/Excel/CSV	06, 12, 17, 22	Permisos fila/campo, auditoría y URLs temporales.
17	Catálogos y selects administrables	09, 10, 26	CRUD tipado con integridad; estados críticos gobernados por código.

ID	Requisito explícito	Cobertura en capítulos	Criterio obligatorio
18	Sistema uniforme de modales	02, 09	Focus trap, navegación accesible, tamaño móvil y propósito claro.
19	Menús dinámicos jerárquicos	02, 06, 09	Navegación por permisos y entitlements evaluados en backend.
20	Dashboard global de salud SaaS	08, 22, 24	Tenants, contratos, dominios, storage, infra, alertas y costes.
21	Pruebas responsive/accesibles	02, 09, 20, 27	Móvil/tablet/escritorio, WCAG y movimiento reducido.
22	Centro de demostración sintético	02, 08, 27	Módulos por sector/rol con datos ficticios, sin cobros reales.
23	Analítica multidimensional	15, 17, 22	Fecha, sucursal, empleado, producto, servicio y drilldown autorizado.
24	Historial versionado contratos/suscripciones	08, 15, 23	Vigencias, renovaciones, cambios, firma y aceptación inmutables.
25	Comisiones comerciales opcionales	12, 22	Reglas auditables y revisión tras devoluciones o reclamos.
26	Cierre de caja y gastos ligeros	12, 22	Arqueo, diferencia, movimientos, egresos y permisos.
27	Activación por empresa y plan	04, 08, 09	Entitlements server-side, flags y techo comercial versionado.
28	Observabilidad del VPS	07, 22, 24, 25	CPU, RAM, discos, latencia API, MySQL, colas, TLS y backups.
29	Onboarding guiado por rubro	02, 04, 08, 09, 16	Asistente, plantillas recomendadas, dominio, marca y pruebas previas.
30	Políticas y consentimiento versionados	05, 17, 18, 23	Tres relaciones legales, versiones, evidencias, opt-in diferenciado.

28.1. Verificación documental automática

Criterio de revisión: los 30 IDs deben aparecer una vez en la matriz; deben existir capítulos de producto, seguridad, operaciones, datos, evidencia y pruebas; no pueden coexistir recomendaciones contradictorias sobre la base de datos o el entorno de alojamiento. Los criterios de aceptación futuros se relacionan con suites de pruebas, pero el diseño documental por sí solo no equivale a certificación.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. La matriz es el mapa de cobertura de producto. Cada fila obliga a un requisito funcional, a su control de seguridad y a una prueba; una mención genérica no alcanza para darlo por cumplido. El resultado esperado de diseño es cobertura total de los treinta requerimientos, sin afirmar que estén desarrollados.

FRONTEND	**Verificar cobertura UI de 30 mejoras con mapeo a casos de uso y componentes.**
BACKEND	Matriz 30 IDs enlazados a endpoints/servicios/controles de seguridad.
BASE DE DATOS	Relaciones 30 IDs a entidades/migraciones y datasets de prueba.

Prueba de aceptación y riesgo

Positivas / negativas. Cobertura 30/30 documental y evidencia técnica antes de cerrar.

Control crítico. Mención genérica de requisito sin implementación completa.

Requisitos de origen que deben rastrearse

1	**Modelado de amenazas multitenant**
2	Permisos por acción
3	Pruebas negativas entre empresas

Fuente completa: 1 tabla(s), 31 filas, 3 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C28-01 Extraer / C28-02 Diseñar / C28-03 Codificar / C28-04 Probar / C28-05 Auditar A / C28-06 Auditar B / C28-07 Auditar C / C28-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Las 30 mejoras verifican persistencia compartida/dedicada y nuevos controles de alcance sin duplicacion de código.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 28, rutas y componentes; 3 parrafos sustantivos y 1 tablas originales (31 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CAPÍTULO 29 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

29. Puertas de lanzamiento y decisiones pendientes

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Puerta de salida de marca: identidad CRECISOL revisada, dominio comercial verificado, titulares legales identificados, remitentes de correo autenticados, nombres y metadatos consistentes, enlaces/QR separados por finalidad y pruebas negativas de suplantación. La adopción del nombre está confirmada; estas comprobaciones técnicas y jurídicas no se presumen ejecutadas.

La finalidad del diseño maestro de CRECISOL es permitir aprobar una línea base cerrada de necesidades y criterios de calidad. Las tecnologías específicas se fijarán mediante decisiones arquitectónicas registradas antes de crear infraestructura definitiva; hasta entonces, no se deben confundir hipótesis con pruebas realizadas.

Capacidad / regla	Comportamiento funcional	Control / aceptación
Tecnología de frontend	Confirmar versiones Angular, Node, bibliotecas de UI y estrategia SSR/híbrida.	Prueba de compatibilidad, rendimiento, seguridad y mantenimiento.
Tecnología backend	Confirmar .NET y proveedor EF Core para MySQL y versiones compatibles.	Migrations, transacciones, concurrencia e integración.
Hostinger VPS	Confirmar CPU/RAM/disco, ancho de banda, backups, región, firewall y acceso operativo.	Dimensionamiento y piloto con carga representativa.
MySQL	Versiones exactas, configuración InnoDB, cifrado, backups, logging y failover futuro.	Ensayo de restore y concurrencia.
Cloudflare R2 - almacenamiento	Configurar R2 para medios públicos y privados; ninguna carpeta otorga permisos.	Política de carpetas, tenancy, caducidad de enlaces y costos.
Proveedor de pago	Seleccionar PSP para Honduras, afiliación, sandbox, webhooks, 3DS, tokenización y liquidación.	No habilitar cobros reales hasta evaluación PCI/legal.
Dominios y DNS	Elegir proveedor DNS, wildcard y certificados para modalidades A/B/C.	Pruebas de aislamiento y automatización de TLS.
Legal y fiscal	Revisar términos del SaaS y plantillas sectoriales con asesoría hondureña.	No atribuir cumplimiento por una plantilla sin revisión.
Escala comercial	Definir límites medibles por plan, uso de CPU/media, facturación y fair-use.	Cuotas por tenant y protección de recursos compartidos.
Operación 24/7	Definir RPO/RTO, disponibilidad ofrecida, soporte, incidentes y horarios de mantenimiento.	Prueba de recuperación y cronograma de on-call proporcional.
Servicios especiales	Determinar si clínicas, niñez o biometría entran en el primer lanzamiento.	Evaluación de impacto específica previa a habilitar.

29.1. Requisitos P0 antes del primer negocio real

01. Autenticación, MFA del administrador, recuperación segura, sesiones y auditoría probados.
02. Aislamiento multitenant y permisos negativos probados en API, DB, media y eventos.
03. Respaldo externo y restauración de prueba completados.
04. Pagos sandbox idempotentes y conciliación validada; pagos reales solo con PSP habilitado.

05. Contratos, políticas y aceptación por empresa revisados por responsable legal.
06. VPS endurecido, MySQL no público, SSL, monitoreo, secret scanning y alertas.
07. Transacciones de reserva, stock, QR, membresía y pago con prueba de concurrencia.
08. Experiencia móvil, accesibilidad, fallos de red y recuperación de pedido verificadas.
09. Pipeline CI/CD con pruebas requeridas, SHA exacto, rollback y documentación operativa.

29.2. Propuesta de verticales piloto

Construir una barbería (reservas y personal), una tienda de tenis (variantes, POS e inventario) y un gimnasio (membresías y QR) como escenarios sintéticos completos que validen los tres modelos comerciales. Un restaurante con mesa QR verifica el autoservicio en una etapa posterior del piloto si la infraestructura y el equipo lo permiten.

29.3. Criterio de cierre

El diseño se puede considerar aprobado documentalmente cuando el propietario acepte alcance, arquitectura de referencia, matriz de permisos, 30 requisitos, criterios de pruebas y decisiones pendientes. El software quedará “listo para producción” solo tras las implementaciones y certificaciones posteriores; ningún documento sustituye una prueba real.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Puerta de salida de marca: identidad CRECISOL revisada, dominio comercial verificado, titulares legales identificados, remitentes de correo autenticados, nombres y metadatos consistentes, enlaces/QR separados por finalidad y pruebas negativas de suplantación. La adopción del nombre está confirmada; estas comprobaciones técnicas y jurídicas no se presumen ejecutadas.

FRONTEND	Matriz de decisiones, go/no-go y pilotos sintéticos sin habilitar onboarding real.
BACKEND	Feature switches que bloquean funciones no verificadas; separación de certificado vs planificado.
BASE DE DATOS	Registro de gates, owners, evidencias y trazabilidad; no falsificar estados.

Prueba de aceptación y riesgo

Positivas / negativas. Cualquier P0 sin prueba bloquea cierre de software; hardware y legal se marcan futuros.

Control crítico. Dar por listo productivo basándose en documento o demo.

Requisitos de origen que deben rastrearse

TECNOLOGÍA DE FRONTEND	Confirmar versiones Angular, Node, bibliotecas de UI y estrategia SSR/híbrida.
TECNOLOGÍA BACKEND	Confirmar .NET y proveedor EF Core para MySQL y versiones compatibles.
HOSTINGER VPS	Confirmar CPU/RAM/disco, ancho de banda, backups, región, firewall y acceso operativo.

Fuente completa: 1 tabla(s), 12 filas, 16 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C29-01 Extraer / C29-02 Diseñar / C29-03 Codificar / C29-04 Probar / C29-05 Auditar A / C29-06 Auditar B / C29-07 Auditar C / C29-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Gates exigen tests, amenazas y evidencia; no confundir dominio declarado con DNS/TLS verificado.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 29, rutas y componentes; 16 parrafos sustantivos y 1 tablas originales (12 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

No-go de seguimiento si falla test de aislamiento, aprobación por versión, condición de cierre, entrega, evidencia o idempotencia.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 30 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

30. Capacidades universales, permisos y rubros

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

REGLA CENTRAL: ningun sector es dueño exclusivo de un módulo. Todos los tenants pueden habilitar las capacidades universales bajo sus planes, permisos y obligaciones aplicables.

El rubro solo propone una plantilla inicial, nunca impone límites arbitrarios: una joyeria puede ofrecer mantenimiento, membresias VIP, reservas y QR; una cafeteria puede vender pases mensuales; un gimnasio puede vender productos y servicios; un taller puede gestionar paquetes, suscripciones, inventario, reparaciones y cotizaciones. Un negocio puede combinar varios rubros, sucursales, locales y experiencias públicas sin duplicar el sistema ni mezclar datos.

30.1. Registro funcional de capacidades y reglas

Capacidad	Función transversal	Regla de habilitacion
IDENTIDAD	Cuentas, acceso sin código manual de tenant, sesiones, MFA, passkeys, recuperación y portal de clientes.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
TENANCY	Dominio tipo A/B/C, sucursales, permisos, capacidades, aislamiento y auditoría.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
MEMBERSHIPS	Planes, inscripciones, cuotas, períodos, upgrades, congelamientos, renovaciones y derechos.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
ACCESS	QR físico o digital, tickets, lectura y validación, dispositivos, cupos y antireplay.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
SCHEDULING	Horarios, festivos, disponibilidad, personas favoritas, espacios y reservas multirrecurso.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
CATALOG	Productos, variantes, servicios, paquetes, tarifas, atributos, impuestos y medios.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
INVENTORY	Inventario, compras, lotes, códigos de barras, recepciones, traslados y control por sede.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
SALES	Cotizaciones, carrito, pedidos, POS, caja, devoluciones, cambios y garantias.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
PAYMENTS	Enlaces de pago, POS, QR de proveedor, transferencia, efectivo, tarjeta y conciliacion.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
CRM	Ficha y eventos del cliente, consentimiento, favoritos, atenciones, incidentes, reseñas.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
LOYALTY	Puntos, cupones, promociones por visita, Wallet, validación de recompensa.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
SOCIAL	Redes, campañas, calendario, mensajes, respuestas configurables y métricas de canal.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
WEB	Página pública, editor visual, anuncios, landing del SaaS, mapas y contacto.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.

Capacidad	Función transversal	Regla de habilitacion
MEDIA	Imágenes, videos, documentos, logos, archivos, versiones, cuotas y accesos privados.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
FINANCE	Ingresos, gastos, caja, impuestos configurables, comisiones y reportes.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
LEGAL	Terminos y condiciones versionados; contratos, consentimiento y evidencias.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
ANALYTICS	Indicadores operativos, visualizaciones, filtros por sede, exportaciones y auditoría.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
SECURITY	Gestión central, controles de confianza, incidentes, registros y pruebas negativas.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
DEMO	Entornos sinteticos de demostracion para plataforma y por sector.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.
API	Integraciones verificadas, webhooks, outbox y tareas asincronas.	Por tenant/sucursal, contrato, rol y accion; sin depender de un rubro fijo.

Una capacidad puede tener estados disponible, contratada, habilitada, configurada, publicada, suspendida y retirada. Estas etapas no son equivalentes. La interfaz solo muestra acciones autorizadas; el backend exige nuevamente la verificación del permiso y del entitlement. El SuperAdmin posee un catalogo global de módulos; los administradores de negocio gestionan los que les correspondan, y empleados/clientes observan exclusivamente las funciones de su rol y relaciones.

30.2. Matriz de aplicabilidad por sectores

Tipo de negocio	Configuración inicial ilustrativa	Limite
Gimnasio y centro deportivo	Membresias, acceso por QR, clases, entrenadores, equipos, tienda, reservas, cuotas y promociones.	No exclusiva; todo módulo universal es elegible.
Barberia y salon	Profesionales, membresia de mantenimiento, citas, cabinas, QR de check-in y productos.	No exclusiva; todo módulo universal es elegible.
Restaurante y cafeteria	Menu, mesas, QR, pedidos, membresia de cafe, reservas, stock, Wallet y POS.	No exclusiva; todo módulo universal es elegible.
Taller auto/moto	Ordenes de reparación, mecanicos, paquetes por kilometraje, reserva, repuestos y garantia.	No exclusiva; todo módulo universal es elegible.
Car wash	Membresia de lavados, QR de acceso, bahias, turnos, variantes por vehiculo, promociones.	No exclusiva; todo módulo universal es elegible.
Spa, estetica, odontologia	Tratamientos, especialistas, paquetes, agenda, control de acceso y privacidad reforzada.	No exclusiva; todo módulo universal es elegible.
Joyerias, relojerias	Garantias, citas, reparaciones, producto serializado, membresias VIP y POS.	No exclusiva; todo módulo universal es elegible.
Ropa, tenis, juguetes	Variantes, inventario, descuentos, reservas de recogida, devoluciones y membresias.	No exclusiva; todo módulo universal es elegible.
Supermercado, pulperia	Código de barras, compras, stock, POS, entregas, precios, fidelidad y tarjetas prepago.	No exclusiva; todo módulo universal es elegible.

Tipo de negocio	Configuración inicial ilustrativa	Limite
Academia, idiomas, danza	Inscripciones, mensualidades, clases, asistencia QR, tutores y calendarios.	No exclusiva; todo módulo universal es elegible.
Ferreteria/electronicos	Producto técnico, servicio, creditos autorizados, presupuestos, inventario y garantias.	No exclusiva; todo módulo universal es elegible.
Mascotas/veterinaria	Productos, agenda, paquetes, historial de servicios y datos sensibles segregados.	No exclusiva; todo módulo universal es elegible.
Hospedajes/eventos	Reserva de espacio, pagos, accesos temporales, horarios, paquetes y capacidad.	No exclusiva; todo módulo universal es elegible.
Servicios profesionales	Citas, cotizaciones, contratos, suscripciones, expedientes y entregables.	No exclusiva; todo módulo universal es elegible.

30.3. Autenticación contextual y acceso a recursos

- El dominio permite resolver el tenant, pero no concede permisos. La identidad autenticada se une a su membresia, sucursal, rol, alcance, estado del recurso y condiciones de la operación.
- El portal del cliente registra sus movimientos SOLO en el tenant al que pertenecen; el historial de empresas contratantes se almacena por separado en el plano global.
- Los lectores QR de membresia y reservacion exigen identidad del dispositivo y aplican reglas de horario, validez de derechos, no duplicacion, limite de visitas y autorización del servicio.
- Los clientes pueden elegir persona, silla, cabina, mesa o espacio cuando el establecimiento habilite esa preferencia; la selección no revela información laboral privada.
- Los empleados no tienen acceso por defecto a finanzas, clientes ajenos ni reportes sensibles. Cada accion se concede explicitamente y genera auditoría cuando corresponde.
- Cuando el negocio deshabilita una capacidad, el backend también la revoca; la eliminación visual o el ocultamiento de un boton nunca reemplazan la autorización.

30.4. Acceso QR compartido: escenario universal

Operación	Ejemplo	Validación requerida
Reservacion	Barberia solicita cita y emite comprobante QR	Reserva, horario, profesional, capacidad y check-in único.
Acceso físico	Gimnasio, coworking o academia utiliza lector	Tenant, sede, credencial, plan activo, zona, anti-replay y dispositivo.
Pago	Cliente abre QR de cobro o link	Intencion de pago, PSP, importe inmutable y webhook.
Mesa	Restaurante asocia un pedido a mesa	Mesa activa, turno de atención, capacidad, protección contra abuso.
Fidelidad	Cliente presenta tarjeta de beneficios	Regla, puntos, firma/estado y canje atomico.
Retiro/entrega	Tienda valida ticket de recogida	Pedido, titular cuando aplique, estado y uso único.
Evento	Academia valida entrada de clase	Sesión, aforo, pase, horario y reingreso autorizado.

Los códigos QR no son el mecanismo de autenticación universal. Los tokens sensibles se emiten como secretos aleatorios de al menos 128 bits de entropia, se almacenan como hash cuando corresponda, se vinculan a una finalidad y caducan. Credenciales de acceso y códigos de mesa tienen riesgos diferentes: el QR público de mesa puede permanecer visible, pero no autoriza cobros ni acceso a datos privados.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. REGLA CENTRAL: ningun sector es dueño exclusivo de un módulo. Todos los tenants pueden habilitar las capacidades universales bajo sus planes, permisos y obligaciones aplicables.

FRONTEND	Administración universal de capacidades, rubros y permisos con tablas y filtros.
BACKEND	Capability Resolver independiente del sector, políticas tenant/plan/sucursal/rol.
BASE DE DATOS	CapabilityCatalog, Entitlement, TenantCapability, PermissionConstraint, SectorTemplate.

Prueba de aceptación y riesgo

Positivas / negativas. Una joyería usa reservas/membresías sin código nuevo; permisos y plan siguen limitando.

Control crítico. No hardcodear módulos por rubro.

Requisitos de origen que deben rastrearse

IDENTIDAD	Cuentas, acceso sin código manual de tenant, sesiones, MFA, passkeys, recuperación y portal de clientes.
TENANCY	Dominio tipo A/B/C, sucursales, permisos, capacidades, aislamiento y auditoría.
MEMBERSHIPS	Planes, inscripciones, cuotas, períodos, upgrades, congelamientos, renovaciones y derechos.

Fuente completa: 3 tabla(s), 44 filas, 14 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C30-01 Extraer / C30-02 Diseñar / C30-03 Codificar / C30-04 Probar / C30-05 Auditar A / C30-06 Auditar B / C30-07 Auditar C / C30-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Roles, entitlements, rubros y acciones por empresa; ninguna pantalla revela módulos contratados de otra.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 30, rutas y componentes; 14 parrafos sustantivos y 3 tablas originales (44 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Seguimiento como capacidad universal disponible para cualquier operación, sin codificar estados específicos en pantallas ni excluir sectores por plan; RBAC restringe acciones.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 31 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

31. Pagos por enlace, cobros y suscripciones universales

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

El link de pago es una capacidad nativa para la facturacion del SaaS y para las ventas de cada negocio. Los dos circuitos monetarios y sus cuentas receptoras son independientes.

El comercio podrá crear un enlace para cobrar una factura, una cotización aprobada, una reserva con anticipo, un pedido, una cuota de membresia, una reparación o un saldo parcial. La plataforma podrá emitir enlaces de pago para sus contratos y renovaciones. Cada tenant controla sus métodos habilitados; el dinero se dirige a la cuenta autorizada del emisor de la venta, salvo un modelo regulado y contratado expresamente.

31.1. Flujo de pago seguro

01. Crear una obligacion transaccional: pedido, cuota, cotización, factura o renovacion con partidas, moneda, impuesto y descuentos fijados en backend.
02. Calcular total de forma determinista; generar checkout_session con importe inmutable, tenant, beneficiario, cliente opcional y vencimiento.
03. Crear payment_link con token opaco aleatorio, hash persistido, condiciones de uso, límites y enlace corto con dominio verificable.
04. Mostrar la página informativa del emisor con desglose, condiciones y advertencias; nunca insertar tarjetas en nuestro frontend sin certificación de alcance PCI.
05. Redirigir a checkout alojado del PSP contratado o registrar otra vía de pago pendiente de comprobación; evitar sobreafirmar pago confirmado.
06. Recibir webhook con firma y timestamp, verificar merchant/tenant/currency/amount, deduplicar evento, correlacionar transacción y persistir atomico.
07. Conciliar frente al PSP y registrar pago, nota, comprobante y movimientos financieros; emitir notificación vía outbox.
08. Si hay error, expiracion, cancelación o pago parcial, conservar historial e impedir aplicar un mismo ingreso dos veces.

31.2. Maquina de estados del link

Entidad	Estados posibles	Restricciones
Checkout	CREADO, EMITIDO, ABIERTO, PROCESANDO, PAGADO, PARCIAL, VENCIDO, CANCELADO, FALLIDO	No retroceder PAGADO por una devolución: crear refund independiente.
Enlace	BORRADOR, ACTIVO, PAUSADO, VENCIDO, CANCELADO, CONSUMIDO	El servidor exige tenant, audiencia, validez, alcance y quota.
Intento	CREADO, REDIRIGIDO, REQUIERE_ACCION, APROBADO, RECHAZADO, DESCONOCIDO	Estado externo se reconcilia; no confiar en callback del browser.
Reembolso	SOLICITADO, APROBADO, EN_PROCESO, COMPLETADO, RECHAZADO	Permisos especiales, registro de comprobantes e idempotencia.
Transferencia	PENDIENTE, EN_REVISION, CONCILIADA, RECHAZADA	Captura manual/documental no equivale a conciliacion bancaria.
Efectivo/POS	PENDIENTE, REGISTRADO, RECONCILIADO, ANULADO	Cajero y sesión de caja identificados, cierre firmado.

31.3. Caracteristicas del enlace de pago

Control	Especificacion obligatoria
Identidad	El link se vincula a un checkout y un tenant real; la URL no muestra IDs secuenciales.
Importe	El monto, moneda, descuentos, impuestos y beneficiario se recalculan y congelan en backend.
Expiracion	Configurable por política; sin enlaces eternos para importes exigibles.
Uso	Uso único para una obligacion única; pagos parciales con ledger y reglas expresas.
Comparticion	Correo, WhatsApp, QR o enlace copiable. El token no debe aparecer en logs ni analítica.
Fraude	Rate limiting, reputacion, deteccion de manipulacion, referencias del PSP y step-up cuando aplique.
Pago repetido	Idempotencia: mismo pedido y misma obligacion no generan doble cargo ni doble reconocimiento.
Webhooks	Firma autentica, replay window, merchant ID, amount, currency, deduplicacion e inbox durable.
Datos de tarjeta	Nunca almacenar PAN completo, CVV, magstripe ni credenciales de autenticación del cliente.
Auditoría	Quien genero, modifico, envio, cancelo, cobro, devolvio y concilio; con fecha y razón.
Privacidad	Página pública minimizada; información adicional del cliente solo tras autenticación.
Disponibilidad	Si PSP falla: PENDIENTE, reintento seguro, aviso humano y reconciliacion posterior.

31.4. Medios de pago para todos los negocios

Medio	Checkout / POS / cuota	Regla de confirmacion
Tarjeta online	Redireccion a proveedor afiliado y checkout alojado.	Confirmacion PSP firmada y conciliada.
Tarjeta presencial	Terminal POS del comercio; referencia de ticket.	Verificar comprobante, lote y cierre; no guardar PAN.
Transferencia	Cuenta bancaria del comercio y referencia de pago.	Conciliacion manual o bancaria, no captura solamente.
Efectivo	Caja empresarial y recibo.	Sesiones y arqueo, con permisos.
Contra entrega	Orden aceptada con pago pendiente.	Confirmar contra entrega, devoluciones y riesgos.
Pago mixto	Abonos, saldo, gift card o dos medios.	Ledger de aplicación sin sobregiros.
Cuotas y membresias	Cobro por período, upgrade, downgrade, congelamiento.	Reglas prorrata y acceso según pago/período.
Link de pago	URL/QR enviada por canal autorizado.	Estados, vencimiento, token e idempotencia.

La eleccion y afiliacion al proveedor de pago real siguen siendo una decisión comercial y regulatoria pendiente. Una cuenta de GitHub, Cloudflare o Hostinger no sustituye una pasarela bancaria. El proyecto desplegara el adaptador de pagos en modo sandbox/deshabilitado hasta acreditar contrato con PSP, flujos de devolución, medidas antifraude, responsables de datos y conciliacion.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. El link de pago es una capacidad nativa para la facturacion del SaaS y para las ventas de cada negocio. Los dos circuitos monetarios y sus cuentas receptoras son independientes.

FRONTEND	Checkout/enlaces/QR con preview de conceptos y monto, historial y estados precisos.
BACKEND	Enlace pago firmado con expiración, idempotency; PSP por adaptador condicionado; suscripciones separadas.
BASE DE DATOS	PaymentLink, Intent, Transaction, WebhookReceipt, Settlement, Refund, SaaS billing separado.

Prueba de aceptación y riesgo

Positivas / negativas. Enlace expirado falla, webhook falso falla, costo alterado no cambia cobro, doble webhook idempotente.

Control crítico. PSP aún sin elegir y no hay pagos reales en local.

Requisitos de origen que deben rastrearse

CHECKOUT	CREADO, EMITIDO, ABIERTO, PROCESANDO, PAGADO, PARCIAL, VENCIDO, CANCELADO, FALLIDO
ENLACE	BORRADOR, ACTIVO, PAUSADO, VENCIDO, CANCELADO, CONSUMIDO
INTENTO	CREADO, REDIRIGIDO, REQUIERE_ACCION, APROBADO, RECHAZADO, DESCONOCIDO

Fuente completa: 3 tabla(s), 29 filas, 15 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C31-01 Extraer / C31-02 Diseñar / C31-03 Codificar / C31-04 Probar / C31-05 Auditar A / C31-06 Auditar B / C31-07 Auditar C / C31-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Links de pago y suscripciones tenant-specific; webhooks con tenant verificado e idempotencia.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 31, rutas y componentes; 15 parrafos sustantivos y 3 tablas originales (29 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Separar aprobación de presupuesto, orden de compra y autorización de cobro; importes/taxes server-side, conciliación e idempotencia; nunca cobrar automáticamente por comentario.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 32 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

32. Cloudflare R2: gestión segura de imágenes, videos y documentos

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Cloudflare es el proveedor objetivo de almacenamiento de objetos: el VPS ejecuta la aplicación y MySQL almacena metadatos, no bytes binarios de archivos.

R2 guardara imágenes, videos, logos, fotos de productos, archivos de soporte, documentos contractuales, comprobantes, cotizaciones exportadas y material editorial. Cloudflare puede utilizar funciones de entrega/transformacion según plan contratado, pero el almacenamiento principal es R2. Google Drive se reserva para documentos internos del proyecto y decisiones colaborativas, no para archivos transaccionales de clientes.

32.1. Buckets, claves y controles

Clase	Bucket/política	Acceso
Medios publicos	saas-public-media (propuesta)	Solo objetos explicitamente publicados; URL de distribucion con cache aislada.
Documentos privados	saas-private-documents (propuesta)	Autorización backend + descarga temporal. Contratos y datos sensibles.
Videos privados	saas-private-videos (propuesta)	Entrega autenticada según riesgo; URLs no indexables.
Evidencia de seguridad	saas-security-evidence (propuesta)	Auditoría y retención estricta, cifrado y permisos privilegiados.
Respaldos del VPS	saas-offsite-backups (propuesta)	Bucket y credenciales separados; restauracion probada.

Las carpetas prefijadas con tenant son una convencion de organización, NO un mecanismo de control de acceso. Una identidad de servicio con acceso completo al bucket no debe quedar expuesta a ningun navegador. El backend decide el tenant, construye la clave opaca del objeto y solicita una URL temporal para una operación concreta.

Ejemplo de object_key interno: tenants/{tenant_uuid}/products/{asset_uuid}/original.webp. El valor visible no autoriza acceso. Para evitar información sensible en URL, no incluir nombres de clientes, correos, DNI, número de contrato ni titulos secretos en la clave. Registrar asset_id, tenant_id, bucket_id, object_key, mime_real, bytes, hash, clasificacion, visibilidad, propietario, retención, estado y version.

32.2. Ciclo de vida del archivo

01. Crear una upload_session autorizada: tenant, propósito, clase de archivo, cuota disponible, extension y MIME permitidos.
02. Emitir carga temporal con operación y clave especifica o recibir streaming backend; delimitar tamano, checksum y caducidad.
03. Mover al estado CUARENTENA: verificar firma de archivo, contenido, malware, seguridad de imagen/documento y reglas de negocio.
04. Publicar el asset de manera atomica solo tras verificación, registrar su versión y relacionarlo a producto, contrato o página.

05. Exponer por CDN solamente recursos de visibilidad Pública. Los objetos privados pasan por autorización de backend y enlace corto.
06. Al eliminar, marcar retención y ejecutar purga programada cuando legalmente proceda; conservar evidencia de acceso/borrado.

32.3. Advertencias de URLs temporales

Una URL presignada de R2 puede reutilizarse hasta que caduque; no debe describirse como token de un solo uso. Para descargas de uso único o de extrema sensibilidad, crear una autorización consumible en nuestra API y servir/autorizar el objeto bajo esa transacción. Las URLs presignadas de R2 operan contra el endpoint S3 de R2, no se deben asumir compatibles con cualquier dominio personalizado. El tiempo de expiracion y la vinculacion al objeto se generan server-side.

32.4. Cuotas por empresa, rendimiento y seguridad

Métrica	Fuente verdadera	Uso en SuperAdmin
Bytes almacenados	Ledger de assets más conciliacion contra R2.	Por tenant, sucursal, tipo, estado y período.
Uploads/descargas	Eventos de servicio + métrica real del proveedor.	Cuotas, tendencias y alertas por abuso.
Trafico/CDN	Telemetria Cloudflare disponible según plan.	Estimacion atribuida, distinguir de factura real.
Costo de transformacion	Cloudflare Images/Stream si se activan expresamente.	Costos separados y presupuesto; no presuponer gratuidad.
Objetos privados	MediaAsset + registros de acceso.	Acceso de soporte temporal con justificacion.
Retención	Política de datos + legal hold + borrado verificado.	Auditoría de cumplimiento y almacenamiento.
Backups	Job, version, bytes, fecha y prueba restore.	Alertas por RPO/RTO y respaldo fallido.

No se asume capacidad ilimitada o costo fijo. El consumo de R2 se factura por almacenamiento y operaciones; video de alto volumen o transformaciones pueden requerir presupuesto separado. Activar alertas por umbral, límites preventivos por tenant y protección de costos antes de operar con clientes reales.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Cloudflare es el proveedor objetivo de almacenamiento de objetos: el VPS ejecuta la aplicación y MySQL almacena metadatos, no bytes binarios de archivos.

FRONTEND	**Previews de imágenes/Word/Excel/PDF e informes, variantes responsive y gestión de versiones.**
BACKEND	Pipeline seguro upload/scan/convert/preview/download, MIME sniffing, cuarentena, URLs temporales.
BASE DE DATOS	Metadata, MediaVersion, ConversionJob, PreviewAsset, Retention, AccessGrant, Quota.

Prueba de aceptación y riesgo

Positivas / negativas. Sin vista fiel se bloquea descarga UI según política; Office malicioso no ejecuta macros; cross-tenant falla.

Control crítico. Confundir vista previa de nombre de archivo con vista fiel renderizada.

Requisitos de origen que deben rastrearse

MEDIOS PUBLICOS	saas-public-media (propuesta)
DOCUMENTOS PRIVADOS	saas-private-documents (propuesta)
VIDEOS PRIVADOS	saas-private-videos (propuesta)

Fuente completa: 2 tabla(s), 14 filas, 16 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C32-01 Extraer / C32-02 Diseñar / C32-03 Codificar / C32-04 Probar / C32-05 Auditar A / C32-06 Auditar B / C32-07 Auditar C / C32-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Archivo y convertidor de preview en sandbox; sin fetch de media ajena ni macro; retención por tenant.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 32, rutas y componentes; 16 parrafos sustantivos y 2 tablas originales (14 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Adjuntos de caso y fotos con vista previa anterior/posterior, hash, actor, retención, recuperación y firma temporal según alcance; pruebas de filtración de archivos.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 33 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

33. Diccionario relacional MySQL completamente normalizado

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Regla: transacciones, relaciones, catálogos, historiales, derechos y evidencias deben tener entidades propias. No almacenaremos pedidos, reservas, filas de caja o permisos como grandes blobs JSON.

Objetivo: tercera forma normal para hechos operacionales (3FN), con claves foraneas, unicidad, referencias por tenant y controles atomicos. Las proyecciones materializadas para graficos son derivadas y reconstruibles. Un diseño normalizado no significa una tabla por cada campo ni infinitas tablas sin razón: significa atributos con dependencia funcional correcta y sin duplicados de hechos fuente.

33.1. Convenciones fisicas, campos transversales y aislamiento

- En tablas de negocio, PK id BINARY(16) opaco; tenant_id BINARY(16) NOT NULL; tenant_id debe formar parte de FK compuestas y claves unicas cuando existe relacion con otra entidad del tenant. Excepciones globales documentadas.
- Usar InnoDB, utf8mb4 y collation elegida explicitamente; UTC en DATETIME(6), timezone IANA separada para reglas locales; importes DECIMAL(19,4) y moneda ISO 4217.
- Usar referencias externas UUIDv7/ULID o alias opaco con entropia suficiente; ningun identificador sustituye permiso. Secretos QR/link se almacenan como hash y no como texto recuperable.
- Cada tabla transaccional declara PK, FK, índice para tenant+consulta, unicidad relevante, NOT NULL, CHECK cuando aplique, created_at/updated_at y, según necesidad, version optimista, created_by, deleted_at.
- Las tablas globales de identidad no se confunden con las tablas tenant-owned. Una identidad puede pertenecer a multiples negocios; cada pertenencia tiene roles y alcance aislados.
- Nunca deshabilitar foreign_key_checks como ruta normal de aplicación. Las migraciones revisadas cumplen integridad, rollback y readback; prohibidas modificaciones directas a esquemas productivos.
- Un selector comercial obtiene opciones de una entidad catalogo y muestra solo valores activos/autorizados. Los estados de seguridad y las maquinas de estados de pago permanecen definidos y probados en backend.
- No borrar en cascada contratos, facturas, pagos, auditorías, consentimientos ni eventos legales. Utilizar anulacion, versiones, retención y depuracion gobernada.

Control SaaS y empresa

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
platform_users	GLOBAL	id, email_normalized, state_code, registered_at	UQ email; MFA independiente
user_profile	GLOBAL user	user_id, display_name, locale, timezone	FK usuario
user_verified_channels	GLOBAL user	user_id, channel_kind, destination_hash, verified_at	UQ canal verificado
password_credentials	GLOBAL user	user_id, password_hash, changed_at	1:1 credencial actual
passkey_credentials	GLOBAL user	user_id, credential_id, public_key, counter	UQ credential_id
mfa_factors	GLOBAL user	user_id, factor_type, enabled_at, state	clave cifrada, no OTP plano

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
mfa_recovery_codes	GLOBAL user	user_id, code_hash, used_at	código único y hash
password_reset_requests	GLOBAL user	user_id, token_hash, expires_at, consumed_at	propósito y ventana unicos
auth_sessions	GLOBAL user	user_id, session_hash, last_seen_at, revoked_at	revocacion y TTL
refresh_token_families	GLOBAL user	user_id, family_hash, status, rotated_at	replay detection
login_attempts	GLOBAL user	user_id_nullable, ip_prefix, result, occurred_at	retención corta y rate limits
security_alerts	GLOBAL	severity, category, state, detected_at	auditoría protegida
roles	GLOBAL/TENANT	scope_kind, key, display_name, status	UQ scope+key
permission_definitions	GLOBAL	action_key, resource_kind, sensitivity	clave de accion inmutable
role_permission_grants	ROLE	role_id, permission_id, effect	UQ rol+accion
user_role_assignments	TENANT user	tenant_id, user_id, role_id, branch_scope	FK compuesta tenant
user_permission_overrides	TENANT user	tenant_id, user_id, permission_id, reason	caducidad/owner
security_policy_versions	GLOBAL/TENANT	policy_key, version, valid_from	version inmutable
tenants	GLOBAL	id, legal_name, display_name, state, created_at	nombre y tax_id según reglas
business_segments	GLOBAL	id, segment_name, display_order, active	catalogo editable
business_segment_links	TENANT	tenant_id, segment_id, is_primary	UQ tenant+segment
branches	TENANT	tenant_id, id, name, timezone, status	UQ tenant+slug
tenant_domains	TENANT	tenant_id, host, kind, is_primary, status	UQ hostname global
domain_verifications	TENANT	tenant_id, domain_id, challenge_hash, checked_at	sin valores sensibles
business_contact_points	TENANT	tenant_id, branch_id, channel_type, value	visibilidad independiente
business_address	TENANT	tenant_id, branch_id, locality, lat, lng	ubicación privada/pública diferenciada
tenant_capability_entitlements	TENANT	tenant_id, capability_key, contract_id, from_at	UQ tenant+capacidad+período
tenant_feature_settings	TENANT	tenant_id, capability_key, setting_key, typed_value_ref	schema y version
support_access_grants	GLOBAL/TENANT	tenant_id, support_user_id, reason, expires_at	JIT y auditoría

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
platform_demo_tenants	GLOBAL	tenant_id, demo_type, synthetic_only	nunca PII real

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Planes, contratos y facturacion del SaaS

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
saas_plans	GLOBAL	id, code, display_name, active	UQ code
saas_plan_prices	GLOBAL	plan_id, currency, amount, billing_interval	version y vigencia
saas_plan_capabilities	GLOBAL	plan_id, capability_id, limits_ref	FK a capacidades
saas_contracts	TENANT	tenant_id, contract_number, customer_party_id, status	UQ tenant+folio
saas_contract_versions	TENANT	tenant_id, contract_id, version_no, terms_version_id	version inmutable
saas_contract_documents	TENANT	tenant_id, contract_version_id, media_asset_id	documento privado
saas_subscriptions	TENANT	tenant_id, plan_id, state, started_at	tenant y plan vigentes
saas_subscription_periods	TENANT	tenant_id, subscription_id, from_at, to_at	período sin superposicion indebida
saas_subscription_events	TENANT	tenant_id, subscription_id, event_kind, occurred_at	append-only
saas_invoices	TENANT	tenant_id, subscription_id, currency, total, state	UQ tenant+folio
saas_invoice_lines	TENANT	tenant_id, invoice_id, line_no, description, amount	FK factura compuesta
saas_collections	TENANT	tenant_id, invoice_id, transaction_id, amount	conciliacion
saas_renewal_policies	TENANT	tenant_id, subscription_id, renewal_mode, notice_days	con evidencia
tenant_quotas	TENANT	tenant_id, quota_key, limit_value, effective_from	UQ version por período
saas_trial_grants	TENANT	tenant_id, plan_id, starts_at, ends_at	no confundir trial con cobro

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Catalogos y productos

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
catalog_taxonomies	GLOBAL/TENANT	tenant_id_nullable, name, parent_id	arbol validado

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
catalog_categories	TENANT	tenant_id, parent_id_nullable, name, slug	UQ slug por tenant
catalog_items	TENANT	tenant_id, category_id, item_kind, name, state	FK tenant+categoría
item_descriptions	TENANT	tenant_id, item_id, locale, body	UQ item+idioma
product_variants	TENANT	tenant_id, item_id, sku, state	UQ sku por tenant
product_bar_codes	TENANT	tenant_id, variant_id, barcode, symbology	UQ barcode según regla
attribute_definitions	TENANT	tenant_id, name, value_type, scope	catalogo tipado
attribute_options	TENANT	tenant_id, definition_id, option_code, label	UQ por atributo
variant_attribute_values	TENANT	tenant_id, variant_id, definition_id, value_ref	UQ variante+atributo
unit_of_measure	GLOBAL/TENANT	code, precisión, symbol, active	UQ unidad
item_unit_assignments	TENANT	tenant_id, item_id, unit_id, conversion	FK unidad
item_price_lists	TENANT	tenant_id, name, currency, effective_from	version y estado
item_price_entries	TENANT	tenant_id, list_id, item_or_variant_id, amount	UQ precio vigente por objeto
service_offerings	TENANT	tenant_id, item_id, duration_minutes, booking_policy	FK item servicio
service_resource_requirements	TENANT	tenant_id, service_id, resource_type_id, qty	FK al tipo de recurso
service_staff_qualifications	TENANT	tenant_id, service_id, staff_id, enabled	autorización profesional
product_bundles	TENANT	tenant_id, bundle_item_id, state	FK catalogo
product_bundle_lines	TENANT	tenant_id, bundle_id, component_item_id, qty	FK ambos tenant
item_media_assignments	TENANT	tenant_id, item_id, media_id, order_no	FK R2 asset
supplier_item_references	TENANT	tenant_id, item_id, supplier_id, external_ref	FK proveedor
item_publication_rules	TENANT	tenant_id, item_id, channel, visible	version publicación

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Inventarios y compras

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
warehouses	TENANT	tenant_id, branch_id, name, status	UQ nombre por sede
storage_locations	TENANT	tenant_id, warehouse_id, code, capacity	UQ ubicación por bodega
stock_lots	TENANT	tenant_id, variant_id, lot_code, expires_at	UQ lote según item
stock_serial_units	TENANT	tenant_id, variant_id, serial_number, warranty_id	UQ serie por tenant
stock_balances	TENANT	tenant_id, warehouse_id, variant_id, on_hand, reserved	UQ tenant+local+variante
stock_ledger	TENANT	tenant_id, warehouse_id, variant_id, delta, reason	append-only, idempotencia
stock_reservations	TENANT	tenant_id, order_id, variant_id, qty, expires_at	sin reservas negativas
stock_transfers	TENANT	tenant_id, from_warehouse, to_warehouse, status	auditable
stock_transfer_lines	TENANT	tenant_id, transfer_id, variant_id, qty	FK transferencias
stock_counts	TENANT	tenant_id, warehouse_id, counted_at, status	cierre autorizado
stock_count_lines	TENANT	tenant_id, stock_count_id, variant_id, expected, counted	ajuste trazado
suppliers	TENANT	tenant_id, name, tax_id_nullable, status	normalizar contactos
supplier_contacts	TENANT	tenant_id, supplier_id, channel, value	varios contactos
purchase_orders	TENANT	tenant_id, supplier_id, branch_id, status	folio por tenant
purchase_order_lines	TENANT	tenant_id, order_id, variant_id, qty, price	DECIMAL
receiving_notes	TENANT	tenant_id, purchase_order_id, received_at, status	recepciones parciales
receiving_note_lines	TENANT	tenant_id, receiving_id, variant_id, qty	lote/serie por linea
reorder_rules	TENANT	tenant_id, warehouse_id, variant_id, min_qty, target_qty	UQ local+variante
warranty_terms	TENANT	tenant_id, item_id, duration_days, policy_version	version
warranty_cases	TENANT	tenant_id, order_line_id, claim_reason, status	auditoría
repair_orders	TENANT	tenant_id, customer_id, asset_description, status	servicio y pieza
repair_order_tasks	TENANT	tenant_id, repair_id, staff_id, task_state	duracion y consumos

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Pedidos, cotizaciones, caja y cobros

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
customer_orders	TENANT	tenant_id, branch_id, customer_id, total, state	UQ folio por tenant
customer_order_lines	TENANT	tenant_id, order_id, variant_or_service_id, qty, unit_price	snapshot de precio
order_status_events	TENANT	tenant_id, order_id, event_kind, occurred_at	append-only
quotes	TENANT	tenant_id, customer_id, branch_id, status	UQ folio por tenant
quote_versions	TENANT	tenant_id, quote_id, version_number, created_at	inmutable
quote_version_lines	TENANT	tenant_id, version_id, item_id, amount	FK version
checkout_sessions	TENANT	tenant_id, target_document_id, amount_due, currency	referencia a obligacion normalizada
payment_links	TENANT	tenant_id, checkout_id, token_hash, expires_at, state	UQ token_hash, uso gobernado
payment_link_deliveries	TENANT	tenant_id, link_id, channel, delivered_at	sin registrar URL secreta
payment_intents	TENANT	tenant_id, checkout_id, provider_id, status	UQ checkout+intento
payment_attempts	TENANT	tenant_id, intent_id, provider_reference, result	webhook conciliado
payment_provider_events	TENANT	tenant_id, provider_id, event_id, signature_ok	UQ proveedor+evento
payment_receipts	TENANT	tenant_id, checkout_id, amount, currency, occurred_at	no dupl. por PSP
payment_allocations	TENANT	tenant_id, receipt_id, obligation_id, amount	saldo no negativo
payment_refunds	TENANT	tenant_id, receipt_id, amount, reason, state	aprobacion y PSP
payment_reconciliation	TENANT	tenant_id, provider_id, period_id, matched_count	evidencia y diferencias
payment_methods	GLOBAL/TENANT	id, method_kind, active, config_ref	config sin secretos en claro
merchant_payment_accounts	TENANT	tenant_id, provider_id, encrypted_reference, status	separar cuenta del SaaS
cash_registers	TENANT	tenant_id, branch_id, register_code, enabled	UQ código por sede
cash_sessions	TENANT	tenant_id, register_id, opened_by, opened_at, status	cierre y arqueo

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
cash_movements	TENANT	tenant_id, session_id, movement_kind, amount	actor y evidencia
returns	TENANT	tenant_id, order_id, reason_code, state	reglas por política
return_lines	TENANT	tenant_id, return_id, order_line_id, qty	no exceder venta original
shipping_deliveries	TENANT	tenant_id, order_id, method_id, state	dirección separada
point_of_sale_devices	TENANT	tenant_id, branch_id, name, device_hash	credenciales revocables

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Agenda, QR y membresias universales

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
business_operating_hours	TENANT	tenant_id, branch_id, weekday, opens_at, closes_at	multiples bloques por día
holiday_calendar_dates	TENANT	tenant_id, branch_id, local_date, holiday_kind	prioridad de excepción
schedule_overrides	TENANT	tenant_id, branch_id, effective_from, effective_to	cierre/extension
staff_profiles	TENANT	tenant_id, user_id, display_name, active	FK membresia
staff_shifts	TENANT	tenant_id, staff_id, branch_id, starts_at, ends_at	validar descanso
staff_absences	TENANT	tenant_id, staff_id, starts_at, ends_at, absence_kind	causa privada
resources	TENANT	tenant_id, branch_id, resource_kind_id, display_name	ej mesa/cabina/bahia
resource_categories	TENANT	tenant_id, name, capacity, active	catalogo editable
resource_qualification_links	TENANT	tenant_id, resource_id, service_id, enabled	FK servicio
availability_holds	TENANT	tenant_id, resource_id, slot_from, slot_to, expiry	bloqueo transaccional
resource_slot_locks	TENANT	tenant_id, resource_id, slot_start, booking_id	UQ recurso+intervalo
bookings	TENANT	tenant_id, customer_id, service_id, start_utc, end_utc, status	sin doble reserva
booking_resources	TENANT	tenant_id, booking_id, resource_id, role	FK compuestas
booking_staff_assignments	TENANT	tenant_id, booking_id, staff_id, assignment	turno validado

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
booking_events	TENANT	tenant_id, booking_id, event_type, occurred_at	append-only
class_sessions	TENANT	tenant_id, branch_id, service_id, capacity, start_utc	academia/gym/otros
class_enrollments	TENANT	tenant_id, class_id, customer_id, state	UQ clase+cliente
membership_plans	TENANT	tenant_id, name, billing_rule_id, status	disponible en todo rubro
membership_plan_benefits	TENANT	tenant_id, plan_id, benefit_id, limit_value	entitlements
membership_contracts	TENANT	tenant_id, customer_id, plan_id, state	contrato separado
membership_periods	TENANT	tenant_id, membership_id, starts_at, ends_at	sin períodos erroneos
membership_events	TENANT	tenant_id, membership_id, event_kind, time_utc	upgrade/pause/renewal
membership_fees	TENANT	tenant_id, membership_id, fee_kind, amount, due_date	mantenimiento etc
membership_entitlements	TENANT	tenant_id, membership_id, resource_scope, allowed_uses	evaluación por servidor
membership_usage_ledger	TENANT	tenant_id, entitlement_id, qty_used, occurred_at	append-only
qr_credentials	TENANT	tenant_id, purpose, token_hash, expires_at	aleatorio y hash
qr_redemptions	TENANT	tenant_id, credential_id, device_id, occurred_at	UQ para uso único
gate_devices	TENANT	tenant_id, branch_id, device_key_hash, state	scopes y rotacion
access_attempts	TENANT	tenant_id, device_id, credential_id, result	auditoría antireplay

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

CRM, experiencia, empleados

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
business_customers	TENANT	tenant_id, id, display_name, created_at	UQ tenant+ref pública
customer_portal_links	TENANT	tenant_id, customer_id, user_id, verified_at	pertenencia sin fusion
customer_contacts	TENANT	tenant_id, customer_id, contact_kind, value	consentimiento
customer_addresses	TENANT	tenant_id, customer_id, address_type, locality	visibilidad

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
customer_history_events	TENANT	tenant_id, customer_id, event_kind, subject_id, occurred_at	append-only y permisos
customer_favorites	TENANT	tenant_id, customer_id, resource_type, resource_id	validación pertenencia
customer_preferences	TENANT	tenant_id, customer_id, preference_key, selected_option	sin revelar PII ajena
customer_feedback	TENANT	tenant_id, customer_id, interaction_id, rating, created_at	elegibilidad verificada
employee_customer_incidents	TENANT	tenant_id, customer_id, staff_id, evidence_ref, state	hechos objetivos, revisión
employee_performance_events	TENANT	tenant_id, staff_id, related_order_id, metric_kind	sin evaluación arbitraria
staff_commission_rules	TENANT	tenant_id, staff_id, rule_ref, effective_at	contrato y aprobacion
staff_commission_entries	TENANT	tenant_id, staff_id, order_line_id, amount, state	devolución revierte
support_cases	TENANT	tenant_id, customer_id, category, state, owner	acceso especifico
support_case_messages	TENANT	tenant_id, case_id, sender_id, body, sent_at	privacy label
business_reviews	TENANT	tenant_id, customer_id, interaction_id, rating, state	moderacion objetiva
review_moderation_events	TENANT	tenant_id, review_id, action, reason, moderator_id	historial inmutable
complaints	TENANT	tenant_id, customer_id, order_id_nullable, issue, state	SLA y apelacion

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Promociones, marketing y redes

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
promotional_campaigns	TENANT	tenant_id, name, starts_at, ends_at, status	version y audiencia
campaign_channel_targets	TENANT	tenant_id, campaign_id, channel_id, enabled	por red
loyalty_programs	TENANT	tenant_id, name, rule_version, status	por empresa
loyalty_accounts	TENANT	tenant_id, customer_id, program_id, state	UQ cliente+programa
loyalty_ledger	TENANT	tenant_id, loyalty_account_id, delta, event_id	append-only
rewards	TENANT	tenant_id, program_id, benefit_id, status	restricciones

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
reward_redemptions	TENANT	tenant_id, reward_id, customer_id, token_hash	UQ token uso único
coupons	TENANT	tenant_id, code_hash, campaign_id, valid_until	no fuga de código privado
coupon_redemptions	TENANT	tenant_id, coupon_id, customer_id, order_id	max uso
wallet_passes	TENANT	tenant_id, customer_id, pass_kind, provider_ref	reconcilacion
social_accounts	TENANT/GLOBAL	tenant_id_nullable, channel, remote_id, state	tokens en secret store
social_posts	TENANT/GLOBAL	tenant_id_nullable, author_id, scheduled_at, state	contenido versionado
social_post_targets	TENANT/GLOBAL	post_id, social_account_id, channel_state	estado por red
social_publication_attempts	TENANT/GLOBAL	target_id, attempted_at, result, external_post_id	idempotencia
social_message_threads	TENANT/GLOBAL	account_id, external_thread_ref, state	consentimientos
social_messages	TENANT/GLOBAL	thread_id, direction, message_type, created_at	metadatos seguros
auto_reply_rules	TENANT/GLOBAL	account_id, trigger_id, template_id, priority	sin loops
message_templates	TENANT/GLOBAL	account_id, language, content, approval_state	restricciones PSP/social
message_deliveries	TENANT/GLOBAL	thread_id, template_id, delivery_state, sent_at	opt-out y límites
marketing_opt_ins	TENANT/GLOBAL	subject_id, purpose_id, channel, granted_at	retiro verificable

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

CMS, apariencia, Cloudflare R2 y mapas

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
media_assets	TENANT/GLOBAL	tenant_id_nullable, bucket_id, object_key, mime, size_bytes	UQ bucket+key
media_versions	TENANT/GLOBAL	asset_id, version_no, checksum, uploaded_at	append-only
media_asset_attachments	TENANT	tenant_id, media_id, owner_kind, owner_id	tenant+propietario
media_upload_sessions	TENANT	tenant_id, requester_id, object_key, expires_at	un uso/limite
media_access_events	TENANT	tenant_id, media_id, actor_id, action, at	retención

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
media_quota_snapshots	TENANT	tenant_id, period, bytes_total, source	conciliacion R2
media_retention_rules	TENANT/GLOBAL	class_id, retention_days, legal_hold_policy	version de política
cms_pages	TENANT/GLOBAL	tenant_id_nullable, slug, page_kind, status	slug único por sitio
cms_page_versions	TENANT/GLOBAL	page_id, version_no, created_by, created_at	publicación inmutable
cms_blocks	TENANT/GLOBAL	page_version_id, component_kind, position, schema_version	tipado y validado
cms_block_properties	TENANT/GLOBAL	block_id, property_key, typed_value_ref	schema permitido
site_theme_tokens	TENANT/GLOBAL	theme_id, token_key, token_value, version	contraste validado
font_library	TENANT/GLOBAL	tenant_id_nullable, family, source_asset_id, license_ref	fuentes seguras
site_publications	TENANT/GLOBAL	page_id, version_id, published_at, rollback_ref	atomica
navigation_menus	TENANT/GLOBAL	tenant_id_nullable, site_id, location, state	público/admin separadas
navigation_menu_items	TENANT/GLOBAL	menu_id, parent_id, target_id, position	no permisos ocultos
location_parking_options	TENANT	tenant_id, branch_id, parking_kind, visible	visibilidad discreta
location_route_notes	TENANT	tenant_id, branch_id, locale, body, visible	sin GPS indebido
dashboard_layouts	TENANT/GLOBAL	tenant_id_nullable, owner_user_id, scope, version	publicación propia
dashboard_widgets	TENANT/GLOBAL	layout_id, widget_kind, position, config_ref	datos filtrados backend

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

Legal, analítica, operaciones e integraciones

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
legal_documents	TENANT/GLOBAL	tenant_id_nullable, kind, locale, state	tipo y alcance
legal_document_versions	TENANT/GLOBAL	document_id, version_no, body_asset_id, effective_at	inmutable
legal_acceptances	TENANT/GLOBAL	document_version_id, subject_id, accepted_at, evidence	version exacta
consent_purposes	TENANT/GLOBAL	tenant_id_nullable, name, retention_rule_id, active	separado marketing

Tabla	Ambito / referencia	Campos obligatorios (base)	Indices y restricciones
consent_records	TENANT/GLOBAL	subject_id, purpose_id, granted_at, revoked_at	historia
subject_right_requests	TENANT/GLOBAL	tenant_id_nullable, subject_id, request_kind, status	auditar plazos
retention_policies	TENANT/GLOBAL	tenant_id_nullable, data_class, days, legal_basis	version
financial_movements	TENANT/GLOBAL	tenant_id_nullable, movement_kind, amount, occurred_at	distinguir saldos
business_expenses	TENANT	tenant_id, branch_id, category_id, amount, occurred_at	permiso financiero
expense_categories	TENANT	tenant_id, name, status	catalogo editable
metric_definitions	GLOBAL/TENANT	metric_key, formula_version, unit, classification	documentar formula
metric_snapshots	TENANT/GLOBAL	tenant_id_nullable, metric_id, period, value	proyeccion derivada
export_jobs	TENANT/GLOBAL	tenant_id_nullable, actor_id, report_id, created_at	scopes y enlace privado
audit_events	TENANT/GLOBAL	tenant_id_nullable, actor_id, action, resource_ref, occurred_at	append-only
outbox_events	TENANT/GLOBAL	tenant_id_nullable, event_key, payload_ref, state	en misma transacción
inbox_dedup_events	TENANT/GLOBAL	tenant_id_nullable, external_event_id, received_at	UQ proveedor+id
job_executions	TENANT/GLOBAL	tenant_id_nullable, job_kind, started_at, status	reties y trazas
api_clients	TENANT/GLOBAL	tenant_id_nullable, client_key_hash, scopes, status	no llaves claras
webhook_subscriptions	TENANT/GLOBAL	tenant_id_nullable, callback_url, event_kind, state	SSRF y firma
webhook_deliveries	TENANT/GLOBAL	subscription_id, event_id, state, attempt_no	idempotente
backup_runs	GLOBAL	backup_kind, produced_at, object_ref, verified_at	prueba restore
deployment_runs	GLOBAL	git_sha, environment, status, deployed_at	SHA CI exacto
ops_incidents	GLOBAL	severity, incident_type, opened_at, status	pista auditable
security_incident_actions	GLOBAL	incident_id, actor_id, action_kind, occurred_at	conservar evidencia

Especificacion lógica: los nombres definitivos, tipos concretos y tablas fisicas se certificaran con migraciones EF Core y revisión de modelo. Las claves de permiso/tenancy son obligatorias en las relaciones aplicables.

33.2. Contratos fisicos de tablas criticas

Las siguientes definiciones son el contrato mínimo de estructuras clave. El DDL final derivara de migraciones revisadas, no de generacion libre en ejecucion. PK y FK compuestas evitan vincular una factura de un tenant con un cliente de otro. En tablas compartidas de identidad global, la autorización se decide por memberships, no por descubrir la cuenta.

Contrato: tenants

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	ID interno opaco; no se presenta como permiso.
legal_name	VARCHAR(180)	NOT NULL	Denominacion para contratos.
display_name	VARCHAR(160)	NOT NULL	Marca comercial visible.
state_code	VARCHAR(24)	NOT NULL	Maquina de estados gobernada.
created_at_utc	DATETIME(6)	NOT NULL	Alta verificable.
created_by	BINARY(16)	FK platform_users	Actor con permiso.

Contrato: platform_users

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Cuenta global sin tenant fijo.
email_normalized	VARCHAR(254)	UQ NOT NULL	No confundir mayusculas.
account_state	VARCHAR(24)	NOT NULL	Bloqueo y recuperación.
security_stamp	BINARY(16)	NOT NULL	Invalida sesiones.
registered_at_utc	DATETIME(6)	NOT NULL	Traza de alta.

Contrato: tenant_memberships

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Membresia persona-tenant.
tenant_id	BINARY(16)	FK NOT NULL	Referencia a tenants.
user_id	BINARY(16)	FK NOT NULL	Referencia a platform_users.
membership_state	VARCHAR(24)	NOT NULL	Solo vigente puede actuar.
valid_from_utc	DATETIME(6)	NOT NULL	Inicio.
valid_to_utc	DATETIME(6)	NULL	Fin eventual; UQ/ventanas.

Contrato: business_customers

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	ID interno.

Campo	Tipo MySQL	Integridad	Uso / validación
tenant_id	BINARY(16)	FK NOT NULL	Aislamiento tenant.
display_name	VARCHAR(180)	NOT NULL	Identificación comercial.
customer_ref	VARCHAR(32)	UQ (tenant_id,customer_ref)	Código público no secreto.
created_at_utc	DATETIME(6)	NOT NULL	Alta.
deleted_at_utc	DATETIME(6)	NULL	Borrado gobernado.

Contrato: bookings

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Reserva.
tenant_id	BINARY(16)	FK NOT NULL	Tenant obligatorio.
customer_id	BINARY(16)	FK compuesta	(tenant_id, customer_id) valido.
service_id	BINARY(16)	FK compuesta	Servicio del mismo tenant.
start_utc	DATETIME(6)	NOT NULL	Inicio en UTC.
end_utc	DATETIME(6)	NOT NULL	Fin posterior.
status_code	VARCHAR(24)	NOT NULL	Estado permitido.
idempotency_hash	BINARY(32)	UQ tenant+hash	No duplicar confirmacion.

Contrato: membership_contracts

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Contrato de cliente con negocio.
tenant_id	BINARY(16)	FK NOT NULL	Aislamiento.
customer_id	BINARY(16)	FK compuesta	Titular valido.
plan_id	BINARY(16)	FK compuesta	Plan ofertado por tenant.
state_code	VARCHAR(24)	NOT NULL	Activo, gracia, suspendido...
started_at_utc	DATETIME(6)	NOT NULL	Inicio.
current_period_id	BINARY(16)	FK compuesta nullable	Período vigente; evitar ciclo con control.

Contrato: payment_links

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Link emitido.
tenant_id	BINARY(16)	FK NOT NULL	Cuenta receptora tenant.
checkout_id	BINARY(16)	FK compuesta	Monto y obligacion congelados.
public_token_hash	BINARY(32)	UQ NOT NULL	Nunca almacenar token claro.

Campo	Tipo MySQL	Integridad	Uso / validación
link_state	VARCHAR(24)	NOT NULL	FSM gobernada.
max_redemptions	SMALLINT UNSIGNED	NOT NULL	Por defecto uno.
redeemed_count	SMALLINT UNSIGNED	NOT NULL	CHECK <= max.
expires_at_utc	DATETIME(6)	NOT NULL	TTL.
created_by	BINARY(16)	FK	Auditoría.

Contrato: media_assets

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Asset.
tenant_id	BINARY(16)	FK nullable solo global	Tenant propietario.
bucket_key	VARCHAR(60)	NOT NULL	Bucket en Cloudflare R2.
object_key	VARCHAR(512)	UQ bucket+key	Objeto sin datos personales.
mime_detected	VARCHAR(100)	NOT NULL	Tipo real validado.
content_sha256	BINARY(32)	NOT NULL	Integridad.
size_bytes	BIGINT UNSIGNED	NOT NULL	Cuotas y consumo.
visibility_code	VARCHAR(24)	NOT NULL	Público o PRIVADO.
scan_state	VARCHAR(24)	NOT NULL	Cuarentena o publicado.

Contrato: qr_credentials

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Token con finalidad.
tenant_id	BINARY(16)	FK NOT NULL	Aislamiento.
token_hash	BINARY(32)	UQ NOT NULL	Antifraude, no secreto claro.
purpose_code	VARCHAR(36)	NOT NULL	Check-in, premio, acceso etc.
valid_from_utc	DATETIME(6)	NOT NULL	Inicio.
expires_at_utc	DATETIME(6)	NOT NULL	Fin.
max_uses	INT UNSIGNED	NOT NULL	Uso único o varias entradas.
current_uses	INT UNSIGNED	NOT NULL	Transaccional.
revoked_at_utc	DATETIME(6)	NULL	Revocacion.

Contrato: audit_events

Campo	Tipo MySQL	Integridad	Uso / validación
id	BINARY(16)	PK	Evento append-only.

Campo	Tipo MySQL	Integridad	Uso / validación
tenant_id	BINARY(16)	NULL solo global	Contexto.
actor_user_id	BINARY(16)	FK nullable actor sistema	No fingir actor humano.
action_key	VARCHAR(100)	NOT NULL	Accion canonica.
subject_ref	VARCHAR(100)	NOT NULL	Recurso afectado.
occurred_at_utc	DATETIME(6)	NOT NULL	UTC.
correlation_id	BINARY(16)	NOT NULL	Traza.
metadata_safe_ref	BINARY(16)	NULL	Sin secretos/PII cruda.

33.3. Ejemplo de integridad entre tenants

Para clientes, un índice UNIQUE (tenant_id, id) habilita FOREIGN KEY (tenant_id, customer_id) REFERENCES business_customers(tenant_id, id) en bookings. El mismo modelo se aplica a productos, facturas, servicios, adjuntos y permisos. Un FK simple customer_id -> business_customers(id) NO demuestra que el cliente sea del tenant de la reserva.

Por razones tecnicas de MySQL: CHECK no puede comparar registros de otras tablas; restricciones de disponibilidad y validación de derechos se realizan mediante transacciones InnoDB y locks. La API no puede aceptar tenant_id del cliente como autoridad. Al confirmar agenda, se bloquean de forma estable los slots o recursos atomicos; se deben probar duraciones variables, cambios de horario y requests concurrentes.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Regla: transacciones, relaciones, catálogos, historiales, derechos y evidencias deben tener entidades propias. No almacenaremos pedidos, reservas, filas de caja o permisos como grandes blobs JSON.

FRONTEND	**Formularios y catálogos generados desde DTOs versionados; validación UX reutilizable.**
BACKEND	Entidades y mapping explícitos por módulo, no repositorio genérico omnipotente.
BASE DE DATOS	Diccionario relacional completo, claves compuestas por tenant, migraciones, restricciones y 3FN.

Prueba de aceptación y riesgo

Positivas / negativas. FK, UNIQUE, CHECK, índice y migración en DB local real; reproducir casos de concurrencia.

Control crítico. Lógica editable en DB, inconsistencias referenciales, consultas sin tenant.

Requisitos de origen que deben rastrearse

PLATFORM_USERS	GLOBAL
USER_PROFILE	GLOBAL user
USER_VERIFIED_CHANNELS	GLOBAL user

Fuente completa: 20 tabla(s), 316 filas, 46 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C33-01 Extraer / C33-02 Diseñar / C33-03 Codificar / C33-04 Probar / C33-05 Auditar A / C33-06 Auditar B / C33-07 Auditar C / C33-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Todas las 3FN/FK/indices tenant-owned, auditoría y placement mapeados; migraciones SHARED/DEDICATED parity.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 33, rutas y componentes; 46 parrafos sustantivos y 20 tablas originales (316 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Normalizar Case, TimelineEvent, CheckIn, Diagnosis, QuoteVersion/Line, ApprovalRequest/Decision, Attachment, Delivery, Closure, WorkflowVersion, Outbox con FK (tenant_id,id) e índices medidos; probar SQL real.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 34 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

34. Formularios completos y tablas de gestión estandarizadas

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Cada entidad debe tener una ficha con campos obligatorios, validaciones, relaciones, permisos, trazabilidad y visibilidad. Ningun formulario termina en un nombre y un boton sin identidad comercial, contexto y reglas.

La plataforma proveera un motor de formularios basado en definiciones versionadas y un registro de componentes seguros. Una plantilla propone campos por rubro; el administrador puede configurar campos complementarios y el diseño, pero no omitir campos legalmente obligatorios ni mutar tipos que rompan datos existentes. Los selectores de negocio se alimentan de catalogos administrables desde MySQL y API; las transiciones de seguridad, dinero y contratos siguen siendo validaciones del backend.

34.1. Matriz de captura mínima por pantalla

Pantalla / entidad	Información completa requerida	Validaciones y seguridad
Alta de empresa	Nombre comercial y legal, categoría principal, pais, moneda, zona horaria, contacto, responsable, sucursal, modalidad dominio, plan, terminos.	Identidad legal, email confirmado, dominio verificado; nunca asignar permisos por nombre.
Sucursal	Nombre, dirección, referencia, lat/lng opcionales, zona horaria, telefonos, horarios, estacionamiento, estado.	Geocodificacion optativa y visibilidad por campo.
Empleado	Identidad, contacto, rol, permisos, sedes, turnos, servicios habilitados, estado laboral.	Invitacion segura; datos financieros solo con permiso.
Cliente comercial	Nombre, contacto, documento cuando aplique, origen, consentimiento, preferencia, observaciones.	Minimizacion; no exigir ID sensible sin finalidad.
Plan de membresia	Nombre, duracion, precio, moneda, cuotas, reglas, sedes, recursos, beneficios, congelamientos.	Validar derechos y vigencia; prorrata documentada.
Inscripcion a membresia	Cliente, plan, período, cuota inicial, método pago, contrato aceptado, beneficiarios.	Ningun acceso sin entitlements efectivos y autorización.
Credencial / QR	Propietario, finalidad, sede/recurso, inicio, fin, usos maximos, política de verificación.	Token aleatorio hash, revocable, dispositivo confiable.
Servicio	Nombre, categoría, detalles, duracion, tarifas, impuestos, sedes, profesionales, recursos, imágenes.	Disponibilidad calculada; precio decidido en servidor.
Producto	Nombre, rubro, categoría, marca, SKU, variantes, unidad, stock, precio, impuestos, medios, garantia.	Variante y SKU validos; no romper existencias.
Categoría	Nombre, slug, padre opcional, orden, estado, visibilidad.	Sin ciclos jerarquicos, slug único tenant.

Pantalla / entidad	Información completa requerida	Validaciones y seguridad
Variante	Atributos tipados, talla/color/modelo, código barras, precio, media, estado.	Unicidad combinacion de atributos y SKU.
Compra	Proveedor, bodega destino, sucursal, fecha, partidas, cantidades, moneda, impuestos, aprobacion.	Recepcion parcial y stock ledger.
Venta/POS	Caja, sede, cliente opcional, partidas, descuentos, impuestos, moneda, medio pago, entrega.	Totales backend, descuentos autorizados, stock atomico.
Cotización	Cliente, vigencia, items/servicios, cantidades, condiciones, impuesto, descuento, firma/aceptacion.	Versiones, conversion sin cambiar historial.
Devolución	Venta origen, lineas, cantidad, motivo, estado físico, método reembolso, aprobador.	No exceder venta, impacto stock/finanzas.
Garantia	Articulo/serie, factura, cobertura, fecha, motivo, evidencia, resolucion.	Plazos y estado documentados.
Reserva	Cliente, sede, servicio, inicio, duracion, profesional/recurso, estado, anticipo, política.	Slot-locks en MySQL y cambios auditados.
Horario	Sucursal, día, bloques apertura/cierre, festivos, excepciones, area/servicio.	Zona horaria y turnos nocturnos sin ambiguedad.
Clase/curso	Servicio, sede, instructor, cupos, calendario, tarifa, requisito, recursos, inscripciones.	Aforo y derecho de membresia opcional.
Mesa/espacio	Sucursal, código de mesa, zona, aforo, QR público, estado, limite y horarios.	QR de mesa no otorga autorización de pago.
Pedido	Cliente o mesa, consumo local/llevar, items, modificadores, estatus, destino, total.	Recalculo, deduplicacion y confirmacion durable.
Promoción	Nombre, período, tipo, alcance, reglas, cupos, publicación y medios.	No reusar recompensas canjeadas.
Fidelidad	Programa, regla acumulacion, niveles, beneficios, costos, vigencias, sede, consentimiento.	Ledger independiente y canje transaccional.
Enlace de pago	Obligacion, importe/moneda, cliente, vencimiento, max usos, canal envio, cuenta receptora.	Token secreto, PSP firmado, conciliacion, no doble cobro.
Caja	Sede, dispositivo, apertura, operador, fondo inicial, movimientos, arqueo, cierre.	Arqueos, permisos, diferencias y auditoría.
Gasto	Categoría, proveedor opcional, monto, moneda, fecha, centro costo, comprobante y aprobador.	Permiso financiero y evidencias.
Campana/red social	Canal, cuenta, material, audiencia, calendario, consentimiento, responsable, aprobacion.	API oficial, tokens cifrados y estado por canal.
Mensaje automático	Canal, disparador, ventana, plantilla aprobada, idioma, respuesta, frecuencia.	Opt-out, condiciones proveedor, anti-loop.
Resena	Interacción elegible, autor, calificación, criterios, texto, visibilidad, estado moderacion.	Sin sesgo/discriminacion ni supresion engañosa.

Pantalla / entidad	Información completa requerida	Validaciones y seguridad
Incidente de cliente	Interacción real, empleado, hechos verificables, evidencia, supervisor y estado revisión.	Privado, proporcional, derecho impugnacion.
Tema visual	Paleta, tipografia, componentes, imágenes, disposicion, responsive, visibilidad, version.	Preview, validación contraste y rollback.
Página pública	Ruta, titulo SEO, secciones, meta, imagen, idioma, CTA, medios y estado.	Solo bloques seguros y autorizados.
Archivo	Tenant, clase, finalidad, version, tipo, tamano, visibilidad, retención, entidad destino.	Scanner, cuarentena y autorización R2.
Contrato SaaS	Empresa, plan, período, moneda, terminos, documentos, firmantes, renovacion.	Firmas/versiones/evidencia inmutable.
Política y consentimiento	Tipo, version, idioma, finalidades, vigencia, estado de publicación.	Opt-in independiente y revocable.
Usuario SuperAdmin	Identidad, rol global, MFA, estado, motivo de acceso excepcional.	Acceso JIT, sin lectura irrestricta de PII.
Contacto y mapa	Dirección, zona, parking, rutas, redes, WhatsApp, horarios y reglas de visibilidad.	Publicar solo campos autorizados.
Soporte/queja	Cliente, asunto, prioridad, adjuntos, responsables, respuesta y resolucion.	Acceso mínimo y auditoría.
Plan comercial de SaaS	Nombre, precio, vigencia, modalidad dominio, cupos, funcionalidades, condiciones.	Version de plan sin alterar contratos anteriores.

34.2. Reglas de tablas visuales y componentes

Componente	Contrato de experiencia	Seguridad y accesibilidad
Tabla CRUD completa	Columnas configurables, anchos, filtros, orden, busqueda, paginado server-side, guardar vistas, selección multiple y exportacion.	Consulta y acciones autorizadas, redaccion PII, evitar cargar toda la BD al cliente.
Columna acciones	Iconos estandarizados para ver, editar, suspender, reactivar, historial, duplicar y eliminar según rol.	Tooltip, nombre accesible, foco, confirmacion destructiva y menu móvil.
Selector administrable	Opciones de catalogos MySQL, orden, dependencia, activo, version y traduccion.	Solo administradores con permiso de catalogo; FK referencial.
Modal de detalle	Vista rica con tabs, multimedia, datos por secciones, campos relacionados y audit trail.	Escapar HTML, autorizar por recurso, scroll y focus trap.
Formulario	Secciones, ayuda contextual, validación inline, autoguardado de borrador permitido.	No mostrar campos sin autorización y revalidar servidor.
Grafico dinámico	Elegir fecha, dimension, filtros, desgloses, comparador, definición y exportacion.	Agregados con política de privacidad, ACL y carga eficiente.
Constructor visual	Arrastrar/soltar, ordenar por teclado, cambiar tema, vista previa y publicación versionada.	Sin ejecutar JS arbitrario; esquemas tipados y autorización de publicación.
Galeria/medios	Subir, crop, elegir variantes, ordenar, publicar/ocultar, reemplazar, auditar uso.	R2, escaneo, quota, no contenido cruzado.

Componente	Contrato de experiencia	Seguridad y accesibilidad
Historial	Timeline legible de quien, cuando, que cambio, estado anterior/nuevo.	Redaccion de secretos, paginado y retención.
Estado	Badge semantico + texto visible para claridad de acciones; filtros sobre estado.	No depender solo del color o icono.
Ayuda y onboarding	Asistente por rubro; progress, ejemplos sinteticos, checklist y vista previa.	No escribir credenciales ni datos reales en demo.

La regla preferente para acciones compactas es boton iconografico, con tooltip en escritorio y nombre accesible para tecnologia asistiva; en móvil usar etiqueta accesible, accion de largo toque o menu contextual. No esconder información fundamental solo en hover. Pagos, borrados, cancelaciones y permisos peligrosos requieren confirmaciones expresas, claridad textual y registro.

34.3. Contratos de campos configurables sin romper normalizacion

- Cada campo dinámico tiene definición: field_key estable, data_type, label, catalog_ref, required_rule, sensitive_level, validation_schema, owner, tenant_scope, UI component y version.
- Los valores multivaluados se guardan en tablas de relaciones, no en cadenas separadas por comas. Atributos heterogeneos pueden usar tablas de valor tipadas, no un campo JSON sin esquema.
- Cambiar tipo o regla requiere migracion de datos/revisión de impacto; campos historicos en documentos conservan snapshot firmado o versionado.
- Importaciones masivas se validan primero en staging aislado, reportan errores fila a fila y nunca desactivan claves foraneas.
- Exigir formularios por sector para datos fisicos relevantes (p.ej., VIN de vehiculo, número de serie de reloj) sin obligar a otro sector a rellenarlos.
- Las pantallas de administración central solo pueden cambiar configuraciones habilitadas por el contrato. Un form builder no puede otorgar privilegios.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Cada entidad debe tener una ficha con campos obligatorios, validaciones, relaciones, permisos, trazabilidad y visibilidad. Ningun formulario termina en un nombre y un boton sin identidad comercial, contexto y reglas.

FRONTEND	**Sistema estándar de formularios CRUD, tablas avanzadas, búsqueda, filtros, modales, previews y descarga.**
BACKEND	Paginación segura, filtros autorizados, validación por intención y acciones pequeñas.
BASE DE DATOS	Catálogos tipados/normalizados y persisted view preferences por usuario y tenant.

Prueba de aceptación y riesgo

Positivas / negativas. Todos los modales XS–XL accesibles, preview antes y después, tabla móvil sin truncado peligroso.

Control crítico. Variaciones ad hoc de UX, formularios sin permisos y componentes muy pesados.

Requisitos de origen que deben rastrearse

ALTA DE EMPRESA	Nombre comercial y legal, categoría principal, pais, moneda, zona horaria, contacto, responsable, sucursal, modalidad dominio, plan, terminos.
SUCURSAL	Nombre, dirección, referencia, lat/lng opcionales, zona horaria, telefonos, horarios, estacionamiento, estado.
EMPLEADO	Identidad, contacto, rol, permisos, sedes, turnos, servicios habilitados, estado laboral.

Fuente completa: 2 tabla(s), 52 filas, 12 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C34-01 Extraer / C34-02 Diseñar / C34-03 Codificar / C34-04 Probar / C34-05 Auditar A / C34-06 Auditar B / C34-07 Auditar C / C34-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Formularios/metadatos/CSV/DOCX/XLSX revisan scope, preview autorizado, exports y modales XS-XL.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 34, rutas y componentes; 12 parrafos sustantivos y 2 tablas originales (52 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Formularios completos de check-in, diagnóstico, presupuesto, aceptación parcial, observaciones, entrega y cierre, modales estandarizados, teclado/contraste y previews. UC-036..040.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 35 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

35. Plataformas definitivas: cuatro proveedores y una sola arquitectura

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Infraestructura base confirmada: GitHub, Google Drive, Cloudflare y VPS Hostinger. El frontend, backend, workers y MySQL viven en el VPS; Cloudflare R2 guarda todos los medios y documentos.

Plataforma	Responsabilidad definitiva	No se utiliza para
GitHub	Repositorio privado único del producto; PR, issues, revisiones, CI/CD, releases y artefactos.	Guardar datos de clientes ni secretos.
Google Drive	Documentación administrativa del proyecto, especificaciones, decisiones, actas y colaboracion.	Base de datos transaccional ni adjuntos privados de clientes.
Cloudflare	R2 para todos los archivos/medios; DNS, TLS/CDN/WAF si se configuran; observabilidad de trafico.	Ejecutar la lógica principal ni almacenar credenciales sin gobierno.
Hostinger VPS	Contenedores Docker: Angular público, Angular admin, ASP.NET API, worker, reverse proxy, MySQL y seguridad operativa.	Suponer alta disponibilidad por tener contenedores separados.

35.1. Topologia lógica de Hostinger

Internet -> Cloudflare DNS/WAF (según configuración) -> Reverse proxy HTTPS del VPS -> frontend Angular público / frontend Angular administrativo -> API ASP.NET Core -> módulos de dominio -> MySQL privado. Worker interno procesa outbox, webhooks, correos y tareas. El backend usa credenciales minimas para R2; el browser recibe solo autorizaciones de carga/descarga estrictamente acotadas. La administración por SSH utiliza cuentas restringidas, llaves y acceso protegido.

Red pública: solo 80/443 (ideal redireccion a 443); puerto SSH limitado por firewall y acceso administrativo. Red app: frontend, reverse proxy, backend y workers. Red db: MySQL sin published ports. Almacenamiento MySQL persistente en volumen controlado y respaldado; config/secrets fuera de imagen y repositorio; credenciales de R2 y PSP con rotacion y alcances minimos.

35.2. Desarrollo veloz sin sacrificar las puertas criticas

01. Una rama por microtarea con alcance pequeno, criterio de aceptacion verificable, pruebas, rollback y evaluación de riesgo.
02. Pruebas rapidas en cada PR: build Angular y .NET, analisis estatico, prueba de unit, integración MySQL efimera, autorización cruzada, migrations dry-run y auditoría de secretos.
03. Docker Compose para paridad local/test/VPS, con diferencias documentadas en secretos, certificados, backup, red y recursos.
04. Desplegar en VPS solo artefactos firmados o identificados por SHA exacto luego de los checks. Evitar cambios directos manuales sobre produccion.
05. Monitorizar CPU, RAM, disco, conexiones MySQL, consultas lentas, 5xx, errores de login, colas, pagos y R2. Alertas antes de agotar capacidad.

06. Respaldar MySQL fuera del VPS (R2 bucket privado separado), con cifrado, checksum, rotacion y prueba periodica de restauración; no confiar solo en snapshots del hosting.
07. RPO, RTO, disponibilidad, costos de R2 y dimensionamiento se fijan con pruebas reales del VPS, sin inventar garantias de produccion.
08. Mientras no exista cuenta PSP formal y acuerdos regulatorios, mantener pagos reales OFF y usar sandbox/datos ficticios. Redes sociales con credenciales separadas y APIs oficiales.

35.3. Decisiones pendientes que no alteran las cuatro plataformas

Decisión	Estado de diseño	Criterio de cierre
Versiones Angular/Node/.NET/MySQL	Por fijar al inicio del repositorio	Elegir estables compatibles y pin de versiones.
Capacidad VPS	Por medir	CPU, memoria, SSD, respaldo, región, ancho de banda, failover.
Reverse proxy	Por decidir dentro del VPS	TLS, dominios, WebSocket, headers y límites.
Cloudflare R2	Proveedor fijado; configuración pendiente	Buckets, permisos, retención, coste, archivos publicos/privados.
Proveedor pagos	Integración externa obligatoria para pagos online	Contrato PSP, sandbox, firma webhook, conciliacion y alcance PCI.
Correo y SMS	Canales externos según necesidades	Reputacion envio, opt-in, entrega, recuperación cuentas.
Wallet y redes	Integración externa por API oficial	Elegibilidad, scopes, licencias y normas de mensajeria.
Documentos legales	Revisión por asesor local	Contratos, consumidor, privacidad, datos sensibles y fiscales.
Backups y DR	Diseño obligatorio, RPO/RTO pendientes	Simulacro de restauracion y evidencias.

Los cuatro proveedores conforman la infraestructura base, pero determinadas funciones del producto usan integraciones externas inevitables (procesador de pagos, correo, WhatsApp/Meta, Google/Apple Wallet y APIs sociales). No son nuevos hosts para frontend/backend/DB y no deben presentarse como una expansion silenciosa de la topologia.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Infraestructura base confirmada: GitHub, Google Drive, Cloudflare y VPS Hostinger. El frontend, backend, workers y MySQL viven en el VPS; Cloudflare R2 guarda todos los medios y documentos.

FRONTEND	Documento/contrato de configuración local y topología futura, sin desplegar nada.
BACKEND	Puertos de integración definidos; SDK externo desacoplado; identidad separada de SOLQARYN.
BASE DE DATOS	Variables de conexión local, estrategias future-ready, nada de DB remota creada.

Prueba de aceptación y riesgo

Positivas / negativas. Sin referencias a Vercel/Render/Aiven/Cloudinary como proveedores base; prohibido conectar producción.

Control crítico. Hostinger, GitHub, Cloudflare, Drive son topología futura; durante esta fase solo código local.

Requisitos de origen que deben rastrearse

GITHUB	**Repositorio privado único del producto; PR, issues, revisiones, CI/CD, releases y artefactos.**
GOOGLE DRIVE	Documentación administrativa del proyecto, especificaciones, decisiones, actas y colaboracion.
CLOUDFLARE	R2 para todos los archivos/medios; DNS, TLS/CDN/WAF si se configuran; observabilidad de trafico.

Fuente completa: 2 tabla(s), 15 filas, 15 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C35-01 Extraer / C35-02 Diseñar / C35-03 Codificar / C35-04 Probar / C35-05 Auditar A / C35-06 Auditar B / C35-07 Auditar C / C35-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

No desplegar. Contratos de cuatro proveedores en repo futuro, dedicado BYODB condicionado y secretos aislados.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 35, rutas y componentes; 15 parrafos sustantivos y 2 tablas originales (15 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CAPÍTULO 36 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

36. Pruebas transversales y condiciones de aceptacion ampliadas

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Estas pruebas son requisitos para el desarrollo, no certificaciones ejecutadas. Cada caso debe tener un test, evidencia, data seed, resultado y responsable.

MEM - Membresias en cualquier sector

Gate	Escenario obligatorio	Evidencia
P0	En tienda de ropa se crea membresia VIP, se aplica descuento correcto y queda registrada su vigencia.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	En cafeteria se vende pase mensual, se valida uso por QR y no se consumen usos de otro tenant.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	En barberia se venden servicios prepagados; no se permite doble canje por requests paralelos.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	En academia se verifican inscripcion, profesor, cupo y asistencia QR; membresia no sustituye autorización.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	En gimnasio se realiza upgrade/downgrade con prorrata, política y cuotas sin perder historial.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Con acceso denegado se informa sin revelar datos sensibles del miembro.	Automática o test guiado, evidencia versionada y resultado requerido.

SCH - Reservas y recursos para todos

Gate	Escenario obligatorio	Evidencia
P0	Dos clientes reservan el último espacio a la vez y solo uno es confirmado en MySQL.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Un cierre festivo invalida nuevos slots pero conserva o reprograma reservas existentes de manera auditada.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	El cliente elige profesional preferido y el servidor respeta horarios, ausencia y cualificacion.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Una reserva pública no muestra detalles privados de empleados, clientes o razones medicas.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	El cambio de turno no rompe duraciones y recursos de reservas concurrentes.	Automática o test guiado, evidencia versionada y resultado requerido.

PAYLINK - Enlace de pago

Gate	Escenario obligatorio	Evidencia
P1	Enlace valido abre desglose; uno vencido, revocado o manipulado no procesa pago.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Alterar tenant, importe, moneda o merchant de la solicitud no altera la obligacion original.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Webhook duplicado o fuera de orden no cobra ni reconoce pago dos veces.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Pago partial/pago fallido/reembolso mantiene conciliacion e historial sin fabricar estado PAGADO.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Link reenviado no expone correo ni pedido de tercero; no se incluye token secreto en logs.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Evento PSP sin firma valida queda rechazado y auditado.	Automática o test guiado, evidencia versionada y resultado requerido.

MEDIA - Archivos Cloudflare

Gate	Escenario obligatorio	Evidencia
P0	Un tenant no puede obtener el asset privado de otro aunque conozca su object_key.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Intentos de subir PDF ejecutable, archivo con extension falsa o imagen maliciosa quedan en cuarentena/rechazo.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Una URL R2 presignada expirada no permite acceso; una URL aún vigente se trata como reutilizable.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	El limite de cuota por empresa se verifica antes y despues de upload y en concurrencia.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	La eliminación valida retención legal; ninguna carpeta privada queda servida por CDN público.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Un respaldo R2 de MySQL permite restauracion aislada con integridad y tenants sin perdida inadvertida.	Automática o test guiado, evidencia versionada y resultado requerido.

DB - Integridad de modelos MySQL

Gate	Escenario obligatorio	Evidencia
P0	FK (tenant_id, customer_id) impide enlazar reserva del tenant A con cliente del B.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	El esquema mantiene 3FN en pedidos, cotizaciones, caja, derechos y consentimiento.	Automática o test guiado, evidencia versionada y resultado requerido.

Gate	Escenario obligatorio	Evidencia
P1	Catalogos activos actualizan selects sin desplegar código; usuarios sin permiso no cambian opciones.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Inventario concurrente con única unidad mantiene saldo no negativo o backorder autorizado.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Un soft delete no pierde relaciones legales, balances ni historial.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Migracion y rollback practican integridad de datos y respaldos.	Automática o test guiado, evidencia versionada y resultado requerido.

UX - Interfaces dinámicas

Gate	Escenario obligatorio	Evidencia
P1	Cliente mueve tarjetas, cambia tema y previsualiza responsive sin ejecutar JS arbitrario.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	La publicación cambia solo sitio/autorización del tenant y puede revertirse.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Tabla con 100k registros página en servidor y mantiene permisos en cada filtro/exportacion.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Los iconos tienen tooltip, aria-label, navegacion teclado y alternativa móvil.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Un modal cierra con teclado, mantiene foco y no muestra datos sin permiso.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Campos obligatorios y variantes por rubro validan errores accesibles.	Automática o test guiado, evidencia versionada y resultado requerido.

RES - Clientes e interacciones

Gate	Escenario obligatorio	Evidencia
P0	Cada negocio conserva historial de clientes por tenant y plataforma conserva historial de empresas distinto.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	No se cruzan interacciones de un cliente entre negocios por email igual.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	La valoracion de empleado se vincula a una atención verificable y evita spam.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Incidente de cliente requiere hechos, evidencia y revisión, no lista negra pública.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Programa de fidelidad QR maneja canjes atomicos y revocacion.	Automática o test guiado, evidencia versionada y resultado requerido.

OPS/LEGAL - Operación y cumplimiento

Gate	Escenario obligatorio	Evidencia
P0	El pipeline bloquea commit que falla security checks, tenant tests o pruebas criticas.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	MySQL no expone puerto público y el acceso SSH está endurecido.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Un contrato/publicación conserva terminos aceptados y version del documento.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Pagos, fotos y datos de menores siguen políticas y permisos propios del tenant.	Automática o test guiado, evidencia versionada y resultado requerido.
P1	Cada plan puede habilitar funciones transversales sin modificar código fuente.	Automática o test guiado, evidencia versionada y resultado requerido.
P0	Se puede operar con perdida temporal de R2 o PSP sin corromper pedidos ni reservas.	Automática o test guiado, evidencia versionada y resultado requerido.

36.1. Regla de cierre para cada módulo universal

Un módulo solo se aprueba cuando su esquema y reglas tienen evidencia de: aislamiento por tenant, rol/accion, validación de input y tipos, datos completos, migraciones, pruebas de concurrencia si aplica, accesibilidad, responsive, logs sin secretos, estados, auditoría, rollback, documentación y respaldo. Debe probarse en al menos dos rubros diferentes, y en un tercero cuando existe riesgo especifico, para demostrar que no se hardcodeo el dominio.

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Estas pruebas son requisitos para el desarrollo, no certificaciones ejecutadas. Cada caso debe tener un test, evidencia, data seed, resultado y responsable.

FRONTEND	**E2E y capturas visuales por flujo y sector; accesibilidad y responsive en múltiples tamaños.**
BACKEND	Suites negativas extendidas y escenarios de fallos idempotentes por módulo.
BASE DE DATOS	Pruebas de límites, integridad, rendimiento, reintentos y regresión.

Prueba de aceptación y riesgo

Positivas / negativas. Cobertura cada escenario adicional con resultados reproducibles y evidencias enlazadas.

Control crítico. No usar capturas para probar backend o seguridad real.

Requisitos de origen que deben rastrearse

P0	**En tienda de ropa se crea membresia VIP, se aplica descuento correcto y queda registrada su vigencia.**
P0	En cafeteria se vende pase mensual, se valida uso por QR y no se consumen usos de otro tenant.
P0	En barberia se venden servicios prepagados; no se permite doble canje por requests paralelos.

Fuente completa: 8 tabla(s), 54 filas, 11 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C36-01 Extraer / C36-02 Diseñar / C36-03 Codificar / C36-04 Probar / C36-05 Auditar A / C36-06 Auditar B / C36-07 Auditar C / C36-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Matriz transversal automatizada: cross-tenant, SuperAdmin, restore, cache, sesiones, DB dedicated y accesibilidad.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 36, rutas y componentes; 11 parrafos sustantivos y 8 tablas originales (54 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

Integración transversal · G.7 Seguimiento universal

Incluir regresión de suite UC-001..UC-042 por rol, tenant SHARED/DEDICATED, concurrencia, cierre, móvil, recuperación, websocket y archivos.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

CAPÍTULO 37 DE 37 | FUENTE + IMPLEMENTACIÓN + AUDITORÍA

37. Referencias normativas y técnicas

FUENTE ORIGINAL | Contenido integro del diseño de 5 de noviembre de 2026: sin suprimir subapartados, requisitos ni filas de tablas.

Cloudflare R2 - Presigned URLs: https://developers.cloudflare.com/r2/api/s3/presigned-urls/

Cloudflare R2 - Pricing and operations: https://developers.cloudflare.com/r2/pricing/

Cloudflare Images - Optimization options: https://developers.cloudflare.com/images/pricing/

Cloudflare Stream - Video (optional paid): https://developers.cloudflare.com/stream/pricing/

MySQL 8.4 InnoDB Foreign Key Constraints: https://dev.mysql.com/doc/refman/8.4/en/create-table-foreign-keys.html

MySQL 8.4 Check Constraints: https://dev.mysql.com/doc/refman/8.4/en/create-table-check-constraints.html

Las siguientes publicaciones son referencias técnicas para las futuras fases de implementación. Sus requisitos deberán verificarse sobre versiones precisas al momento de programar y desplegar.

NIST SP 800-63B-4 — autenticación y autenticadores: https://csrc.nist.gov/pubs/sp/800/63/b/4/final

OWASP ASVS 5.0.0 — marco de verificación de seguridad: https://github.com/OWASP/ASVS/tree/v5.0.0

OWASP Forgot Password Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html

OWASP Multi-Tenant Security Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Multi_Tenant_Security_Cheat_Sheet.html

OWASP Choosing and Using Security Questions: https://cheatsheetseries.owasp.org/cheatsheets/Choosing_and_Using_Security_Questions_Cheat_Sheet.html

OWASP Authorization Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

OWASP File Upload Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

OWASP Password Storage Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

OWASP Logging Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

OWASP API Security Top 10: https://owasp.org/API-Security/

MySQL 8.4 InnoDB transaction model: https://dev.mysql.com/doc/refman/8.4/en/innodb-transaction-model.html

MySQL 8.4 Deadlocks: https://dev.mysql.com/doc/refman/8.4/en/innodb-deadlocks.html

WebAuthn / FIDO2 — W3C: https://www.w3.org/TR/webauthn-3/

WCAG 2.2 — W3C: https://www.w3.org/TR/WCAG22/

PCI Security Standards Council: https://www.pcisecuritystandards.org/

Hostinger — documentación VPS/Docker: https://www.hostinger.com/support/

Microsoft ASP.NET Core security: https://learn.microsoft.com/aspnet/core/security/

Docker Compose documentation: https://docs.docker.com/compose/

Google Wallet API documentation: https://developers.google.com/wallet

Apple Wallet passes documentation: https://developer.apple.com/wallet/

MapLibre GL JS: https://maplibre.org/maplibre-gl-js/docs/

OpenFreeMap: https://openfreemap.org/

Contrato de implementación y certificación del capítulo

Plan de trabajo precedente integrado; debe ejecutarse como una única unidad de avance. Las pruebas aqui descritas son criterios a demostrar, no resultados realizados.

ESTADO: PENDIENTE DE IMPLEMENTACIÓN Y CERTIFICACIÓN · DESARROLLO LOCAL

Intención documentada. Cloudflare R2 - Presigned URLs: https://developers.cloudflare.com/r2/api/s3/presigned-urls/

FRONTEND	Documentar referencias de a11y, Angular y patrones UI sin copiar bibliotecas prohibidas.
BACKEND	ADR y referencias normativas / .NET / OWASP con versión, fecha y licencia.
BASE DE DATOS	Normas MySQL, SQL, privacidad y trazabilidad de permisos/retención.

Prueba de aceptación y riesgo

Positivas / negativas. Referencias resolubles y licencias compatibles; citas de fuentes actualizadas.

Control crítico. No importar código, licencia o arquitectura de SOLQARYN; solo consulta autorizada.

Requisitos de origen que deben rastrearse

Capítulo de referencias y normas: trazabilidad de sus párrafos completos en el anexo íntegro y verificación de enlaces/licencias.

Fuente completa: 0 tabla(s), 0 filas, 29 párrafos. Véase original y anexo textual; los tres ejemplos anteriores no sustituyen cobertura total.

Secuencia y auditorías (evidencia por completar)

- C37-01 Extraer / C37-02 Diseñar / C37-03 Codificar / C37-04 Probar / C37-05 Auditar A / C37-06 Auditar B / C37-07 Auditar C / C37-08 Acta.

AUDITORÍA A [ ] AUDITORÍA B [ ] AUDITORÍA C [ ] ACTA [ ] APROBACIÓN [ ] CIERRE [ ]

Control de aislamiento adicional obligatorio

Referencias y controles reflejan OWASP tenancy y privilegios MySQL sin fingir certificación externa.

También ejecutar TEN-001/TEN-002/TEN-008/TEN-009/TEN-010/TEN-021/TEN-032 si la superficie del capítulo lo permite; documentar NO APLICA con razon verificable en casos sin datos o interfaz.

A. Producto / requisito | Mapa del capítulo 37, rutas y componentes; 29 parrafos sustantivos y 0 tablas originales (0 filas incl. encabezados).

B. Seguridad / tenant | Pruebas positivas/negativas de roles, cache, bitácora y placement SHARED/DEDICATED segun impacto.

C. Código / calidad | Compilacion, pruebas, UI/rendimiento si aplica, revisión de cambios y rollback.

Cierre | Acta, hash local, registros de prueba y aprobación. Sin evidencia = NO CERTIFICADO.

CIERRE NORMATIVO

Integración transversal · G.7 Seguimiento universal

Ampliar referencias sobre evidencia electrónica, autorizaciones, protección de archivos, OWASP ASVS/tenant, retención y firma aplicable; sin inventar validez jurídica.

Estado de esta integración: ESPECIFICADO / PENDIENTE DE CÓDIGO Y PRUEBAS. No acredita certificación del capítulo.

Decisiones, restricciones y estado real

Veredicto documental del nuevo módulo universal

La especificación universal de seguimiento, observaciones, aprobaciones, evidencias, notificaciones y cierre queda integrada en este mismo documento y trazada a los 37 capítulos. No hay un “capítulo 38”, ni dos planes paralelos, ni validaciones técnicas fabricadas. Se requiere implementar el software uno a uno, ejecutar UC-001..UC-042 con evidencia y superar auditorías A/B/C; toda brecha descubierta se registra y bloquea el cierre de su microtarea.

VI · Decisiones abiertas y prohibiciones

ID	Decisión / evidencia	Estado actual	Acción antes de aprobar
ADR-001	Monolito modular vs microservicios físicamente separados	Monolito modular recomendado; microservicios distribuidos ABIERTO	Probar cargas, equipo, costes y límites de módulos; dueño decide
ADR-002	Node.js	Fijar major 24 por instrucción del propietario	Test Angular 22/Node 24.22.2/TS6.0 y npm lock
ADR-003	Angular, Material y librerías	Angular 22 propuesto; no asumir versión final	Alinear patches y compilar con Node 24
ADR-004	Backend/EF/MySQL	.NET10 LTS + EF10 + Oracle MySQL Provider candidatos	Migración/locking/transacciones/EF material tests
ADR-005	SSR/híbrido vs SPA	ABIERTO	Medir SEO, LCP y coste del runtime local
ADR-006	Dominio `crecisol.com`	Usuario afirma titularidad; comprobación técnica diferida	Validar con registrador/DNS/TLS solo cuando se autorice, no ahora
ADR-007	Razón social real, fiscalidad y remitentes	NO ACREDITADOS en documento	Identidad legal real y revisión jurídico-fiscal antes de publicación
ADR-008	PSP/pagos reales	ABIERTO y diferido	Sandbox, afiliación, webhooks, regulación Honduras y conciliar cuando toque
ADR-009	Hostinger VPS, Cloudflare, GitHub, Google Drive	Topología futura fijada por usuario; NO OPERAR AHORA	Capítulos 24/25/35 solo contratos locales ahora
ADR-010	CDN, conversión Office y análisis de archivos	Capacidad funcional obligatoria; implementación no terminada	Evaluar seguridad, licencias, límites de conversión en local
ADR-011	Límites de escalabilidad/p95/bytes por ruta	Sin mediciones reales	Crear benchmark y fijar presupuesto tras medir

ID	Decisión / evidencia	Estado actual	Acción antes de aprobar
ADR-012	Alcance sectores con salud/niñez/biometría	Condicionado en original	No activar sin evaluación legal y seguridad específica
ADR-013	Stack UI/estilos/iconos	Un design system requerido; biblioteca exacta abierta	Accesibilidad, licencia, bundle y personalización segura
ADR-014	Compatibilidad de provider Oracle `MySql.EntityFrameworkCore 10.0.12` / EF 10.0.14	Paquetes publicados, prueba end-to-end no ejecutada	No certificar EF hasta compilar migraciones y CRUD con MySQL 8.4

Prohibiciones: no importar código o secrets de SOLQARYN; no crear GitHub ni desplegar por inferencia; no afirmar pruebas ejecutadas por solo redactar criterios. El cumplimiento perfecto se valida con evidencia y hallazgos P0/P1=0, nunca se garantiza por adelantado.

VII · Estado real de ejecución

Corte: 2026-11-07. No hay certificaciones de código nuevas acreditadas por esta consolidación.

Intervalo	Estado	Evidencia
C01	`DOCUMENTADO / STARTER PARCIAL`	Contratos y esquema semilla en `frontend/`, `backend/`, `database/`; no compilado ni integrado real
C02–C07	`DOCUMENTADO / NO IMPLEMENTADO`	Auditoría histórica 01–07 disponible en archivo anterior, sin pruebas del SaaS
C08–C37	`PLANIFICADO / NO IMPLEMENTADO`	Fichas por capítulo, matriz íntegra y gates
Programa	`NO CERTIFICADO`	Requiere revisión secuencial, compilación y QA triple por capítulo

El histórico de prototipos HTML de planificación no es código de negocio productivo. No se hereda ningún estado “CERTIFICADO” de esos tableros.

Plantilla de acta CXX

- Capítulo, versión de fuente, cobertura párrafos/tablas, archivos exactos y hash.
- Requisitos y no-gos; casos de uso y datos; permisos y ámbito tenant.
- Resultado real de build Node24/Angular, dotnet10 y MySQL8.4 donde aplique.
- Auditoría A — pruebas y evidencia, issues y cierre.
- Auditoría B — ataques negativos, integridad y evidencia, issues y cierre.
- Auditoría C — arquitectura, visual, métricas, rollback y evidencia, issues y cierre.
- Dictamen CERTIFICADO, BLOQUEADO o PENDIENTE con identidad/responsable/fecha.

VIII · Capítulo 01: inicio y siguientes microtareas

No certificado / starter local parcial. Fuente: 3 tablas, 24 filas (incluye encabezados), 34 párrafos. Esto es el contrato de desarrollo detallado, no un acta de ejecución.

Secuencia de microtareas de código

- C01-01 Extraer identidad, marca, seis superficies de publicación, límites y matrices de aceptación desde fuente original; rastrear 100% de filas/párrafos. Entregable: C01_REQUIREMENTS.json.

- C01-02 Definir PlatformBrand tipado y snapshots versionados; diferenciar visual/comercial vs jurídico; especificar variables brand.name, brand.tagline, domain.canonical, legal.owner, footer.copyright. Entregable: contratos Domain+Application.
- C01-03 Modelar migración MySQL 3FN de identidad global con versiones, auditoría, textos multilenguaje y restricción de único snapshot publicado, sin tabla EAV genérica. Entregable: SQL y pruebas.
- C01-04 Crear endpoint mínimo público que entrega únicamente PublishedBrandSnapshot desde storage/seed de desarrollo. El frontend no contiene nombre duplicado fuera del contrato seed. Entregable: API y frontend integrados.
- C01-05 Construir landing editorial básica y pie con copyright parametrizado, design tokens, iconos semánticos; preview al editar y post-guardado en futuro admin seguro. Entregable: UX accesible y responsive.
- C01-06 Integrar administración cuando exista auth/roles de capítulos 05/06: por ahora solo readonly / mock sintético; no exponer escritura sin MFA/ABAC.
- C01-07 Tests A: nombre cambiado en único registro/seed afecta cabecera, SEO y footer; copyright SaaS/tenant distintos y no mezclados; slug y dominio no otorgan autorización.
- C01-08 Tests B: XSS/no HTML arbitrario, valores inválidos, host malicioso, seed jurídico faltante, no fuga de campos privados.
- C01-09 Tests C: compilar Node24+Angular22, net10, ejecutar tests e inspección visual móvil/tablet/escritorio con capturas; registrar métricas y esquema; pendiente de herramienta compatible.
- C01-10 Triple auditoría y acta de aceptación; sin certificación hasta evidencia positiva, negativa, docs, hash y aprobación.

Criterios no negociables del capítulo

- CRECISOL conserva eslogan y descriptor actuales, pero su valor viene de configuración central editable; no aparece texto duplicado en 50 componentes.
- crecisol.com: el usuario afirma propiedad; antes de usarlo como dominio canónico verificado falta comprobación técnica autorizada en etapa futura.
- La relación de marca “una plataforma de SOLQARYN” es dato editorial, no acceso a repo/credenciales/usuarios SOLQARYN.
- No emitir copyright jurídico a nombre de una persona no acreditada; conservar estado pendiente y emisor independiente por ámbito.
- Nadie podrá editar validación, antifraude, permisos, SQL o lógica ejecutable desde un constructor visual.
- No cerrar el capítulo mientras no existan versiones compiladas y tests ejecutados. El código semilla puede ser demostrativo, pero jamás declarado certificado.

Documentación fuente, evidencia y referencias

Anexo fuente exacta: ORIGINAL_SIN_MODIFICACIONES.docx, índice DOCUMENTO_ORIGINAL_INDICE_INTEGRO.json, transcripción 05_TRAZABILIDAD_ORIGINAL_COMPLETA.md y hash DOCUMENTO_ORIGINAL_SHA256.txt. Este documento printable es operativo; la extracción íntegra constituye el mecanismo de control contra omisiones.

Panel de conformidad del documento maestro

Punto de control	Estado documental	Condicion para certificar código
Integridad del origen	37/37 capítulos, 84 tablas originales, 1,024 filas incluida cabecera.	Trazabilidad requisito->ruta->test->evidencia por capítulo.
Criterios anteriores de desarrollo	Integrados en apartados normativos y fichas 01-37.	Revisión, implementación y compilacion por capítulo.
Nuevo aislamiento	SHARED+DEDICATED y 32 pruebas P0 definidas.	Ejecución automatizada real para A/B y tenant dedicado.
SuperAdmin	Gobierno global y vista de todas las pantallas con soporte justificado.	MFA, grant, redaccion PII, doble auditoría e2e.
Cuentas y perfiles de todos los actores	Registro, foto, contacto, contraseñas, passkeys y recuperación protegidos por realm y tenant.	IDN-001..IDN-020 ejecutadas; negativos en URL, navegador y medios.
Inicio de sesión sin selector	Resuelve tenant automáticamente por contexto verificable y membresía; multitenant ambiguo bloqueado.	AUTO-001..012 ejecutados contra SHARED/DEDICATED, URL y navegador; SuperAdmin desde gestor.
Auditoría privada	TENANT_AUDIT separada de PLATFORM_AUDIT.	Pruebas de lectura/escritura/falsificacion y retención.
Parametrización	ConfigKeyRegistry, schemas, drafts/previews/versiones.	Actualizaciones sin cambiar archivos de UI y regresion.
Estado real del software	SIN CERTIFICACIÓN; este entregable es documental.	37/37 cierres con logs y auditoría global de código local.

Referencias tecnicas consultables

https://cheatsheetseries.owasp.org/cheatsheets/Multi_Tenant_Security_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

https://dev.mysql.com/doc/refman/8.4/en/privileges-provided.html

https://dev.mysql.com/doc/refman/8.4/en/stored-objects-security.html

https://angular.dev/reference/versions

https://dotnet.microsoft.com/en-us/platform/support/policy

https://nodejs.org/en/download

Huella de fuentes recibidas

CRECISOL_Diseno_Maestro_SaaS_Multitenant_FINAL(1).docx SHA-256: 7ab9e56a11a4a6332597f5897ecf2506584cc2aed75c093d8dcb60366677f6f9

CRECISOL_PLAN_MAESTRO_DESARROLLO_LOCAL_v2(1).docx SHA-256: 15a40dd7cd9b47699b4fbc99fd297abd6579ac414c6b9939e8438677532db83c

CRECISOL_MAESTRO_CONSOLIDADO_COMPLETO_v2_IMPRIMIR(1).pdf SHA-256: be95c1cb4df6d7eb2064893e0d898b6de162a193a2866a10b62cbb73682d3e54

Ninguna de estas huellas demuestra por si sola pruebas funcionales de software; solamente identifica las entradas documentales consolidadas.